

PECB

ISO-IEC-27001-LEAD-IMPLEMENTER Exam

ISO/IEC 27001 Lead Implementer

THANK YOU
FOR YOUR PURCHASED

QUESTIONS & ANSWERS
(RETAIL VERSION - FULL QUESTIONS SET)

WWW.STUDY4EXAM.COM



Product Questions: 290

Version: 9.3

Question: 1

Scenario 1: HealthGenic is a pediatric clinic that monitors the health and growth of individuals from infancy to early adulthood using a web-based medical software. The software is also used to schedule appointments, create customized medical reports, store patients' data and medical history, and communicate with all the involved parties, including parents, other physicians, and the medical laboratory staff.

Last month, HealthGenic experienced a number of service interruptions due to the increased number of users accessing the software. Another issue the company faced while using the software was the complicated user interface, which the untrained personnel found challenging to use. The top management of HealthGenic immediately informed the company that had developed the software about the issue. The software company fixed the issue; however, in the process of doing so, it modified some files that comprised sensitive information related to HealthGenic's patients. The modifications that were made resulted in incomplete and incorrect medical reports and, more importantly, invaded the patients' privacy.

Based on the scenario above, answer the following question:

Which of the following indicates that the confidentiality of information was compromised?

- A. Service interruptions due to the increased number of users
- B. Invasion of patients' privacy
- C. Modification of patients' medical reports

Answer: B

Question: 2

Scenario 1: HealthGenic is a pediatric clinic that monitors the health and growth of individuals from infancy to early adulthood using a web-based medical software. The software is also used to schedule appointments, create customized medical reports, store patients' data and medical history, and communicate with all the involved parties, including parents, other physicians, and the

medical laboratory staff.

Last month, HealthGenic experienced a number of service interruptions due to the increased number of users accessing the software. Another issue the company faced while using the software was the complicated user interface, which the untrained personnel found challenging to use. The top management of HealthGenic immediately informed the company that had developed the software about the issue. The software company fixed the issue; however, in the process of doing so, it modified some files that comprised sensitive information related to HealthGenic's patients. The modifications that were made resulted in incomplete and incorrect medical reports and, more importantly, invaded the patients' privacy.

Based on scenario 1, what is a potential impact of the loss of integrity of information in HealthGenic?

- A. Disruption of operations and performance degradation
- B. Incomplete and incorrect medical reports
- C. Service interruptions and complicated user interface

Answer: B

Question: 3

Scenario 1: HealthGenic is a pediatric clinic that monitors the health and growth of individuals from infancy to early adulthood using a web-based medical software. The software is also used to schedule appointments, create customized medical reports, store patients' data and medical history, and communicate with all the involved parties, including parents, other physicians, and the medical laboratory staff.

Last month, HealthGenic experienced a number of service interruptions due to the increased number of users accessing the software. Another issue the company faced while using the software was the complicated user interface, which the untrained personnel found challenging to use. The top management of HealthGenic immediately informed the company that had developed the software about the issue. The software company fixed the issue; however, in the process of doing so, it modified some files that comprised sensitive information related to HealthGenic's patients. The modifications that were made resulted in incomplete and incorrect medical reports and, more importantly, invaded the patients' privacy.

Intrinsic vulnerabilities, such as the _____ are related to the characteristics of the asset. Refer to scenario 1.

- A. Software malfunction
- B. Service interruptions
- C. Complicated user interface

Answer: C

Question: 4

Scenario 1: HealthGenic is a pediatric clinic that monitors the health and growth of individuals from infancy to early adulthood using a web-based medical software. The software is also used to schedule appointments, create customized medical reports, store patients' data and medical history, and communicate with all the [^involved parties, including parents, other physicians, and the medical laboratory staff.

Last month, HealthGenic experienced a number of service interruptions due to the increased number of users accessing the software. Another issue the company faced while using the software was the complicated user interface, which the untrained personnel found challenging to use. The top management of HealthGenic immediately informed the company that had developed the software about the issue. The software company fixed the issue; however, in the process of doing so, it modified some files that comprised sensitive information related to HealthGenic's patients. The modifications that were made resulted in incomplete and incorrect medical reports and, more importantly, invaded the patients' privacy.

Which situation described in scenario 1 represents a threat to HealthGenic?

- A. HealthGenic did not train its personnel to use the software
- B. The software company modified information related to HealthGenic's patients
- C. HealthGenic used a web-based medical software for storing patients' confidential information

Answer: B

Question: 5

Scenario 1: HealthGenic is a pediatric clinic that monitors the health and growth of individuals from infancy to early adulthood using a web-based medical software. The software is also used to schedule appointments, create customized medical reports, store patients' data and medical history, and communicate with all the [^involved parties, including parents, other physicians, and the medical laboratory staff.

Last month, HealthGenic experienced a number of service interruptions due to the increased number of users accessing the software. Another issue the company faced while using the software was the complicated user interface, which the untrained personnel found challenging to use. The top management of HealthGenic immediately informed the company that had developed the software about the issue. The software company fixed the issue; however, in the process of doing so, it modified some files that comprised sensitive information related to HealthGenic's patients. The modifications that were made resulted in incomplete and incorrect medical reports and, more importantly, invaded the patients' privacy.

In scenario 1, HealthGenic experienced a number of service interruptions due to the loss of functionality of the software. Which principle of information security has been affected in this case?

- A. Availability

- B. Confidentiality
- C. Integrity

Answer: A

Question: 6

Scenario 2: Beauty is a cosmetics company that has recently switched to an e-commerce model, leaving the traditional retail. The top management has decided to build their own custom platform in-house and outsource the payment process to an external provider operating online payments systems that support online money transfers.

Due to this transformation of the business model, a number of security controls were implemented based on the identified threats and vulnerabilities associated to critical assets. To protect customers' information. Beauty's employees had to sign a confidentiality agreement. In addition, the company reviewed all user access rights so that only authorized personnel can have access to sensitive files and drafted a new segregation of duties chart.

However, the transition was difficult for the IT team, who had to deal with a security incident not long after transitioning to the e-commerce model. After investigating the incident, the team concluded that due to the out-of-date anti-malware software, an attacker gained access to their files and exposed customers' information, including their names and home addresses.

The IT team decided to stop using the old anti-malware software and install a new one which would automatically remove malicious code in case of similar incidents. The new software was installed in every workstation within the company. After installing the new software, the team updated it with the latest malware definitions and enabled the automatic update feature to keep it up to date at all times. Additionally, they established an authentication process that requires a user identification and password when accessing sensitive information.

In addition, Beauty conducted a number of information security awareness sessions for the IT team and other employees that have access to confidential information in order to raise awareness on the importance of system and network security.

Based on the scenario above, answer the following question:

After investigating the incident. Beauty decided to install a new anti-malware software. What type of security control has been implemented in this case?

- A. Preventive
- B. Detective
- C. Corrective

Answer: A

Question: 7

Scenario 2: Beauty is a cosmetics company that has recently switched to an e-commerce model,

leaving the traditional retail. The top management has decided to build their own custom platform in-house and outsource the payment process to an external provider operating online payments systems that support online money transfers.

Due to this transformation of the business model, a number of security controls were implemented based on the identified threats and vulnerabilities associated to critical assets. To protect customers' information. Beauty's employees had to sign a confidentiality agreement. In addition, the company reviewed all user access rights so that only authorized personnel can have access to sensitive files and drafted a new segregation of duties chart.

However, the transition was difficult for the IT team, who had to deal with a security incident not long after transitioning to the e commerce model. After investigating the incident, the team concluded that due to the out-of-date anti-malware software, an attacker gamed access to their files and exposed customers' information, including their names and home addresses.

The IT team decided to stop using the old anti-malware software and install a new one which would automatically remove malicious code in case of similar incidents. The new software was installed in every workstation within the company. After installing the new software, the team updated it with the latest malware definitions and enabled the automatic update feature to keep it up to date at all times. Additionally, they established an authentication process that requires a user identification and password when accessing sensitive information.

In addition, Beauty conducted a number of information security awareness sessions for the IT team and other employees that have access to confidential information in order to raise awareness on the importance of system and network security.

Which statement below suggests that Beauty has implemented a managerial control that helps avoid the occurrence of incidents? Refer to scenario 2.

- A. Beauty's employees signed a confidentiality agreement
- B. Beauty conducted a number of information security awareness sessions for the IT team and other employees that have access to confidential information
- C. Beauty updated the segregation of duties chart

Answer: B

Question: 8

Scenario 2: Beauty is a cosmetics company that has recently switched to an e-commerce model, leaving the traditional retail. The top management has decided to build their own custom platform in-house and outsource the payment process to an external provider operating online payments systems that support online money transfers.

Due to this transformation of the business model, a number of security controls were implemented based on the identified threats and vulnerabilities associated to critical assets. To protect customers' information. Beauty's employees had to sign a confidentiality agreement. In addition, the company reviewed all user access rights so that only authorized personnel can have access to sensitive files and drafted a new segregation of duties chart.

However, the transition was difficult for the IT team, who had to deal with a security incident not long after transitioning to the e commerce model. After investigating the incident, the team concluded that due to the out-of-date anti-malware software, an attacker gamed access to their files

and exposed customers' information, including their names and home addresses.

The IT team decided to stop using the old anti-malware software and install a new one which would automatically remove malicious code in case of similar incidents. The new software was installed in every workstation within the company. After installing the new software, the team updated it with the latest malware definitions and enabled the automatic update feature to keep it up to date at all times. Additionally, they established an authentication process that requires a user identification and password when accessing sensitive information.

In addition, Beauty conducted a number of information security awareness sessions for the IT team and other employees that have access to confidential information in order to raise awareness on the importance of system and network security.

According to scenario 2. Beauty has reviewed all user access rights. What type of control is this?

- A. Detective and administrative
- B. Corrective and managerial
- C. Legal and technical

Answer: A

Question: 9

Scenario 2: Beauty is a cosmetics company that has recently switched to an e-commerce model, leaving the traditional retail. The top management has decided to build their own custom platform in-house and outsource the payment process to an external provider operating online payments systems that support online money transfers.

Due to this transformation of the business model, a number of security controls were implemented based on the identified threats and vulnerabilities associated to critical assets. To protect customers' information. Beauty's employees had to sign a confidentiality agreement. In addition, the company reviewed all user access rights so that only authorized personnel can have access to sensitive files and drafted a new segregation of duties chart.

However, the transition was difficult for the IT team, who had to deal with a security incident not long after transitioning to the e-commerce model. After investigating the incident, the team concluded that due to the out-of-date anti-malware software, an attacker gained access to their files and exposed customers' information, including their names and home addresses.

The IT team decided to stop using the old anti-malware software and install a new one which would automatically remove malicious code in case of similar incidents. The new software was installed in every workstation within the company. After installing the new software, the team updated it with the latest malware definitions and enabled the automatic update feature to keep it up to date at all times. Additionally, they established an authentication process that requires a user identification and password when accessing sensitive information.

In addition, Beauty conducted a number of information security awareness sessions for the IT team and other employees that have access to confidential information in order to raise awareness on the importance of system and network security.

Based on scenario 2, Beauty should have implemented (1)_____ to

detect (2)_____.

- A. (1) An access control software, (2) patches
- B. (1) Network intrusions, (2) technical vulnerabilities
- C. (1) An intrusion detection system, (2) intrusions on networks

Answer: C

Question: 10

Scenario 2: Beauty is a cosmetics company that has recently switched to an e-commerce model, leaving the traditional retail. The top management has decided to build their own custom platform in-house and outsource the payment process to an external provider operating online payments systems that support online money transfers.

Due to this transformation of the business model, a number of security controls were implemented based on the identified threats and vulnerabilities associated to critical assets. To protect customers' information. Beauty's employees had to sign a confidentiality agreement. In addition, the company reviewed all user access rights so that only authorized personnel can have access to sensitive files and drafted a new segregation of duties chart.

However, the transition was difficult for the IT team, who had to deal with a security incident not long after transitioning to the e-commerce model. After investigating the incident, the team concluded that due to the out-of-date anti-malware software, an attacker gained access to their files and exposed customers' information, including their names and home addresses.

The IT team decided to stop using the old anti-malware software and install a new one which would automatically remove malicious code in case of similar incidents. The new software was installed in every workstation within the company. After installing the new software, the team updated it with the latest malware definitions and enabled the automatic update feature to keep it up to date at all times. Additionally, they established an authentication process that requires a user identification and password when accessing sensitive information.

In addition, Beauty conducted a number of information security awareness sessions for the IT team and other employees that have access to confidential information in order to raise awareness on the importance of system and network security.

Based on scenario 2, which information security principle is the IT team aiming to ensure by establishing a user authentication process that requires user identification and password when accessing sensitive information?

- A. Integrity
- B. Confidentiality
- C. Availability

Answer: B

Question: 11

FinanceX, a well-known financial institution, uses an online banking platform that enables clients to easily and securely access their bank accounts. To log in, clients are required to enter the one-time authorization code sent to their smartphone. What can be concluded from this scenario?

- A. FinanceX has implemented a security control that ensures the confidentiality of information
- B. FinanceX has implemented an integrity control that avoids the involuntary corruption of data
- C. FinanceX has incorrectly implemented a security control that could become a vulnerability

Answer: A

Question: 12

An employee of the organization accidentally deleted customers' data stored in the database. What is the impact of this action?

- A. Information is not accessible when required
- B. Information is modified in transit
- C. Information is not available to only authorized users

Answer: A

Question: 13

Which of the following statements regarding information security risk is NOT correct?

- A. Information security risk is associated with the potential that the vulnerabilities of an information asset may be exploited by threats
- B. Information security risk cannot be accepted without being treated or during the process of risk treatment
- C. Information security risk can be expressed as the effect of uncertainty on information security objectives

Answer: B

Question: 14

The IT Department of a financial institution decided to implement preventive controls to avoid

potential security breaches. Therefore, they separated the development, testing, and operating equipment, secured their offices, and used cryptographic keys. However, they are seeking further measures to enhance their security and minimize the risk of security breaches. Which of the following controls would help the IT Department achieve this objective?

- A. Alarms to detect risks related to heat, smoke, fire, or water
- B. Change all passwords of all systems
- C. An access control software to restrict access to sensitive files

Answer: C

Question: 15

Diana works as a customer service representative for a large e-commerce company. One day, she accidentally modified the order details of a customer without their permission. Due to this error, the customer received an incorrect product. Which information security principle was breached in this case?

- A. Availability
- B. Confidentiality
- C. Integrity

Answer: C

Question: 16

Scenario 3: Socket Inc is a telecommunications company offering mainly wireless products and services. It uses MongoDB, a document model database that offers high availability, scalability, and flexibility.

Last month, Socket Inc. reported an information security incident. A group of hackers compromised its MongoDB database, because the database administrators did not change its default settings, leaving it without a password and publicly accessible.

Fortunately, Socket Inc. performed regular information backups in their MongoDB database, so no information was lost during the incident. In addition, a syslog server allowed Socket Inc. to centralize all logs in one server. The company found out that no persistent backdoor was placed and that the attack was not initiated from an employee inside the company by reviewing the event logs that record user faults and exceptions.

To prevent similar incidents in the future, Socket Inc. decided to use an access control system that grants access to authorized personnel only. The company also implemented a control in order to define and implement rules for the effective use of cryptography, including cryptographic key management, to protect the database from unauthorized access. The implementation was based on all relevant agreements, legislation, and regulations, and the information classification scheme. To improve security and reduce the administrative efforts, network segregation using VPNs was

proposed.

Lastly, Socket Inc. implemented a new system to maintain, collect, and analyze information related to information security threats, and integrate information security into project management.

Based on the scenario above, answer the following question:

Which security control does NOT prevent information security incidents from recurring?

- A. Segregation of networks
- B. Privileged access rights
- C. Information backup

Answer: C

Question: 17

Scenario 3: Socket Inc is a telecommunications company offering mainly wireless products and services. It uses MongoDB, a document model database that offers high availability, scalability, and flexibility.

Last month, Socket Inc. reported an information security incident. A group of hackers compromised its MongoDB database, because the database administrators did not change its default settings, leaving it without a password and publicly accessible.

Fortunately, Socket Inc. performed regular information backups in their MongoDB database, so no information was lost during the incident. In addition, a syslog server allowed Socket Inc. to centralize all logs in one server. The company found out that no persistent backdoor was placed and that the attack was not initiated from an employee inside the company by reviewing the event logs that record user faults and exceptions.

To prevent similar incidents in the future, Socket Inc. decided to use an access control system that grants access to authorized personnel only. The company also implemented a control in order to define and implement rules for the effective use of cryptography, including cryptographic key management, to protect the database from unauthorized access. The implementation was based on all relevant agreements, legislation, and regulations, and the information classification scheme. To improve security and reduce the administrative efforts, network segregation using VPNs was proposed.

Lastly, Socket Inc. implemented a new system to maintain, collect, and analyze information related to information security threats, and integrate information security into project management.

Socket Inc. has implemented a control for the effective use of cryptography and cryptographic key management. Is this compliant with ISO/IEC 27001? Refer to scenario 3.

- A. No, the control should be implemented only for defining rules for cryptographic key management
- B. Yes, the control for the effective use of the cryptography can include cryptographic key management
- C. No, because the standard provides a separate control for cryptographic key management

Answer: B

Question: 18

Scenario 3: Socket Inc is a telecommunications company offering mainly wireless products and services. It uses MongoDB, a document model database that offers high availability, scalability, and flexibility.

Last month, Socket Inc. reported an information security incident. A group of hackers compromised its MongoDB database, because the database administrators did not change its default settings, leaving it without a password and publicly accessible.

Fortunately, Socket Inc. performed regular information backups in their MongoDB database, so no information was lost during the incident. In addition, a syslog server allowed Socket Inc. to centralize all logs in one server. The company found out that no persistent backdoor was placed and that the attack was not initiated from an employee inside the company by reviewing the event logs that record user faults and exceptions.

To prevent similar incidents in the future, Socket Inc. decided to use an access control system that grants access to authorized personnel only. The company also implemented a control in order to define and implement rules for the effective use of cryptography, including cryptographic key management, to protect the database from unauthorized access. The implementation was based on all relevant agreements, legislation, and regulations, and the information classification scheme. To improve security and reduce the administrative efforts, network segregation using VPNs was proposed.

Lastly, Socket Inc. implemented a new system to maintain, collect, and analyze information related to information security threats, and integrate information security into project management.

Can Socket Inc. find out that no persistent backdoor was placed and that the attack was initiated from an employee inside the company by reviewing event logs that record user faults and exceptions? Refer to scenario 3.

- A. Yes. Socket Inc. can find out that no persistent backdoor was placed by only reviewing user faults and exceptions logs
- B. No, Socket Inc should also have reviewed event logs that record user activities
- C. No, Socket Inc. should have reviewed all the logs on the syslog server

Answer: B

Question: 19

Scenario 3: Socket Inc is a telecommunications company offering mainly wireless products and services. It uses MongoDB, a document model database that offers high availability, scalability, and flexibility.

Last month, Socket Inc. reported an information security incident. A group of hackers compromised its MongoDB database, because the database administrators did not change its default settings,

leaving it without a password and publicly accessible.

Fortunately, Socket Inc. performed regular information backups in their MongoDB database, so no information was lost during the incident. In addition, a syslog server allowed Socket Inc. to centralize all logs in one server. The company found out that no persistent backdoor was placed and that the attack was not initiated from an employee inside the company by reviewing the event logs that record user faults and exceptions.

To prevent similar incidents in the future, Socket Inc. decided to use an access control system that grants access to authorized personnel only. The company also implemented a control in order to define and implement rules for the effective use of cryptography, including cryptographic key management, to protect the database from unauthorized access. The implementation was based on all relevant agreements, legislation, and regulations, and the information classification scheme. To improve security and reduce the administrative efforts, network segregation using VPNs was proposed.

Lastly, Socket Inc. implemented a new system to maintain, collect, and analyze information related to information security threats, and integrate information security into project management.

Based on scenario 3, what would help Socket Inc. address similar information security incidents in the future?

- A. Using the MongoDB database with the default settings
- B. Using cryptographic keys to protect the database from unauthorized access
- C. Using the access control system to ensure that only authorized personnel is granted access

Answer: B

Question: 20

Scenario 3: Socket Inc is a telecommunications company offering mainly wireless products and services. It uses MongoDB, a document model database that offers high availability, scalability, and flexibility.

Last month, Socket Inc. reported an information security incident. A group of hackers compromised its MongoDB database, because the database administrators did not change its default settings, leaving it without a password and publicly accessible.

Fortunately, Socket Inc. performed regular information backups in their MongoDB database, so no information was lost during the incident. In addition, a syslog server allowed Socket Inc. to centralize all logs in one server. The company found out that no persistent backdoor was placed and that the attack was not initiated from an employee inside the company by reviewing the event logs that record user faults and exceptions.

To prevent similar incidents in the future, Socket Inc. decided to use an access control system that grants access to authorized personnel only. The company also implemented a control in order to define and implement rules for the effective use of cryptography, including cryptographic key management, to protect the database from unauthorized access. The implementation was based on all relevant agreements, legislation, and regulations, and the information classification scheme. To improve security and reduce the administrative efforts, network segregation using VPNs was proposed.

Lastly, Socket Inc. implemented a new system to maintain, collect, and analyze information related to information security threats, and integrate information security into project management.

Based on scenario 3. which information security control of Annex A of ISO/IEC 27001 did Socket Inc. implement by establishing a new system to maintain, collect, and analyze information related to information security threats?

- A. Annex A 5.5 Contact with authorities
- B. Annex A 5.7 Threat Intelligence
- C. Annex A 5.13 Labeling of information

Answer: B

Question: 21

An organization documented each security control that it implemented by describing their functions in detail. Is this compliant with ISO/IEC 27001?

- A. No, the standard requires to document only the operation of processes and controls, so no description of each security control is needed
- B. No, because the documented information should have a strict format, including the date, version number and author identification
- C. Yes, but documenting each security control and not the process in general will make it difficult to review the documented information

Answer: C

Question: 22

Which security controls must be implemented to comply with ISO/IEC 27001?

- A. Those designed by the organization only
- B. Those included in the risk treatment plan
- C. Those listed in Annex A of ISO/IEC 27001, without any exception

Answer: B

Question: 23

What is the main purpose of Annex A 7.1 Physical security perimeters of ISO/IEC 27001?

- A. To prevent unauthorized physical access, damage, and interference to the organization's information and other associated assets
- B. To maintain the confidentiality of information that is accessible by personnel or external parties
- C. To ensure access to information and other associated assets is defined and authorized

Answer: A

Question: 24

An organization wants to enable the correlation and analysis of security-related events and other recorded data and to support investigations into information security incidents. Which control should it implement?

- A. Use of privileged utility programs
- B. Clock synchronization
- C. Installation of software on operational systems

Answer: B

Question: 25

The incident management process of an organization enables them to prepare for and respond to information security incidents. In addition, the organization has procedures in place for assessing information security events. According to ISO/IEC 27001, what else must an incident management process include?

- A. Processes for using knowledge gained from information security incidents
- B. Establishment of two information security incident response teams
- C. Processes for handling information security incidents of suppliers as defined in their agreements

Answer: A

Question: 26

Who should be involved, among others, in the draft, review, and validation of information security procedures?

- A. An external expert
- B. The information security committee

C. The employees in charge of ISMS operation

Answer: B

Question: 27

An organization has implemented a control that enables the company to manage storage media through their life cycle of use, acquisition, transportation and disposal. Which control category does this control belong to?

- A. Organizational
- B. Physical
- C. Technological

Answer: B

Question: 28

Scenario 4: TradeB, a commercial bank that has just entered the market, accepts deposits from its clients and offers basic financial services and loans for investments. TradeB has decided to implement an information security management system (ISMS) based on ISO/IEC 27001. Having no experience of a management information system implementation, TradeB's top management contracted two experts to direct and manage the ISMS implementation project.

First, the project team analyzed the 93 controls of ISO/IEC 27001 Annex A and listed only the security controls deemed applicable to the company and their objectives. Based on this analysis, they drafted the Statement of Applicability. Afterward, they conducted a risk assessment, during which they identified assets, such as hardware, software, and networks, as well as threats and vulnerabilities, assessed potential consequences and likelihood, and determined the level of risks based on three nonnumerical categories (low, medium, and high). They evaluated the risks based on the risk evaluation criteria and decided to treat only the high risk category. They also decided to focus primarily on the unauthorized use of administrator rights and system interruptions due to several hardware failures by establishing a new version of the access control policy, implementing controls to manage and control user access, and implementing a control for ICT readiness for business continuity.

Lastly, they drafted a risk assessment report, in which they wrote that if after the implementation of these security controls the level of risk is below the acceptable level, the risks will be accepted.

Based on the scenario above, answer the following question:

The decision to treat only risks that were classified as high indicates that Trade B has:

- A. Evaluated other risk categories based on risk treatment criteria
- B. Accepted other risk categories based on risk acceptance criteria
- C. Modified other risk categories based on risk evaluation criteria

Answer: B

Question: 29

Scenario 4: TradeB. a commercial bank that has just entered the market, accepts deposits from its clients and offers basic financial services and loans for investments. TradeB has decided to implement an information security management system (ISMS) based on ISO/IEC 27001 Having no experience of a management [^system implementation, TradeB's top management contracted two experts to direct and manage the ISMS implementation project.

First, the project team analyzed the 93 controls of ISO/IEC 27001 Annex A and listed only the security controls deemed applicable to the company and their objectives Based on this analysis, they drafted the Statement of Applicability. Afterward, they conducted a risk assessment, during which they identified assets, such as hardware, software, and networks, as well as threats and vulnerabilities, assessed potential consequences and likelihood, and determined the level of risks based on three nonnumerical categories (low, medium, and high). They evaluated the risks based on the risk evaluation criteria and decided to treat only the high risk category They also decided to focus primarily on the unauthorized use of administrator rights and system interruptions due to several hardware failures by establishing a new version of the access control policy, implementing controls to manage and control user access, and implementing a control for ICT readiness for business continuity

Lastly, they drafted a risk assessment report, in which they wrote that if after the implementation of these security controls the level of risk is below the acceptable level, the risks will be accepted

Based on scenario 4, the fact that TradeB defined the level of risk based on three nonnumerical categories indicates that;

- A. The level of risk will be evaluated against qualitative criteria
- B. The level of risk will be defined using a formula
- C. The level of risk will be evaluated using quantitative analysis

Answer: A

Question: 30

Scenario 4: TradeB. a commercial bank that has just entered the market, accepts deposits from its clients and offers basic financial services and loans for investments. TradeB has decided to implement an information security management system (ISMS) based on ISO/IEC 27001 Having no experience of a management [^system implementation, TradeB's top management contracted two experts to direct and manage the ISMS implementation project.

First, the project team analyzed the 93 controls of ISO/IEC 27001 Annex A and listed only the security controls deemed applicable to the company and their objectives Based on this analysis, they drafted the Statement of Applicability. Afterward, they conducted a risk assessment, during which they identified assets, such as hardware, software, and networks, as well as threats and vulnerabilities,

assessed potential consequences and likelihood, and determined the level of risks based on three nonnumerical categories (low, medium, and high). They evaluated the risks based on the risk evaluation criteria and decided to treat only the high risk category. They also decided to focus primarily on the unauthorized use of administrator rights and system interruptions due to several hardware failures by establishing a new version of the access control policy, implementing controls to manage and control user access, and implementing a control for ICT readiness for business continuity.

Lastly, they drafted a risk assessment report, in which they wrote that if after the implementation of these security controls the level of risk is below the acceptable level, the risks will be accepted.

Based on scenario 4, what type of assets were identified during risk assessment?

- A. Supporting assets
- B. Primary assets
- C. Business assets

Answer: A

Question: 31

Scenario 4: TradeB, a commercial bank that has just entered the market, accepts deposits from its clients and offers basic financial services and loans for investments. TradeB has decided to implement an information security management system (ISMS) based on ISO/IEC 27001. Having no experience of a management system implementation, TradeB's top management contracted two experts to direct and manage the ISMS implementation project.

First, the project team analyzed the 93 controls of ISO/IEC 27001 Annex A and listed only the security controls deemed applicable to the company and their objectives. Based on this analysis, they drafted the Statement of Applicability. Afterward, they conducted a risk assessment, during which they identified assets, such as hardware, software, and networks, as well as threats and vulnerabilities, assessed potential consequences and likelihood, and determined the level of risks based on three nonnumerical categories (low, medium, and high). They evaluated the risks based on the risk evaluation criteria and decided to treat only the high risk category. They also decided to focus primarily on the unauthorized use of administrator rights and system interruptions due to several hardware failures by establishing a new version of the access control policy, implementing controls to manage and control user access, and implementing a control for ICT readiness for business continuity.

Lastly, they drafted a risk assessment report, in which they wrote that if after the implementation of these security controls the level of risk is below the acceptable level, the risks will be accepted.

Which of the actions presented in scenario 4 is NOT compliant with the requirements of ISO/IEC 27001?

- A. TradeB selected only ISO/IEC 27001 controls deemed applicable to the company
- B. The Statement of Applicability was drafted before conducting the risk assessment
- C. The external experts selected security controls and drafted the Statement of Applicability

Answer: B

Question: 32

Scenario 4: TradeB, a commercial bank that has just entered the market, accepts deposits from its clients and offers basic financial services and loans for investments. TradeB has decided to implement an information security management system (ISMS) based on ISO/IEC 27001. Having no experience of a management information system implementation, TradeB's top management contracted two experts to direct and manage the ISMS implementation project.

First, the project team analyzed the 93 controls of ISO/IEC 27001 Annex A and listed only the security controls deemed applicable to the company and their objectives. Based on this analysis, they drafted the Statement of Applicability. Afterward, they conducted a risk assessment, during which they identified assets, such as hardware, software, and networks, as well as threats and vulnerabilities, assessed potential consequences and likelihood, and determined the level of risks based on three nonnumerical categories (low, medium, and high). They evaluated the risks based on the risk evaluation criteria and decided to treat only the high risk category. They also decided to focus primarily on the unauthorized use of administrator rights and system interruptions due to several hardware failures by establishing a new version of the access control policy, implementing controls to manage and control user access, and implementing a control for ICT readiness for business continuity.

Lastly, they drafted a risk assessment report, in which they wrote that if after the implementation of these security controls the level of risk is below the acceptable level, the risks will be accepted.

What should TradeB do in order to deal with residual risks? Refer to scenario 4.

- A. TradeB should evaluate, calculate, and document the value of risk reduction following risk treatment.
- B. TradeB should immediately implement new controls to treat all residual risks.
- C. TradeB should accept the residual risks only above the acceptance level.

Answer: A

Question: 33

Scenario 5: Operaze is a small software development company that develops applications for various companies around the world. Recently, the company conducted a risk assessment to assess the information security risks that could arise from operating in a digital landscape. Using different testing methods, including penetration testing and code review, the company identified some issues in its ICT systems, including improper user permissions, misconfigured security settings, and insecure network configurations. To resolve these issues and enhance information security, Operaze decided to implement an information security management system (ISMS) based on ISO/IEC 27001. Considering that Operaze is a small company, the entire IT team was involved in the ISMS.

implementation project. Initially, the company analyzed the business requirements and the internal and external environment, identified its key processes and activities, and identified and analyzed the interested parties. In addition, the top management of Operaze decided to include most of the company's departments within the ISMS scope. The defined scope included the organizational and physical boundaries. The IT team drafted an information security policy and communicated it to all relevant interested parties. In addition, other specific policies were developed to elaborate on security issues and the roles and responsibilities were assigned to all interested parties.

Following that, the HR manager claimed that the paperwork created by ISMS does not justify its value and the implementation of the ISMS should be canceled. However, the top management determined that this claim was invalid and organized an awareness session to explain the benefits of the ISMS to all interested parties.

Operaze decided to migrate its physical servers to their virtual servers on third-party infrastructure.

The new cloud computing solution brought additional changes to the company. Operaze's top management, on the other hand, aimed to not only implement an effective ISMS but also ensure the smooth running of the ISMS operations. In this situation, Operaze's top management concluded that the services of external experts were required to implement their information security strategies.

The IT team, on the other hand, decided to initiate a change in the ISMS scope and implemented the required modifications to the processes of the company.

Based on the scenario above, answer the following question:

What led Operaze to implement the ISMS?

- A. Identification of vulnerabilities
- B. Identification of threats
- C. Identification of assets

Answer: A

Question: 34

Scenario 5: Operaze is a small software development company that develops applications for various companies around the world. Recently, the company conducted a risk assessment to assess the information security risks that could arise from operating in a digital landscape. Using different testing methods, including penetration testing and code review, the company identified some issues in its ICT systems, including improper user permissions, misconfigured security settings, and insecure network configurations. To resolve these issues and enhance information security, Operaze decided to implement an information security management system (ISMS) based on ISO/IEC 27001.

Considering that Operaze is a small company, the entire IT team was involved in the ISMS implementation project. Initially, the company analyzed the business requirements and the internal and external environment, identified its key processes and activities, and identified and analyzed the interested parties. In addition, the top management of Operaze decided to include most of the company's departments within the ISMS scope. The defined scope included the organizational and physical boundaries. The IT team drafted an information security policy and communicated it to all relevant interested parties. In addition, other specific policies were developed to elaborate on security issues and the roles and responsibilities were assigned to all interested parties.

Following that, the HR manager claimed that the paperwork created by ISMS does not justify its value and the implementation of the ISMS should be canceled. However, the top management

determined that this claim was invalid and organized an awareness session to explain the benefits of the ISMS to all interested parties.

Operaze decided to migrate its physical servers to their virtual servers on third-party infrastructure.

The new cloud computing solution brought additional changes to the company. Operaze's top management, on the other hand, aimed to not only implement an effective ISMS but also ensure the smooth running of the ISMS operations. In this situation, Operaze's top management concluded that the services of external experts were required to implement their information security strategies.

The IT team, on the other hand, decided to initiate a change in the ISMS scope and implemented the required modifications to the processes of the company.

Based on scenario 5, after migrating to cloud, Operaze's IT team changed the ISMS scope and implemented all the required modifications. Is this acceptable?

- A. Yes, because the ISMS scope should be changed when there are changes to the external environment
- B. No, because the company has already defined the ISMS scope
- C. No, because any change in ISMS scope should be accepted by the management

Answer: C

Question: 35

Scenario 5: Operaze is a small software development company that develops applications for various companies around the world. Recently, the company conducted a risk assessment to assess the information security risks that could arise from operating in a digital landscape. Using different testing methods, including penetration testing and code review, the company identified some issues in its ICT systems, including improper user permissions, misconfigured security settings, and insecure network configurations. To resolve these issues and enhance information security, Operaze decided to implement an information security management system (ISMS) based on ISO/IEC 27001.

Considering that Operaze is a small company, the entire IT team was involved in the ISMS implementation project. Initially, the company analyzed the business requirements and the internal and external environment, identified its key processes and activities, and identified and analyzed the interested parties. In addition, the top management of Operaze decided to include most of the company's departments within the ISMS scope. The defined scope included the organizational and physical boundaries. The IT team drafted an information security policy and communicated it to all relevant interested parties. In addition, other specific policies were developed to elaborate on security issues and the roles and responsibilities were assigned to all interested parties.

Following that, the HR manager claimed that the paperwork created by ISMS does not justify its value and the implementation of the ISMS should be canceled. However, the top management determined that this claim was invalid and organized an awareness session to explain the benefits of the ISMS to all interested parties.

Operaze decided to migrate its physical servers to their virtual servers on third-party infrastructure.

The new cloud computing solution brought additional changes to the company. Operaze's top management, on the other hand, aimed to not only implement an effective ISMS but also ensure the smooth running of the ISMS operations. In this situation, Operaze's top management concluded that

the services of external experts were required to implement their information security strategies. The IT team, on the other hand, decided to initiate a change in the ISMS scope and implemented the required modifications to the processes of the company.

Based on scenario 5. in which category of the interested parties does the MR manager of Operaze belong?

- A. Positively influenced interested parties, because the ISMS will increase the effectiveness and efficiency of the HR Department
- B. Negatively influenced interested parties, because the HR Department will deal with more documentation
- C. Both A and B

Answer: B

Question: 36

Scenario 5: Operaze is a small software development company that develops applications for various companies around the world. Recently, the company conducted a risk assessment to assess the information security risks that could arise from operating in a digital landscape. Using different testing methods, including penetration testing and code review, the company identified some issues in its ICT systems, including improper user permissions, misconfigured security settings, and insecure network configurations. To resolve these issues and enhance information security, Operaze decided to implement an information security management system (ISMS) based on ISO/IEC 27001.

Considering that Operaze is a small company, the entire IT team was involved in the ISMS implementation project. Initially, the company analyzed the business requirements and the internal and external environment, identified its key processes and activities, and identified and analyzed the interested parties. In addition, the top management of Operaze decided to include most of the company's departments within the ISMS scope. The defined scope included the organizational and physical boundaries. The IT team drafted an information security policy and communicated it to all relevant interested parties. In addition, other specific policies were developed to elaborate on security issues and the roles and responsibilities were assigned to all interested parties.

Following that, the HR manager claimed that the paperwork created by ISMS does not justify its value and the implementation of the ISMS should be canceled. However, the top management determined that this claim was invalid and organized an awareness session to explain the benefits of the ISMS to all interested parties.

Operaze decided to migrate its physical servers to their virtual servers on third-party infrastructure. The new cloud computing solution brought additional changes to the company. Operaze's top management, on the other hand, aimed to not only implement an effective ISMS but also ensure the smooth running of the ISMS operations. In this situation, Operaze's top management concluded that the services of external experts were required to implement their information security strategies. The IT team, on the other hand, decided to initiate a change in the ISMS scope and implemented the required modifications to the processes of the company.

Based on scenario 5. which committee should Operaze create to ensure the smooth running of the

ISMS?

- A. Information security committee
- B. Management committee
- C. Operational committee

Answer: A

Question: 37

Scenario 5: Operaze is a small software development company that develops applications for various companies around the world. Recently, the company conducted a risk assessment to assess the information security risks that could arise from operating in a digital landscape. Using different testing methods, including penetration testing and code review, the company identified some issues in its ICT systems, including improper user permissions, misconfigured security settings, and insecure network configurations. To resolve these issues and enhance information security, Operaze decided to implement an information security management system (ISMS) based on ISO/IEC 27001.

Considering that Operaze is a small company, the entire IT team was involved in the ISMS implementation project. Initially, the company analyzed the business requirements and the internal and external environment, identified its key processes and activities, and identified and analyzed the interested parties. In addition, the top management of Operaze decided to include most of the company's departments within the ISMS scope. The defined scope included the organizational and physical boundaries. The IT team drafted an information security policy and communicated it to all relevant interested parties. In addition, other specific policies were developed to elaborate on security issues and the roles and responsibilities were assigned to all interested parties.

Following that, the HR manager claimed that the paperwork created by ISMS does not justify its value and the implementation of the ISMS should be canceled. However, the top management determined that this claim was invalid and organized an awareness session to explain the benefits of the ISMS to all interested parties.

Operaze decided to migrate its physical servers to their virtual servers on third-party infrastructure. The new cloud computing solution brought additional changes to the company. Operaze's top management, on the other hand, aimed to not only implement an effective ISMS but also ensure the smooth running of the ISMS operations. In this situation, Operaze's top management concluded that the services of external experts were required to implement their information security strategies. The IT team, on the other hand, decided to initiate a change in the ISMS scope and implemented the required modifications to the processes of the company.

What is the next step that Operaze's ISMS implementation team should take after drafting the information security policy? Refer to scenario 5.

- A. Implement the information security policy
- B. Obtain top management's approval for the information security policy
- C. Communicate the information security policy to all employees

Answer: B

Question: 38

An organization has adopted a new authentication method to ensure secure access to sensitive areas and facilities of the company. It requires every employee to use a two-factor authentication (password and QR code). This control has been documented, standardized, and communicated to all employees, however its use has been "left to individual initiative, and it is likely that failures can be detected. Which level of maturity does this control refer to?

- A. Optimized
- B. Defined
- C. Quantitatively managed

Answer: B

Question: 39

Which tool is used to identify, analyze, and manage interested parties?

- A. The probability/impact matrix
- B. The power/interest matrix
- C. The likelihood/severity matrix

Answer: B

Question: 40

'The ISMS covers all departments within Company XYZ that have access to customers' data
a. The purpose of the ISMS is to ensure the confidentiality, integrity, and availability of customers' data, and ensure compliance with the applicable regulatory requirements regarding information security." What does this statement describe?

- A. The information systems boundary of the ISMS scope
- B. The organizational boundaries of the ISMS scope
- C. The physical boundary of the ISMS scope

Answer: B

Question: 41

An organization has justified the exclusion of control 5.18 Access rights of ISO/IEC 27001 in the Statement of Applicability (SoA) as follows: "An access control reader is already installed at the main entrance of the building." Which statement is correct'

- A. The justification for the exclusion of a control is not required to be included in the SoA
- B. The justification is not acceptable, because it does not reflect the purpose of control 5.18
- C. The justification is not acceptable because it does not indicate that it has been selected based on the risk assessment results

Answer: B

Question: 42

Which statement is an example of risk retention?

- A. An organization has decided to release the software even though some minor bugs have not been fixed yet
- B. An organization has implemented a data loss protection software
- C. An organization terminates work in the construction site during a severe storm

Answer: A

Question: 43

Which option below should be addressed in an information security policy?

- A. Actions to be performed after an information security incident
- B. Legal and regulatory obligations imposed upon the organization
- C. The complexity of information security processes and their interactions

Answer: B

Question: 44

Which approach should organizations use to implement an ISMS based on ISO/IEC 27001?

- A. An approach that is suitable for organization's scope
- B. Any approach that enables the ISMS implementation within the 12month period
- C. Only the approach provided by the standard

Answer: A

Question: 45

What risk treatment option has Company A implemented if it has required from its employees the change of email passwords at least once every 60 days?

- A. Risk modification
- B. Risk avoidance
- C. Risk retention

Answer: A

Question: 46

Scenario 6: Skyver offers worldwide shipping of electronic products, including gaming consoles, flat-screen TVs, computers, and printers. In order to ensure information security, the company has decided to implement an information security management system (ISMS) based on the requirements of ISO/IEC 27001.

Colin, the company's best information security expert, decided to hold a training and awareness session for the personnel of the company regarding the information security challenges and other information security-related controls. The session included topics such as Skyver's information security approaches and techniques for mitigating phishing and malware.

One of the participants in the session is Lisa, who works in the HR Department. Although Colin explains the existing Skyver's information security policies and procedures in an honest and fair manner, she finds some of the issues being discussed too technical and does not fully understand the session. Therefore, in a lot of cases, she requests additional help from the trainer and her colleagues. Based on the scenario above, answer the following question:

How should Colin have handled the situation with Lisa?

- A. Extend the duration of the training and awareness session in order to be able to achieve better results
- B. Promise Lisa that future training and awareness sessions will be easily understandable
- C. Deliver training and awareness sessions for employees with the same level of competence needs based on the activities they perform within the company

Answer: C

Question: 47

Scenario 6: Skyver offers worldwide shipping of electronic products, including gaming consoles, flat-screen TVs, computers, and printers. In order to ensure information security, the company has decided to implement an information security management system (ISMS) based on the requirements of ISO/IEC 27001.

Colin, the company's best information security expert, decided to hold a training and awareness session for the personnel of the company regarding the information security challenges and other information security-related controls. The session included topics such as Skyver's information security approaches and techniques for mitigating phishing and malware.

One of the participants in the session is Lisa, who works in the HR Department. Although Colin explains the existing Skyver's information security policies and procedures in an honest and fair manner, she finds some of the issues being discussed too technical and does not fully understand the session. Therefore, in a lot of cases, she requests additional help from the trainer and her colleagues

Based on the last paragraph of scenario 6, which principles of an effective communication strategy did Colin NOT follow?

- A. Transparency and credibility
- B. Credibility and responsiveness
- C. Appropriateness and clarity

Answer: C

Question: 48

Scenario 6: Skyver offers worldwide shipping of electronic products, including gaming consoles, flat-screen TVs, computers, and printers. In order to ensure information security, the company has decided to implement an information security management system (ISMS) based on the requirements of ISO/IEC 27001.

Colin, the company's best information security expert, decided to hold a training and awareness session for the personnel of the company regarding the information security challenges and other information security-related controls. The session included topics such as Skyver's information security approaches and techniques for mitigating phishing and malware.

One of the participants in the session is Lisa, who works in the HR Department. Although Colin explains the existing Skyver's information security policies and procedures in an honest and fair manner, she finds some of the issues being discussed too technical and does not fully understand the session. Therefore, in a lot of cases, she requests additional help from the trainer and her colleagues

Based on scenario 6, Lisa found some of the issues being discussed in the training and awareness session too technical, thus not fully understanding the session. What does this indicate?

- A. Lisa did not take actions to acquire the necessary competence
- B. The effectiveness of the training and awareness session was not evaluated
- C. Skyver did not determine differing team needs in accordance to the activities they perform and the intended results

Answer: C

Question: 49

Scenario 6: Skyver offers worldwide shipping of electronic products, including gaming consoles, flat-screen TVs, computers, and printers. In order to ensure information security, the company has decided to implement an information security management system (ISMS) based on the requirements of ISO/IEC 27001.

Colin, the company's best information security expert, decided to hold a training and awareness session for the personnel of the company regarding the information security challenges and other information security-related controls. The session included topics such as Skyver's information security approaches and techniques for mitigating phishing and malware.

One of the participants in the session is Lisa, who works in the HR Department. Although Colin explains the existing Skyver's information security policies and procedures in an honest and fair manner, she finds some of the issues being discussed too technical and does not fully understand the session. Therefore, in a lot of cases, she requests additional help from the trainer and her colleagues

Based on scenario 6, when should Colin deliver the next training and awareness session?

- A. After he ensures that the group of employees targeted have satisfied the organization's needs
- B. After he conducts a competence needs analysis and records the competence related issues
- C. After he determines the employees' availability and motivation

Answer: B

Question: 50

Scenario 6: Skyver offers worldwide shipping of electronic products, including gaming consoles, flat-screen TVs, computers, and printers. In order to ensure information security, the company has decided to implement an information security management system (ISMS) based on the requirements of ISO/IEC 27001.

Colin, the company's best information security expert, decided to hold a training and awareness session for the personnel of the company regarding the information security challenges and other information security-related controls. The session included topics such as Skyver's information security approaches and techniques for mitigating phishing and malware.

One of the participants in the session is Lisa, who works in the HR Department. Although Colin explains the existing Skyver's information security policies and procedures in an honest and fair manner, she finds some of the issues being discussed too technical and does not fully understand the session. Therefore, in a lot of cases, she requests additional help from the trainer and her colleagues

What is the difference between training and awareness? Refer to scenario 6.

- A. Training helps acquire certain skills, whereas awareness develops certain habits and behaviors.

- B. Training helps acquire a skill, whereas awareness helps apply it in practice
- C. Training helps transfer a message with the intent of informing, whereas awareness helps change the behavior toward the message

Answer: A

Question: 51

Scenario 7: InfoSec is a multinational corporation headquartered in Boston, MA, which provides professional electronics, gaming, and entertainment services. After facing numerous information security incidents, InfoSec has decided to establish teams and implement measures to prevent potential incidents in the future

Emma, Bob, and Anna were hired as the new members of InfoSec's information security team, which consists of a security architecture team, an incident response team (IRT) and a forensics team. Emma's job is to create information security plans, policies, protocols, and training to prepare InfoSec to respond to incidents effectively. Emma and Bob would be full-time employees of InfoSec, whereas Anna was contracted as an external consultant.

Bob, a network expert, will deploy a screened subnet network architecture. This architecture will isolate the demilitarized zone (DMZ) to which hosted public services are attached and InfoSec's publicly accessible resources from their private network. Thus, InfoSec will be able to block potential attackers from causing unwanted events inside the company's network. Bob is also responsible for ensuring that a thorough evaluation of the nature of an unexpected event is conducted, including the details on how the event happened and what or whom it might affect.

Anna will create records of the data, reviews, analysis, and reports in order to keep evidence for the purpose of disciplinary and legal action, and use them to prevent future incidents. To do the work accordingly, she should be aware of the company's information security incident management policy beforehand.

Among others, this policy specifies the type of records to be created, the place where they should be kept, and the format and content that specific record types should have.

Based on this scenario, answer the following question:

Based on his tasks, which team is Bob part of?

- A. Security architecture team
- B. Forensics team
- C. Incident response team

Answer: C

Question: 52

Scenario 7: InfoSec is a multinational corporation headquartered in Boston, MA, which provides

professional electronics, gaming, and entertainment services. After facing numerous information security incidents, InfoSec has decided to establish teams and implement measures to prevent potential incidents in the future

Emma, Bob, and Anna were hired as the new members of InfoSec's information security team, which consists of a security architecture team, an incident response team (IRT) and a forensics team. Emma's job is to create information security plans, policies, protocols, and training to prepare InfoSec to respond to incidents effectively. Emma and Bob would be full-time employees of InfoSec, whereas Anna was contracted as an external consultant.

Bob, a network expert, will deploy a screened subnet network architecture. This architecture will isolate the demilitarized zone (DMZ) to which hosted public services are attached and InfoSec's publicly accessible resources from their private network. Thus, InfoSec will be able to block potential attackers from causing unwanted events inside the company's network. Bob is also responsible for ensuring that a thorough evaluation of the nature of an unexpected event is conducted, including the details on how the event happened and what or whom it might affect.

Anna will create records of the data, reviews, analysis, and reports in order to keep evidence for the purpose of disciplinary and legal action, and use them to prevent future incidents. To do the work accordingly, she should be aware of the company's information security incident management policy beforehand.

Among others, this policy specifies the type of records to be created, the place where they should be kept, and the format and content that specific record types should have.

According to scenario 7, a demilitarized zone (DMZ) is deployed within InfoSec's network. What type of control has InfoSec implemented in this case?

- A. Detective
- B. Preventive
- C. Corrective

Answer: B

Question: 53

Scenario 7: InfoSec is a multinational corporation headquartered in Boston, MA, which provides professional electronics, gaming, and entertainment services. After facing numerous information security incidents, InfoSec has decided to establish teams and implement measures to prevent potential incidents in the future.

Emma, Bob, and Anna were hired as the new members of InfoSec's information security team, which consists of a security architecture team, an incident response team (IRT) and a forensics team. Emma's job is to create information security plans, policies, protocols, and training to prepare InfoSec to respond to incidents effectively. Emma and Bob would be full-time employees of InfoSec, whereas Anna was contracted as an external consultant.

Bob, a network expert, will deploy a screened subnet network architecture. This architecture will isolate the demilitarized zone (DMZ) to which hosted public services are attached and InfoSec's publicly accessible resources from their private network. Thus, InfoSec will be able to block potential attackers from causing unwanted events inside the company's network. Bob is also responsible for ensuring that a thorough evaluation of the nature of an unexpected event is conducted, including the

details on how the event happened and what or whom it might affect.

Anna will create records of the data, reviews, analysis, and reports in order to keep evidence for the purpose of disciplinary and legal action, and use them to prevent future incidents. To do the work accordingly, she should be aware of the company's information security incident management policy beforehand

Among others, this policy specifies the type of records to be created, the place where they should be kept, and the format and content that specific record types should have.

Based on scenario 7. InfoSec contracted Anna as an external consultant. Based on her tasks, is this action compliant with ISO/IEC 27001°

- A. No, the skills of incident response or forensic analysis shall be developed internally
- B. Yes, forensic investigation may be conducted internally or by using external consultants
- C. Yes, organizations must use external consultants for forensic investigation, as required by the standard

Answer: B

Question: 54

Scenario 7: InfoSec is a multinational corporation headquartered in Boston, MA, which provides professional electronics, gaming, and entertainment services. After facing numerous information security incidents, InfoSec has decided to establish teams and implement measures to prevent potential incidents in the future

Emma, Bob. and Anna were hired as the new members of InfoSec's information security team, which consists of a security architecture team, an incident response team (IRT) and a forensics team Emma's job is to create information security plans, policies, protocols, and training to prepare InfoSec to respond to incidents effectively Emma and Bob would be full-time employees of InfoSec, whereas Anna was contracted as an external consultant.

Bob, a network expert, will deploy a screened subnet network architecture This architecture will isolate the demilitarized zone (DMZ) to which hosted public services are attached and InfoSec's publicly accessible resources from their private network Thus, InfoSec will be able to block potential attackers from causing unwanted events inside the company's network. Bob is also responsible for ensuring that a thorough evaluation of the nature of an unexpected event is conducted, including the details on how the event happened and what or whom it might affect.

Anna will create records of the data, reviews, analysis, and reports in order to keep evidence for the purpose of disciplinary and legal action, and use them to prevent future incidents. To do the work accordingly, she should be aware of the company's information security incident management policy beforehand

Among others, this policy specifies the type of records to be created, the place where they should be kept, and the format and content that specific record types should have.

Based on scenario 7, what should Anna be aware of when gathering data?

- A. The use of the buffer zone that blocks potential attacks coming from malicious websites where data can be collected
- B. The type of data that helps prevent future occurrences of information security incidents

C. The collection and preservation of records

Answer: C

Question: 55

Scenario 7: InfoSec is a multinational corporation headquartered in Boston, MA, which provides professional electronics, gaming, and entertainment services. After facing numerous information security incidents, InfoSec has decided to establish teams and implement measures to prevent potential incidents in the future

Emma, Bob, and Anna were hired as the new members of InfoSec's information security team, which consists of a security architecture team, an incident response team (IRT) and a forensics team. Emma's job is to create information security plans, policies, protocols, and training to prepare InfoSec to respond to incidents effectively. Emma and Bob would be full-time employees of InfoSec, whereas Anna was contracted as an external consultant.

Bob, a network expert, will deploy a screened subnet network architecture. This architecture will isolate the demilitarized zone (DMZ) to which hosted public services are attached and InfoSec's publicly accessible resources from their private network. Thus, InfoSec will be able to block potential attackers from causing unwanted events inside the company's network. Bob is also responsible for ensuring that a thorough evaluation of the nature of an unexpected event is conducted, including the details on how the event happened and what or whom it might affect.

Anna will create records of the data, reviews, analysis, and reports in order to keep evidence for the purpose of disciplinary and legal action, and use them to prevent future incidents. To do the work accordingly, she should be aware of the company's information security incident management policy beforehand.

Among others, this policy specifies the type of records to be created, the place where they should be kept, and the format and content that specific record types should have.

Why did InfoSec establish an IRT? Refer to scenario 7.

- A. To comply with the ISO/IEC 27001 requirements related to incident management
- B. To collect, preserve, and analyze the information security incidents
- C. To assess, respond to, and learn from information security incidents

Answer: C

Question: 56

Kyte, a company that has an online shopping website, has added a Q&A section to its website; however, its Customer Service Department almost never provides answers to users' questions. Which principle of an effective communication strategy has Kyte not followed?

- A. Clarity

- B. Appropriateness
- C. Responsiveness

Answer: B

Question: 57

What should an organization allocate to ensure the maintenance and improvement of the information security management system?

- A. The appropriate transfer to operations
- B. Sufficient resources, such as the budget, qualified personnel, and required tools
- C. The documented information required by ISO/IEC 27001

Answer: B

Question: 58

An organization uses Platform as a Services (PaaS) to host its cloud-based services. As such, the cloud provider manages most of the services to the organization. However, the organization still manages _____

- A. Operating system and visualization
- B. Servers and storage
- C. Application and data

Answer: C

Question: 59

A company decided to use an algorithm that analyzes various attributes of customer behavior, such as browsing patterns and demographics, and groups customers based on their similar characteristics. This way, the company will be able to identify frequent buyers and trend-followers, among others. What type of machine learning is the company using?

- A. Decision tree machine learning
- B. Supervised machine learning
- C. Unsupervised machine learning

Answer: C

Question: 60

Scenario 8: SunDee is an American biopharmaceutical company, headquartered in California, the US. It specializes in developing novel human therapeutics, with a focus on cardiovascular diseases, oncology, bone health, and inflammation. The company has had an information security management system (ISMS) based on SO/IEC 27001 in place for the past two years. However, it has not monitored or measured the performance and effectiveness of its ISMS and conducted management reviews regularly

Just before the recertification audit, the company decided to conduct an internal audit. It also asked most of their staff to compile the written individual reports of the past two years for their departments. This left the Production Department with less than the optimum workforce, which decreased the company's stock.

Tessa was SunDee's internal auditor. With multiple reports written by 50 different employees, the internal audit process took much longer than planned, was very inconsistent, and had no qualitative measures whatsoever. Tessa concluded that SunDee must evaluate the performance of the ISMS adequately. She defined SunDee's negligence of ISMS performance evaluation as a major nonconformity, so she wrote a nonconformity report including the description of the nonconformity, the audit findings, and recommendations. Additionally, Tessa created a new plan which would enable SunDee to resolve these issues and presented it to the top management.

Based on the scenario above, answer the following question:

What caused SunDee's workforce disruption?

- A. The negligence of performance evaluation and monitoring and measurement procedures
- B. The inconsistency of reports written by different employees
- C. The voluminous written reports

Answer: A

Question: 61

Scenario 8: SunDee is an American biopharmaceutical company, headquartered in California, the US. It specializes in developing novel human therapeutics, with a focus on cardiovascular diseases, oncology, bone health, and inflammation. The company has had an information security management system (ISMS) based on SO/IEC 27001 in place for the past two years. However, it has not monitored or measured the performance and effectiveness of its ISMS and conducted management reviews regularly

Just before the recertification audit, the company decided to conduct an internal audit. It also asked most of their staff to compile the written individual reports of the past two years for their departments. This left the Production Department with less than the optimum workforce, which decreased the company's stock.

Tessa was SunDee's internal auditor. With multiple reports written by 50 different employees, the

internal audit process took much longer than planned, was very inconsistent, and had no qualitative measures whatsoever Tessa concluded that SunDee must evaluate the performance of the ISMS adequately. She defined SunDee's negligence of ISMS performance evaluation as a major nonconformity, so she wrote a nonconformity report including the description of the nonconformity, the audit findings, and recommendations. Additionally, Tessa created a new plan which would enable SunDee to resolve these issues and presented it to the top management

Based on scenario 8. did the nonconformity report include all the necessary aspects?

- A. Yes, the report included all the necessary aspects
- B. No, the report must also specify the root cause of the nonconformity
- C. No, the report must also specify the audit criteria

Answer: B

Question: 62

Scenario 8: SunDee is an American biopharmaceutical company, headquartered in California, the US. It specializes in developing novel human therapeutics, with a focus on cardiovascular diseases, oncology, bone health, and inflammation. The company has had an information security management system (ISMS) based on ISO/IEC 27001 in place for the past two years. However, it has not monitored or measured the performance and effectiveness of its ISMS and conducted management reviews regularly

Just before the recertification audit, the company decided to conduct an internal audit. It also asked most of their staff to compile the written individual reports of the past two years for their departments. This left the Production Department with less than the optimum workforce, which decreased the company's stock.

Tessa was SunDee's internal auditor. With multiple reports written by 50 different employees, the internal audit process took much longer than planned, was very inconsistent, and had no qualitative measures whatsoever Tessa concluded that SunDee must evaluate the performance of the ISMS adequately. She defined SunDee's negligence of ISMS performance evaluation as a major nonconformity, so she wrote a nonconformity report including the description of the nonconformity, the audit findings, and recommendations. Additionally, Tessa created a new plan which would enable SunDee to resolve these issues and presented it to the top management

How does SunDee's negligence affect the ISMS certificate? Refer to scenario 8.

- A. SunDee will renew the ISMS certificate, because it has conducted an Internal audit to evaluate the ISMS effectiveness
- B. SunDee might not be able to renew the ISMS certificate, because it has not conducted management reviews at planned intervals
- C. SunDee might not be able to renew the ISMS certificate, because the internal audit lasted longer than planned

Answer: B

Question: 63

Scenario 8: SunDee is an American biopharmaceutical company, headquartered in California, the US. It specializes in developing novel human therapeutics, with a focus on cardiovascular diseases, oncology, bone health, and inflammation. The company has had an information security management system (ISMS) based on SO/IEC 27001 in place for the past two years. However, it has not monitored or measured the performance and effectiveness of its ISMS and conducted management reviews regularly

Just before the recertification audit, the company decided to conduct an internal audit. It also asked most of their staff to compile the written individual reports of the past two years for their departments. This left the Production Department with less than the optimum workforce, which decreased the company's stock.

Tessa was SunDee's internal auditor. With multiple reports written by 50 different employees, the internal audit process took much longer than planned, was very inconsistent, and had no qualitative measures whatsoever. Tessa concluded that SunDee must evaluate the performance of the ISMS adequately. She defined SunDee's negligence of ISMS performance evaluation as a major nonconformity, so she wrote a nonconformity report including the description of the nonconformity, the audit findings, and recommendations. Additionally, Tessa created a new plan which would enable SunDee to resolve these issues and presented it to the top management.

Based on scenario 8, does SunDee comply with ISO/IEC 27001 requirements regarding the monitoring and measurement process?

- A. Yes, because the standard does not indicate when the monitoring and measurement phase should be performed
- B. Yes, because the standard requires that the monitoring and measurement phase be conducted every two years
- C. No, because even though the standard does not imply when such a process should be performed, the company must have a monitoring and measurement process in place

Answer: C

Question: 64

Scenario 8: SunDee is an American biopharmaceutical company, headquartered in California, the US. It specializes in developing novel human therapeutics, with a focus on cardiovascular diseases, oncology, bone health, and inflammation. The company has had an information security management system (ISMS) based on SO/IEC 27001 in place for the past two years. However, it has not monitored or measured the performance and effectiveness of its ISMS and conducted management reviews regularly

Just before the recertification audit, the company decided to conduct an internal audit. It also asked

most of their staff to compile the written individual reports of the past two years for their departments. This left the Production Department with less than the optimum workforce, which decreased the company's stock.

Tessa was SunDee's internal auditor. With multiple reports written by 50 different employees, the internal audit process took much longer than planned, was very inconsistent, and had no qualitative measures whatsoever. Tessa concluded that SunDee must evaluate the performance of the ISMS adequately. She defined SunDee's negligence of ISMS performance evaluation as a major nonconformity, so she wrote a nonconformity report including the description of the nonconformity, the audit findings, and recommendations. Additionally, Tessa created a new plan which would enable SunDee to resolve these issues and presented it to the top management.

According to scenario 8, Tessa created a plan for ISMS monitoring and measurement and presented it to the top management. Is this acceptable?

- A. No, Tessa should only communicate the issues found to the top management
- B. Yes, Tessa can advise the top management on improving the company's functions
- C. No, Tessa must implement all the improvements needed for issues found during the audit

Answer: B

Question: 65

An organization has decided to conduct information security awareness and training sessions on a monthly basis for all employees. Only 45% of employees who attended these sessions were able to pass the exam. What does the percentage represent?

- A. Measurement objective
- B. Attribute
- C. Performance indicator

Answer: C

Question: 66

A small organization that is implementing an ISMS based on ISO/IEC 27001 has decided to outsource the internal audit function to a third party. Is this acceptable?

- A. Yes, outsourcing the internal audit function to a third party is often a better option for small organizations to demonstrate independence and impartiality
- B. No, the organizations cannot outsource the internal audit function to a third party because during internal audit, the organization audits its own system
- C. No, the outsourcing of the internal audit function may compromise the independence and impartiality of the internal audit team

Answer: A

Question: 67

An organization that has an ISMS in place conducts management reviews at planned intervals, but does not retain documented information on the results. Is this in accordance with the requirements of ISO/IEC 27001?

- A. Yes. ISO/IEC 27001 does not require organizations to document the results of management reviews
- B. No, ISO/IEC 27001 requires organizations to document the results of management reviews
- C. Yes. ISO/IEC 27001 requires organizations to document the results of management reviews only if they are conducted ad hoc

Answer: B

Question: 68

Del&Co has decided to improve their staff-related controls to prevent incidents. Which of the following is NOT a preventive control related to the Del&Co's staff?

- A. Authentication and authorization
- B. Control of physical access to the equipment
- C. Video cameras

Answer: C

Question: 69

Which of the situations below can negatively affect the internal audit process?

- A. Restricting the internal auditor's access to offices and documentation
- B. Conducting internal audit interviews with all employees of the organization
- C. Reporting the internal audit results to the top management

Answer: A

Question: 70

Scenario 9: OpenTech provides IT and communications services. It helps data communication enterprises and network operators become multi-service providers During an internal audit, its internal auditor, Tim, has identified nonconformities related to the monitoring procedures He identified and evaluated several system Invulnerabilities.

Tim found out that user IDs for systems and services that process sensitive information have been reused and the access control policy has not been followed After analyzing the root causes of this nonconformity, the ISMS project manager developed a list of possible actions to resolve the nonconformity. Then, the ISMS project manager analyzed the list and selected the activities that would allow the elimination of the root cause and the prevention of a similar situation in the future. These activities were included in an action plan The action plan, approved by the top management, was written as follows:

A new version of the access control policy will be established and new restrictions will be created to ensure that network access is effectively managed and monitored by the Information and Communication Technology (ICT) Department

The approved action plan was implemented and all actions described in the plan were documented.

Based on this scenario, answer the following question:

OpenTech has decided to establish a new version of its access control policy. What should the company do when such changes occur?

- A. Identify the change factors to be monitored
- B. Update the information security objectives
- C. Include the changes in the scope

Answer: B

Question: 71

Scenario 9: OpenTech provides IT and communications services. It helps data communication enterprises and network operators become multi-service providers During an internal audit, its internal auditor, Tim, has identified nonconformities related to the monitoring procedures He identified and evaluated several system Invulnerabilities.

Tim found out that user IDs for systems and services that process sensitive information have been reused and the access control policy has not been followed After analyzing the root causes of this nonconformity, the ISMS project manager developed a list of possible actions to resolve the nonconformity. Then, the ISMS project manager analyzed the list and selected the activities that would allow the elimination of the root cause and the prevention of a similar situation in the future. These activities were included in an action plan The action plan, approved by the top management, was written as follows:

A new version of the access control policy will be established and new restrictions will be created to ensure that network access is effectively managed and monitored by the Information and Communication Technology (ICT) Department

The approved action plan was implemented and all actions described in the plan were documented.

Based on scenario 9, OpenTech has taken all the actions needed, except_____.

- A. Corrective actions
- B. Preventive actions
- C. Permanent corrections

Answer: B

Question: 72

Scenario 9: OpenTech provides IT and communications services. It helps data communication enterprises and network operators become multi-service providers During an internal audit, its internal auditor, Tim, has identified nonconformities related to the monitoring procedures He identified and evaluated several system Invulnerabilities.

Tim found out that user IDs for systems and services that process sensitive information have been reused and the access control policy has not been followed After analyzing the root causes of this nonconformity, the ISMS project manager developed a list of possible actions to resolve the nonconformity. Then, the ISMS project manager analyzed the list and selected the activities that would allow the elimination of the root cause and the prevention of a similar situation in the future. These activities were included in an action plan The action plan, approved by the top management, was written as follows:

A new version of the access control policy will be established and new restrictions will be created to ensure that network access is effectively managed and monitored by the Information and Communication Technology (ICT) Department

The approved action plan was implemented and all actions described in the plan were documented.

Based on scenario 9. is the action plan for the identified nonconformities sufficient to eliminate the detected nonconformities?

- A. Yes, because a separate action plan has been created for the identified nonconformity
- B. No, because the action plan does not include a timeframe for implementation
- C. No, because the action plan does not address the root cause of the identified nonconformity

Answer: B

Question: 73

Scenario 9: OpenTech provides IT and communications services. It helps data communication enterprises and network operators become multi-service providers During an internal audit, its internal auditor, Tim, has identified nonconformities related to the monitoring procedures He identified and evaluated several system Invulnerabilities.

Tim found out that user IDs for systems and services that process sensitive information have been reused and the access control policy has not been followed After analyzing the root causes of this

nonconformity, the ISMS project manager developed a list of possible actions to resolve the nonconformity. Then, the ISMS project manager analyzed the list and selected the activities that would allow the elimination of the root cause and the prevention of a similar situation in the future. These activities were included in an action plan. The action plan, approved by the top management, was written as follows:

A new version of the access control policy will be established and new restrictions will be created to ensure that network access is effectively managed and monitored by the Information and Communication Technology (ICT) Department.

The approved action plan was implemented and all actions described in the plan were documented.

Based on scenario 9, did the ISMS project manager complete the corrective action process appropriately?

- A. Yes, the corrective action process should include the identification of the nonconformity, situation analysis, and implementation of corrective actions
- B. No, the corrective action did not address the root cause of the nonconformity
- C. No, the corrective action process should also include the review of the implementation of the selected actions

Answer: C

Question: 74

Which of the following is NOT part of the steps required by ISO/IEC 27001 that an organization must take when a nonconformity is detected?

- A. React to the nonconformity, take action to control and correct it, and deal with its consequences
- B. Evaluate the need for action to eliminate the causes of the nonconformity so that it does not recur or occur elsewhere
- C. Communicate the details of the nonconformity to every employee of the organization and suspend the employee that caused the nonconformity

Answer: C

Question: 75

What supports the continual improvement of an ISMS?

- A. The update of documented information
- B. The update of action plans
- C. The update of external audit reports

Answer: A

Question: 76

Scenario 10: NetworkFuse develops, manufactures, and sells network hardware. The company has had an operational information security management system (ISMS) based on ISO/IEC 27001 requirements and a quality management system (QMS) based on ISO 9001 for approximately two years. Recently, it has applied for a combined certification audit in order to obtain certification against ISO/IEC 27001 and ISO 9001.

After selecting the certification body, NetworkFuse prepared the employees for the audit. The company decided to not conduct a self-evaluation before the audit since, according to the top management, it was not necessary. In addition, it ensured the availability of documented information, including internal audit reports and management reviews, technologies in place, and the general operations of the ISMS and the QMS. However, the company requested from the certification body that the documentation could not be carried off-site. However, the audit was not performed within the scheduled days because NetworkFuse rejected the audit team leader assigned and requested their replacement. The company asserted that the same audit team leader issued a recommendation for certification to its main competitor, which, for the company's top management, was a potential conflict of interest. The request was not accepted by the certification body.

Based on the scenario above, answer the following question:

Does NetworkFuse fulfill the prerequisites for a certification audit?

- A. Yes, because the certification body has been selected
- B. Yes, because internal audits and management reviews have been performed
- C. Yes, because the ISMS must be operational for at least one year prior to the certification audit

Answer: B

Question: 77

Scenario 10: NetworkFuse develops, manufactures, and sells network hardware. The company has had an operational information security management system (ISMS) based on ISO/IEC 27001 requirements and a quality management system (QMS) based on ISO 9001 for approximately two years. Recently, it has applied for a combined certification audit in order to obtain certification against ISO/IEC 27001 and ISO 9001.

After selecting the certification body, NetworkFuse prepared the employees for the audit. The company decided to not conduct a self-evaluation before the audit since, according to the top management, it was not necessary. In addition, it ensured the availability of documented information, including internal audit reports and management reviews, technologies in place, and the general operations of the ISMS and the QMS. However, the company requested from the certification body that the documentation could not be carried off-site.

However, the audit was not performed within the scheduled days because NetworkFuse rejected the audit team leader assigned and requested their replacement. The company asserted that the same

audit team leader issued a recommendation for certification to its main competitor, which, for the company's top management, was a potential conflict of interest. The request was not accepted by the certification body

NetworkFuse should _____ to ensure that employees are prepared for the audit. Refer to scenario 10.

- A. Conduct practice interviews
- B. Observe the technologies used
- C. Select a certification body that provides combined audits

Answer: A

Question: 78

Scenario 10: NetworkFuse develops, manufactures, and sells network hardware. The company has had an operational information security management system (ISMS) based on ISO/IEC 27001 requirements and a quality management system (QMS) based on ISO 9001 for approximately two years. Recently, it has applied for a combined certification audit in order to obtain certification against ISO/IEC 27001 and ISO 9001.

After selecting the certification body, NetworkFuse prepared the employees for the audit. The company decided to not conduct a self-evaluation before the audit since, according to the top management, it was not necessary. In addition, it ensured the availability of documented information, including internal audit reports and management reviews, technologies in place, and the general operations of the ISMS and the QMS. However, the company requested from the certification body that the documentation could not be carried off-site. However, the audit was not performed within the scheduled days because NetworkFuse rejected the audit team leader assigned and requested their replacement. The company asserted that the same audit team leader issued a recommendation for certification to its main competitor, which, for the company's top management, was a potential conflict of interest. The request was not accepted by the certification body.

According to scenario 10, NetworkFuse requested from the certification body to review all the documentation only on-site. Is this acceptable?

- A. Yes, the auditee may request that the review of the documentation takes place on-site
- B. Yes, only if a confidentiality agreement is formerly signed by the audit team
- C. No, the certification body decides whether the documentation review takes place on-site or off-site

Answer: A

Question: 79

Scenario 10: NetworkFuse develops, manufactures, and sells network hardware. The company has had an operational information security management system (ISMS) based on ISO/IEC 27001 requirements and a quality management system (QMS) based on ISO 9001 for approximately two years. Recently, it has applied for a combined certification audit in order to obtain certification against ISO/IEC 27001 and ISO 9001.

After selecting the certification body, NetworkFuse prepared the employees for the audit. The company decided to not conduct a self-evaluation before the audit since, according to the top management, it was not necessary. In addition, it ensured the availability of documented information, including internal audit reports and management reviews, technologies in place, and the general operations of the ISMS and the QMS. However, the company requested from the certification body that the documentation could not be carried off-site.

However, the audit was not performed within the scheduled days because NetworkFuse rejected the audit team leader assigned and requested their replacement. The company asserted that the same audit team leader issued a recommendation for certification to its main competitor, which, for the company's top management, was a potential conflict of interest. The request was not accepted by the certification body.

The certification body rejected NetworkFuse's request to change the audit team leader. Is this acceptable? Refer to scenario 10.

- A. No, because an auditee cannot request the rejection of an audit team member
- B. Yes, because NetworkFuse did not give a valid reason to support their claims
- C. No, auditee's requests for the replacement of auditors must be accepted

Answer: B

Question: 80

Scenario 10: NetworkFuse develops, manufactures, and sells network hardware. The company has had an operational information security management system (ISMS) based on ISO/IEC 27001 requirements and a quality management system (QMS) based on ISO 9001 for approximately two years. Recently, it has applied for a combined certification audit in order to obtain certification against ISO/IEC 27001 and ISO 9001.

After selecting the certification body, NetworkFuse prepared the employees for the audit. The company decided to not conduct a self-evaluation before the audit since, according to the top management, it was not necessary. In addition, it ensured the availability of documented information, including internal audit reports and management reviews, technologies in place, and the general operations of the ISMS and the QMS. However, the company requested from the certification body that the documentation could not be carried off-site.

However, the audit was not performed within the scheduled days because NetworkFuse rejected the audit team leader assigned and requested their replacement. The company asserted that the same audit team leader issued a recommendation for certification to its main competitor, which, for the company's top management, was a potential conflict of interest. The request was not accepted by the certification body.

Based on scenario 10. NetworkFuse did not conduct a self-evaluation of the ISMS before the audit. Is this compliant to ISO/IEC 27001?

- A. No, the auditee must review the requirements of clauses 4 to 10 before the conduct of a certification audit
- B. Yes, the standard indicates that the auditee shall rely only on internal audit and management review reports to prepare for the certification audit
- C. Yes, the standard does not require to conduct a self-evaluation before the audit but it is a good practice to follow

Answer: C

Question: 81

Scenario 1: HealthGenic is a pediatric clinic that monitors the health and growth of individuals from infancy to early adulthood using a web-based medical software. The software is also used to schedule appointments, create customized medical reports, store patients' data and medical history, and communicate with all the involved parties, including parents, other physicians, and the medical laboratory staff.

Last month, HealthGenic experienced a number of service interruptions due to the increased number of users accessing the software. Another issue the company faced while using the software was the complicated user interface, which the untrained personnel found challenging to use. The top management of HealthGenic immediately informed the company that had developed the software about the issue. The software company fixed the issue; however, in the process of doing so, it modified some files that comprised sensitive information related to HealthGenic's patients. The modifications that were made resulted in incomplete and incorrect medical reports and, more importantly, invaded the patients' privacy.

Based on the scenario above, answer the following question:

According to scenario 1, which of the following controls implemented by Antiques is a detective and administrative control?

- A. Enable the automatic update feature of the new software
- B. Review of all user access rights
- C. Review of the information security policy

Answer: B

Question: 82

Scenario 1: HealthGenic is a pediatric clinic that monitors the health and growth of individuals from infancy to early adulthood using a web-based medical software. The software is also used to schedule appointments, create customized medical reports, store patients' data and medical history, and communicate with all the involved parties, including parents, other physicians, and the medical laboratory staff.

Last month, HealthGenic experienced a number of service interruptions due to the increased number of users accessing the software. Another issue the company faced while using the software was the complicated user interface, which the untrained personnel found challenging to use.

The top management of HealthGenic immediately informed the company that had developed the software about the issue. The software company fixed the issue; however, in the process of doing so, it modified some files that comprised sensitive information related to HealthGenic's patients. The modifications that were made resulted in incomplete and incorrect medical reports and, more importantly, invaded the patients' privacy.

Based on the scenario above, answer the following question:

According to scenario 1. to detect (1) _____, Antiques should have implemented (2)

- A. (1) Patches. (2) an access control software
- B. (1) Intrusions on networks. (?) an intrusion detection system
- C. (1) Technical vulnerabilities. (2) network intrusions

Answer: B

Question: 83

Scenario 2: Beauty is a cosmetics company that has recently switched to an e-commerce model, leaving the traditional retail. The top management has decided to build their own custom platform in-house and outsource the payment process to an external provider operating online payments systems that support online money transfers.

Due to this transformation of the business model, a number of security controls were implemented based on the identified threats and vulnerabilities associated to critical assets. To protect customers' information. Beauty's employees had to sign a confidentiality agreement. In addition, the company reviewed all user access rights so that only authorized personnel can have access to sensitive files and drafted a new segregation of duties chart.

However, the transition was difficult for the IT team, who had to deal with a security incident not long after transitioning to the e-commerce model. After investigating the incident, the team concluded that due to the out-of-date anti-malware software, an attacker gained access to their files and exposed customers' information, including their names and home addresses.

The IT team decided to stop using the old anti-malware software and install a new one which would automatically remove malicious code in case of similar incidents. The new software was installed in every workstation within the company. After installing the new software, the team updated it with the latest malware definitions and enabled the automatic update feature to keep it up to date at all times. Additionally, they established an authentication process that requires a user identification and password when accessing sensitive information.

In addition, Beauty conducted a number of information security awareness sessions for the IT team and other employees that have access to confidential information in order to raise awareness on the importance of system and network security.

Based on the scenario above, answer the following question:

According to scenario 2, Solena decided to issue a press release in which its representatives denied the attack. What does this situation present?

- A. Lack of communication strategies
- B. Lack of transparency toward their users
- C. Lack of availability toward their users

Answer: B

Question: 84

Scenario 2: Beauty is a cosmetics company that has recently switched to an e-commerce model, leaving the traditional retail. The top management has decided to build their own custom platform in-house and outsource the payment process to an external provider operating online payments systems that support online money transfers.

Due to this transformation of the business model, a number of security controls were implemented based on the identified threats and vulnerabilities associated to critical assets. To protect customers' information. Beauty's employees had to sign a confidentiality agreement. In addition, the company reviewed all user access rights so that only authorized personnel can have access to sensitive files and drafted a new segregation of duties chart.

However, the transition was difficult for the IT team, who had to deal with a security incident not long after transitioning to the e-commerce model. After investigating the incident, the team concluded that due to the out-of-date anti-malware software, an attacker gained access to their files and exposed customers' information, including their names and home addresses.

The IT team decided to stop using the old anti-malware software and install a new one which would automatically remove malicious code in case of similar incidents. The new software was installed in every workstation within the company. After installing the new software, the team updated it with the latest malware definitions and enabled the automatic update feature to keep it up to date at all times. Additionally, they established an authentication process that requires a user identification and password when accessing sensitive information.

In addition, Beauty conducted a number of information security awareness sessions for the IT team and other employees that have access to confidential information in order to raise awareness on the importance of system and network security.

Based on the scenario above, answer the following question:

Which situation described in scenario 2 indicates service unavailability?

- A. Lucas was not able to access the website with his credentials
- B. Attackers still had access to the data when Solena delivered a press release
- C. Lucas was asked to change his password weekly

Answer: A

Question: 85

Scenario 2: Beauty is a cosmetics company that has recently switched to an e-commerce model, leaving the traditional retail. The top management has decided to build their own custom platform in-house and outsource the payment process to an external provider operating online payments systems that support online money transfers.

Due to this transformation of the business model, a number of security controls were implemented based on the identified threats and vulnerabilities associated to critical assets. To protect customers' information. Beauty's employees had to sign a confidentiality agreement. In addition, the company reviewed all user access rights so that only authorized personnel can have access to sensitive files and drafted a new segregation of duties chart.

However, the transition was difficult for the IT team, who had to deal with a security incident not long after transitioning to the e-commerce model. After investigating the incident, the team concluded that due to the out-of-date anti-malware software, an attacker gained access to their files and exposed customers' information, including their names and home addresses.

The IT team decided to stop using the old anti-malware software and install a new one which would automatically remove malicious code in case of similar incidents. The new software was installed in every workstation within the company. After installing the new software, the team updated it with the latest malware definitions and enabled the automatic update feature to keep it up to date at all times. Additionally, they established an authentication process that requires a user identification and password when accessing sensitive information.

In addition, Beauty conducted a number of information security awareness sessions for the IT team and other employees that have access to confidential information in order to raise awareness on the importance of system and network security.

Based on the scenario above, answer the following question:

Based on scenario 2. which principle of information security was NOT compromised by the attack?

- A. Confidentiality
- B. integrity
- C. Availability

Answer: B

Question: 86

Org Y. a well-known bank, uses an online banking platform that enables clients to easily and securely access their bank accounts. To log in. clients are required to enter the one-time authorization code sent to their smartphone. What can be concluded from this scenario?

- A. Org Y has implemented an integrity control that avoids the involuntary corruption of data
- B. Org Y has incorrectly implemented a security control that could become a vulnerability
- C. Org Y has implemented a security control that ensures the confidentiality of information

Answer: C

Question: 87

The application used by an organization has a complicated user interface. What does the complicated user interface represent in this case?

- A. An intrinsic vulnerability, since it is a characteristic of the asset
- B. An extrinsic vulnerability, since it is an external factor that impacts the asset
- C. A type of threat, since it may result in an unwanted incident

Answer: A

Question: 88

Which of the following practices indicates that Company A has implemented clock synchronization?

- A. Logs that record activities and other relevant events are stored and analyzed
- B. Information processing systems are coordinated according to an approved time source
- C. Suspected information security events are reported in a timely manner through an appropriate channel

Answer: B

Question: 89

The purpose of control 7.2 Physical entry of ISO/IEC 27001 is to ensure only authorized access to, the organization's information and other associated assets occur. Which action below does NOT fulfill this purpose?

- A. Verifying items of equipment containing storage media
- B. Using appropriate entry controls
- C. Implementing access points

Answer: A

Question: 90

The purpose of control 5.9 inventory of Information and other associated assets of ISO/IEC 27001 is to identify organization's information and other associated assets in order to preserve their information security and assign ownership. Which of the following actions does NOT fulfill this purpose?

- A. Conducting regular reviews of identified information and other associated assets
- B. Establishing rules to control physical and logical access to Information and other associated assets
- C. Assigning the responsibility for appropriately classifying and protecting information and other associated assets to the asset owners

Answer: B

Question: 91

Why should the security testing processes be defined and implemented in the development life cycle?

- A. To protect the production environment and data from compromise by development and test activities
- B. To validate if information security requirements are met when applications are deployed to the production environment
- C. To Identify organizational assets and define appropriate protection responsibilities

Answer: C

Question: 92

Upon the risk assessment outcomes. Socket Inc. decided to:

- Require the use of passwords with at least 12 characters containing uppercase and lowercase letters, symbols, and numbers
- Require the change of passwords at least once every 60 days
- Keep backup copies of files on IT-provided network drives
- Assign users to a separate network when they have access to cloud storage files storing customers' personal data.

Based on the scenario above, answer the following question:

Which of the following options indicate that Socket Inc. used risk modification to treat risks?

- A. Conducting a risk assessment before deciding to use third-party services
- B. Requiring the change of passwords at least once every 60 days
- C. Storing customers' personal data in a cloud-based storage

Answer: B

Question: 93

Upon the risk assessment outcomes. Socket Inc. decided to:

- Require the use of passwords with at least 12 characters containing uppercase and lowercase letters, symbols, and numbers
- Require the change of passwords at least once every 60 days
- Keep backup copies of files on IT-provided network drives
- Assign users to a separate network when they have access to cloud storage files storing customers' personal data.

What is the most important asset to Socket Inc. associated with the use of cloud storage? Refer to scenario 5.

- A. IT provided network drives
- B. Employees with access to cloud storage files
- C. Customers' personal data

Answer: C

Question: 94

Upon the risk assessment outcomes. Socket Inc. decided to:

- Require the use of passwords with at least 12 characters containing uppercase and lowercase letters, symbols, and numbers
- Require the change of passwords at least once every 60 days
- Keep backup copies of files on IT-provided network drives
- Assign users to a separate network when they have access to cloud storage files storing customers' personal data.

Based on scenario 5. Socket Inc. decided to use cloud storage to store customers' personal data considering that the identified risks have low likelihood and high impact, is this acceptable?

- A. Yes. because the calculated level of risk is below the acceptable threshold
- B. No, because the impact of the identified risks is considered in he high
- C. No. because the identified risks fall above the risk acceptable criteria threshold

Answer: B

Question: 95

Upon the risk assessment outcomes. Socket Inc. decided to:

- Require the use of passwords with at least 12 characters containing uppercase and lowercase letters, symbols, and numbers
- Require the change of passwords at least once every 60 days
- Keep backup copies of files on IT-provided network drives
- Assign users to a separate network when they have access to cloud storage files storing customers' personal data.

Based on scenario 5. Socket Inc. decided to assign users to a separate network when accessing cloud storage files. What does this ensure?

- A. Better security when using cloud storage files
- B. Elimination of risks related to the use of cloud storage services
- C. Creation of backup copies of files

Answer: A

Question: 96

Upon the risk assessment outcomes. Socket Inc. decided to:

- Require the use of passwords with at least 12 characters containing uppercase and lowercase letters, symbols, and numbers
- Require the change of passwords at least once every 60 days
- Keep backup copies of files on IT-provided network drives
- Assign users to a separate network when they have access to cloud storage files storing customers' personal data.

Based on scenario 5, what can be considered as a residual risk to Socket Inc.?

- A. Files are decrypted once the user is authenticated
- B. Users with access to cloud storage files are segregated on a separate network
- C. The use of passwords with at least 12 characters containing a mixture of uppercase and lowercase letters, symbols, and numbers

Answer: A

Question: 97

Why is the power/interest matrix used for?

- A. Define the information security and physical boundaries
- B. identify business requirements
- C. Determine and manage interested parties

Answer: C

Question: 98

An organization has established a policy that provides the personnel with the information required to effectively deploy encryption solutions in order to protect organizational confidential data

a. What type of policy is this?

- A. High-level general policy
- B. High-level topic-specific policy
- C. Topic-specific policy

Answer: C

Question: 99

Which of the following is the information security committee responsible for?

- A. Ensure smooth running of the ISMS
- B. Set annual objectives and the ISMS strategy
- C. Treat the nonconformities

Answer: B

Question: 100

What risk treatment option has Company A Implemented If it has decided not to collect information from users so that It is not necessary to implement information security controls?

- A. Risk avoidance
- B. Risk retention
- C. Risk modification

Answer: A

Question: 101

TradeB communicated the information security processes and procedures to employees. Which principle of efficient communication strategy did they use?

- A. Transparency
- B. Appropriateness
- C. Responsiveness

Answer: A

Question: 102

Once they made sure that the attackers do not have access in their system, the security administrators decided to proceed with the forensic analysis. They concluded that their access security system was not designed for threat detection, including the detection of malicious files which could be the cause of possible future attacks.

Based on these findings, Texas H&H Inc, decided to modify its access security system to avoid future incidents and integrate an incident management policy in their Information security policy that could serve as guidance for employees on how to respond to similar incidents.

Based on the scenario above, answer the following question:

Texas M&H Inc. decided to integrate the incident management policy to the existent information security policy. How do you define this situation?

- A. Acceptable, the incident management policy may be integrated into the overall information security policy of the organization
- B. Acceptable, but only if the incident management policy addresses environmental, or health and safety issues
- C. Unacceptable, the incident management policy should be drafted as a separate document in order to be clear and effective

Answer: A

Question: 103

Scenario 7: Incident Response at Texas H&H Inc.

Once they made sure that the attackers do not have access in their system, the security administrators decided to proceed with the forensic analysis. They concluded that their access security system was not designed for threat detection, including the detection of malicious files which could be the cause of possible future attacks.

Based on these findings, Texas H&H Inc, decided to modify its access security system to avoid future incidents and integrate an incident management policy in their Information security policy that could serve as guidance for employees on how to respond to similar incidents.

Based on the scenario above, answer the following question:

Texas H&H Inc. decided to assign an internal expert for their forensic analysis. Is this acceptable? Refer to scenario 7.

- A. Yes. forensic analysis can be done by either an internal or external expert
- B. Yes. hiring an external expert for forensic analysis is a requirement of the standard
- C. No. the company's forensic analysis should be based on the conclusion of its cloud storage provider investigation

Answer: A

Question: 104

Scenario 7: Incident Response at Texas H&H Inc.

Once they made sure that the attackers do not have access in their system, the security administrators decided to proceed with the forensic analysis. They concluded that their access security system was not designed for threat detection, including the detection of malicious files which could be the cause of possible future attacks.

Based on these findings, Texas H&H Inc, decided to modify its access security system to avoid future incidents and integrate an incident management policy in their Information security policy that could serve as guidance for employees on how to respond to similar incidents.

Based on the scenario above, answer the following question:

According to scenario 7, the team prevented a potential attack based on knowledge gained from previous incidents. Is this acceptable?

- A. No, before responding to an information security incident, an information security incident management policy must be established
- B. No, every information security incident is different, hence knowledge gained from previous incidents cannot prevent potential attacks
- C. Yes, in the absence of an information security incident management policy, lessons learned can be applied

Answer: C

Question: 105

Scenario 7: Incident Response at Texas H&H Inc.

Once they made sure that the attackers do not have access in their system, the security administrators decided to proceed with the forensic analysis. They concluded that their access security system was not designed for threat detection, including the detection of malicious files which could be the cause of possible future attacks.

Based on these findings, Texas H&H Inc. decided to modify its access security system to avoid future incidents and integrate an incident management policy in their Information security policy that could serve as guidance for employees on how to respond to similar incidents.

Based on the scenario above, answer the following question:

Based on scenario 7, what else should Texas H&H Inc. do when responding to the incident?

- A. Decide to stop using cloud services in order to eliminate the risk of similar incidents happening in the future
- B. Record and document the incident which serves as input for future corrective actions
- C. Communicate the updated Information security policy only to the top management of the company

Answer: B

Question: 106

Once they made sure that the attackers do not have access in their system, the security administrators decided to proceed with the forensic analysis. They concluded that their access security system was not designed for threat detection, including the detection of malicious files which could be the cause of possible future attacks.

Based on these findings, Texas H&H Inc. decided to modify its access security system to avoid future incidents and integrate an incident management policy in their Information security policy that could serve as guidance for employees on how to respond to similar incidents.

Based on the scenario above, answer the following question:

Which situation described in scenario 7 indicates that Texas H&H Inc. implemented a detective control?

- A. Texas H&H Inc. integrated the incident management policy in its information security policy
- B. Texas H&H Inc. tested its system for malicious activity and checked cloud-based email settings
- C. Texas H&H Inc. hired an expert to conduct a forensic analysis

Answer: C

Question: 107

Following a reported event, an Information security event ticket has been completed and its priority has been assigned. Then, the event has been evaluated to determine if it is an information security incident, which phase of the incident management has been completed?

- A. initial assessment and decision
- B. Detection and reporting
- C. Evaluation and confirmation

Answer: C

Question: 108

What should an organization demonstrate through documentation?

- A. That the complexity of processes and their interactions is documented
- B. That the distribution of paper copies is regularly complete
- C. That its security controls are implemented based on risk scenarios

Answer: C

Question: 109

HealthGenic is a pediatric clinic that monitors the health and growth of individuals from infancy to early adulthood using a web-based medical software. The software is also used to schedule appointments, create customized medical reports, store patients' data and medical history, and communicate with all the involved parties, including parents, other physicians, and the medical laboratory staff.

Last month, HealthGenic experienced a number of service interruptions due to the increased number of users accessing the software. Another issue the company faced while using the software was the complicated user interface, which the untrained personnel found challenging to use. The top management of HealthGenic immediately informed the company that had developed the software about the issue. The software company fixed the issue; however, in the process of doing so, it modified some files that comprised sensitive information related to HealthGenic's patients. The modifications that were made resulted in incomplete and incorrect medical reports and, more importantly, invaded the patients' privacy.

Based on scenario 8, how does the HealthGenic's negligence affect the ISMS certificate?

- A. HealthGenic will be able to renew the ISMS certificate, as they did not detect any information security incident in the past two years
- B. HealthGenic might not be able to renew the ISMS certificate, as it has not conducted management

reviews at planned intervals

C. HealthGenic might not be able to renew the ISMS certificate, as the internal audit lasted longer than planned

Answer: B

Question: 110

HealthGenic is a pediatric clinic that monitors the health and growth of individuals from infancy to early adulthood using a web-based medical software. The software is also used to schedule appointments, create customized medical reports, store patients' data and medical history, and communicate with all the [^involved parties, including parents, other physicians, and the medical laboratory staff.

Last month, HealthGenic experienced a number of service interruptions due to the increased number of users accessing the software. Another issue the company faced while using the software was the complicated user interface, which the untrained personnel found challenging to use.

The top management of HealthGenic immediately informed the company that had developed the software about the issue. The software company fixed the issue; however, in the process of doing so, it modified some files that comprised sensitive information related to HealthGenic's patients. The modifications that were made resulted in incomplete and incorrect medical reports and, more importantly, invaded the patients' privacy.

Which situation presented in scenario 8 is not in compliance with ISO/IEC 27001 requirements?

A. Emma has an operational role in the HealthGenic's management system

B. The recodification audit is planned to be conducted two years after HealthGenic implemented the ISMS

C. Emma had access to all offices and documentation of HealthGenic

Answer: A

Question: 111

If an organization wants to monitor operations in real time and notify users about deviations, which type of dashboard should be used?

A. Strategic dashboard

B. Tactical dashboard

C. Operational dashboard

Answer: C

Question: 112

Who should verify the effectiveness of the corrective actions taken by the auditee after an internal audit?

- A. An Independent auditor should be contracted to perform this evaluation
- B. The internal auditor
- C. The information security manager

Answer: B

Question: 113

Company X restricted the access of the internal auditor of some of its documentation taking into account its confidentiality. Is this acceptable?

- A. Yes. it is up to the company to determine what an internal auditor can access
- B. Yes. confidential information should not be increased by internal auditors
- C. No. restricting the internal auditor's access to offices and documentation can negatively affect the internal audit process

Answer: C

Question: 114

Invalid Electric, a manufacturer of electrical components, is preparing for its upcoming ISO 27001 certification audit. This is the first time the company has undergone such an audit, and many of its employees are not familiar with the process. The management team is concerned that employees may not be adequately prepared for interviews and the scrutiny of documentation during the audit. To ensure that employees are ready for the audit, the management team is considering several options to help them understand what to expect and how to handle the auditor's questions confidently.

How can Invalid Electric's ensure that its employees are prepared for the audit?

- A. By conducting practice Interviews with the employees
- B. By allowing the employees to observe the technologies used
- C. By showing the employees the internal audit reports so they can anticipate the questions asked by the auditor

Answer: A

Question: 115

Invalid Electric, a manufacturer of electrical components, is preparing for its upcoming ISO 27001 certification audit. This is the first time the company has undergone such an audit, and many of its employees are not familiar with the process. The management team is concerned that employees may not be adequately prepared for interviews and the scrutiny of documentation during the audit. To ensure that employees are ready for the audit, the management team is considering several options to help them understand what to expect and how to handle the auditor's questions confidently.

Based on scenario 10, did Invalid Electric provide a valid reason for requesting the replacement of the audit team leader?

- A. No, because Issuing a recommendation for certification to a main competitor is not a conflict of interest situation
- B. No, because the auditee can request the replacement of an auditor only if the auditor has worked for the auditee
- C. Yes, because the auditee can request to replace an auditor that has worked for one of its major competitors

Answer: C

Question: 116

According to ISO/IEC 27001, why shall organizations document nonconformities?

- A. To provide evidence of the requirements set by internal audit after reviewing their audit reports
- B. To provide evidence of the results of the corrective actions and the nature of the nonconformities
- C. To provide evidence of regulations set by external sources that need to be followed by the organization

Answer: B

Question: 117

Scenario 1:

HealthGenic is a leading multi-specialty healthcare organization providing patients with

comprehensive medical services in Toronto, Canada

a. The organization relies heavily on a web-based medical software platform to monitor patient health, schedule appointments, generate customized medical reports, securely store patient data, and facilitate seamless communication among various stakeholders, including patients, physicians, and medical laboratory staff.

As the organization expanded its services and demand grew, frequent and prolonged service interruptions became more common, causing significant disruptions to patient care and administrative processes. As such, HealthGenic initiated a comprehensive risk analysis to assess the severity of risks it faced.

When comparing the risk analysis results with its risk criteria to determine whether the risk and its significance were acceptable or tolerable, HealthGenic noticed a critical gap in its capacity planning and infrastructure resilience. Recognizing the urgency of this issue, HealthGenic reached out to the software development company responsible for its platform. Utilizing its expertise in healthcare technology, data management, and compliance regulations, the software development company successfully resolved the service interruptions.

However, HealthGenic also uncovered unauthorized changes to user access controls. Consequently, some medical reports were altered, resulting in incomplete and inaccurate medical records. The company swiftly acknowledged and corrected the unintentional changes to user access controls. When analyzing the root cause of these changes, HealthGenic identified a vulnerability related to the segregation of duties within the IT department, which allowed individuals with system administration access also to manage user access controls. Therefore, HealthGenic decided to prioritize controls related to organizational structure, including segregation of duties, job rotations, job descriptions, and approval processes.

In response to the consequences of the service interruptions, the software development company revamped its infrastructure by adopting a scalable architecture hosted on a cloud platform, enabling dynamic resource allocation based on demand. Rigorous load testing and performance optimization were conducted to identify and address potential bottlenecks, ensuring the system could handle increased user loads seamlessly. Additionally, the company promptly assessed the unauthorized access and data alterations.

To ensure that all employees, including interns, are aware of the importance of data security and the proper handling of patient information, HealthGenic included controls tailored to specifically address employee training, management reviews, and internal audits. Additionally, given the sensitivity of patient data, HealthGenic implemented strict confidentiality measures, including robust authentication methods, such as multi-factor authentication.

In response to the challenges faced by HealthGenic, the organization recognized the vital importance of ensuring a secure cloud computing environment. It initiated a comprehensive self-assessment specifically tailored to evaluate and enhance the security of its cloud infrastructure and practices.

Which information security principle was impacted by the alteration of medical records?

- A. Availability
- B. Confidentiality
- C. Integrity

Answer: C

Question: 118

Scenario 1:

HealthGenic is a leading multi-specialty healthcare organization providing patients with comprehensive medical services in Toronto, Canada

a. The organization relies heavily on a web-based medical software platform to monitor patient health, schedule appointments, generate customized medical reports, securely store patient data, and facilitate seamless communication among various stakeholders, including patients, physicians, and medical laboratory staff.

As the organization expanded its services and demand grew, frequent and prolonged service interruptions became more common, causing significant disruptions to patient care and administrative processes. As such, HealthGenic initiated a comprehensive risk analysis to assess the severity of risks it faced.

When comparing the risk analysis results with its risk criteria to determine whether the risk and its significance were acceptable or tolerable, HealthGenic noticed a critical gap in its capacity planning and infrastructure resilience. Recognizing the urgency of this issue, HealthGenic reached out to the software development company responsible for its platform. Utilizing its expertise in healthcare technology, data management, and compliance regulations, the software development company successfully resolved the service interruptions.

However, HealthGenic also uncovered unauthorized changes to user access controls. Consequently, some medical reports were altered, resulting in incomplete and inaccurate medical records. The company swiftly acknowledged and corrected the unintentional changes to user access controls. When analyzing the root cause of these changes, HealthGenic identified a vulnerability related to the segregation of duties within the IT department, which allowed individuals with system administration access also to manage user access controls. Therefore, HealthGenic decided to prioritize controls related to organizational structure, including segregation of duties, job rotations, job descriptions, and approval processes.

In response to the consequences of the service interruptions, the software development company revamped its infrastructure by adopting a scalable architecture hosted on a cloud platform, enabling dynamic resource allocation based on demand. Rigorous load testing and performance optimization were conducted to identify and address potential bottlenecks, ensuring the system could handle increased user loads seamlessly. Additionally, the company promptly assessed the unauthorized access and data alterations.

To ensure that all employees, including interns, are aware of the importance of data security and the proper handling of patient information, HealthGenic included controls tailored to specifically address employee training, management reviews, and internal audits. Additionally, given the sensitivity of patient data, HealthGenic implemented strict confidentiality measures, including robust authentication methods, such as multi-factor authentication.

In response to the challenges faced by HealthGenic, the organization recognized the vital importance of ensuring a secure cloud computing environment. It initiated a comprehensive self-assessment specifically tailored to evaluate and enhance the security of its cloud infrastructure and practices.

Based on scenario 1, what type of controls did HealthGenic decide to prioritize?

- A. Technical controls
- B. Administrative controls
- C. Managerial controls

Answer: B

Question: 119

Scenario 1:

HealthGenic is a leading multi-specialty healthcare organization providing patients with comprehensive medical services in Toronto, Canada.

a. The organization relies heavily on a web-based medical software platform to monitor patient health, schedule appointments, generate customized medical reports, securely store patient data, and facilitate seamless communication among various stakeholders, including patients, physicians, and medical laboratory staff.

As the organization expanded its services and demand grew, frequent and prolonged service interruptions became more common, causing significant disruptions to patient care and administrative processes. As such, HealthGenic initiated a comprehensive risk analysis to assess the severity of risks it faced.

When comparing the risk analysis results with its risk criteria to determine whether the risk and its significance were acceptable or tolerable, HealthGenic noticed a critical gap in its capacity planning and infrastructure resilience. Recognizing the urgency of this issue, HealthGenic reached out to the software development company responsible for its platform. Utilizing its expertise in healthcare technology, data management, and compliance regulations, the software development company successfully resolved the service interruptions.

However, HealthGenic also uncovered unauthorized changes to user access controls. Consequently, some medical reports were altered, resulting in incomplete and inaccurate medical records. The company swiftly acknowledged and corrected the unintentional changes to user access controls.

When analyzing the root cause of these changes, HealthGenic identified a vulnerability related to the segregation of duties within the IT department, which allowed individuals with system administration access also to manage user access controls. Therefore, HealthGenic decided to prioritize controls related to organizational structure, including segregation of duties, job rotations, job descriptions, and approval processes.

In response to the consequences of the service interruptions, the software development company revamped its infrastructure by adopting a scalable architecture hosted on a cloud platform, enabling dynamic resource allocation based on demand. Rigorous load testing and performance optimization were conducted to identify and address potential bottlenecks, ensuring the system could handle increased user loads seamlessly. Additionally, the company promptly assessed the unauthorized access and data alterations.

To ensure that all employees, including interns, are aware of the importance of data security and the proper handling of patient information, HealthGenic included controls tailored to specifically address employee training, management reviews, and internal audits. Additionally, given the sensitivity of patient data, HealthGenic implemented strict confidentiality measures, including robust authentication methods, such as multi-factor authentication.

In response to the challenges faced by HealthGenic, the organization recognized the vital importance of ensuring a secure cloud computing environment. It initiated a comprehensive self-assessment specifically tailored to evaluate and enhance the security of its cloud infrastructure and practices.

According to scenario 1, what is the possible threat associated with the vulnerability discovered by HealthGenic when analyzing the root cause of unauthorized changes?

- A. Theft
- B. Lawsuit
- C. Fraud

Answer: C

Question: 120

Scenario 1:

HealthGenic is a leading multi-specialty healthcare organization providing patients with comprehensive medical services in Toronto, Canada.

a. The organization relies heavily on a web-based medical software platform to monitor patient health, schedule appointments, generate customized medical reports, securely store patient data, and facilitate seamless communication among various stakeholders, including patients, physicians, and medical laboratory staff.

As the organization expanded its services and demand grew, frequent and prolonged service interruptions became more common, causing significant disruptions to patient care and administrative processes. As such, HealthGenic initiated a comprehensive risk analysis to assess the severity of risks it faced.

When comparing the risk analysis results with its risk criteria to determine whether the risk and its significance were acceptable or tolerable, HealthGenic noticed a critical gap in its capacity planning and infrastructure resilience. Recognizing the urgency of this issue, HealthGenic reached out to the software development company responsible for its platform. Utilizing its expertise in healthcare technology, data management, and compliance regulations, the software development company successfully resolved the service interruptions.

However, HealthGenic also uncovered unauthorized changes to user access controls. Consequently, some medical reports were altered, resulting in incomplete and inaccurate medical records. The company swiftly acknowledged and corrected the unintentional changes to user access controls. When analyzing the root cause of these changes, HealthGenic identified a vulnerability related to the segregation of duties within the IT department, which allowed individuals with system administration access also to manage user access controls. Therefore, HealthGenic decided to prioritize controls related to organizational structure, including segregation of duties, job rotations, job descriptions, and approval processes.

In response to the consequences of the service interruptions, the software development company revamped its infrastructure by adopting a scalable architecture hosted on a cloud platform, enabling dynamic resource allocation based on demand. Rigorous load testing and performance optimization were conducted to identify and address potential bottlenecks, ensuring the system could handle increased user loads seamlessly. Additionally, the company promptly assessed the unauthorized access and data alterations.

To ensure that all employees, including interns, are aware of the importance of data security and the proper handling of patient information, HealthGenic included controls tailored to specifically address employee training, management reviews, and internal audits. Additionally, given the sensitivity of patient data, HealthGenic implemented strict confidentiality measures, including robust authentication methods, such as multi-factor authentication.

In response to the challenges faced by HealthGenic, the organization recognized the vital importance

of ensuring a secure cloud computing environment. It initiated a comprehensive self-assessment specifically tailored to evaluate and enhance the security of its cloud infrastructure and practices.

During which of the following processes did HealthGenic notice a critical gap in its capacity planning and infrastructure resilience?

- A. Risk evaluation
- B. Risk treatment
- C. Risk acceptance

Answer: A

Question: 121

Scenario 1:

HealthGenic is a leading multi-specialty healthcare organization providing patients with comprehensive medical services in Toronto, Canada.

a. The organization relies heavily on a web-based medical software platform to monitor patient health, schedule appointments, generate customized medical reports, securely store patient data, and facilitate seamless communication among various stakeholders, including patients, physicians, and medical laboratory staff.

As the organization expanded its services and demand grew, frequent and prolonged service interruptions became more common, causing significant disruptions to patient care and administrative processes. As such, HealthGenic initiated a comprehensive risk analysis to assess the severity of risks it faced.

When comparing the risk analysis results with its risk criteria to determine whether the risk and its significance were acceptable or tolerable, HealthGenic noticed a critical gap in its capacity planning and infrastructure resilience. Recognizing the urgency of this issue, HealthGenic reached out to the software development company responsible for its platform. Utilizing its expertise in healthcare technology, data management, and compliance regulations, the software development company successfully resolved the service interruptions.

However, HealthGenic also uncovered unauthorized changes to user access controls. Consequently, some medical reports were altered, resulting in incomplete and inaccurate medical records. The company swiftly acknowledged and corrected the unintentional changes to user access controls.

When analyzing the root cause of these changes, HealthGenic identified a vulnerability related to the segregation of duties within the IT department, which allowed individuals with system administration access also to manage user access controls. Therefore, HealthGenic decided to prioritize controls related to organizational structure, including segregation of duties, job rotations, job descriptions, and approval processes.

In response to the consequences of the service interruptions, the software development company revamped its infrastructure by adopting a scalable architecture hosted on a cloud platform, enabling dynamic resource allocation based on demand. Rigorous load testing and performance optimization were conducted to identify and address potential bottlenecks, ensuring the system could handle increased user loads seamlessly. Additionally, the company promptly assessed the unauthorized access and data alterations.

To ensure that all employees, including interns, are aware of the importance of data security and the

proper handling of patient information, HealthGenic included controls tailored to specifically address employee training, management reviews, and internal audits. Additionally, given the sensitivity of patient data, HealthGenic implemented strict confidentiality measures, including robust authentication methods, such as multi-factor authentication.

In response to the challenges faced by HealthGenic, the organization recognized the vital importance of ensuring a secure cloud computing environment. It initiated a comprehensive self-assessment specifically tailored to evaluate and enhance the security of its cloud infrastructure and practices.

Based on scenario 1, has HealthGenic implemented physical access controls?

- A. Yes, it included physical access controls in its strategy
- B. No, its primary focus has been on digital access controls
- C. No, its primary focus has been on legal access controls

Answer: B

Question: 122

Scenario 2:

Beauty is a well-established cosmetics company in the beauty industry. The company was founded several decades ago with a passion for creating high-quality skincare, makeup, and personal care products that enhance natural beauty. Over the years, Beauty has built a strong reputation for its innovative product offerings, commitment to customer satisfaction, and dedication to ethical and sustainable business practices.

In response to the rapidly evolving landscape of consumer shopping habits, Beauty transitioned from traditional retail to an e-commerce model. To initiate this strategy, Beauty conducted a comprehensive information security risk assessment, analyzing potential threats and vulnerabilities associated with its new e-commerce venture, aligned with its business strategy and objectives. Concerning the identified risks, the company implemented several information security controls. All employees were required to sign confidentiality agreements to emphasize the importance of protecting sensitive customer data.

a. The company thoroughly reviewed user access rights, ensuring only authorized personnel could access sensitive information. In addition, since the company stores valuable products and unique formulas in the warehouse, it installed alarm systems and surveillance cameras with real-time alerts to prevent any potential act of vandalism.

After a while, the information security team analyzed the audit logs to monitor and track activities across the newly implemented security controls. Upon investigating and analyzing the audit logs, it was discovered that an attacker had accessed the system due to out-of-date anti-malware software, exposing customers' sensitive information, including names and home addresses. Following this, the IT team replaced the anti-malware software with a new one capable of automatically removing malicious code in case of similar incidents. The new software was installed on all workstations and regularly updated with the latest malware definitions, with an automatic update feature enabled. An authentication process requiring user identification and a password was also implemented to access sensitive information.

During the investigation, Maya, the information security manager of Beauty, found that information security responsibilities in job descriptions were not clearly defined, for which the company took

immediate action. Recognizing that their e-commerce operations would have a global reach, Beauty diligently researched and complied with the industry's legal, statutory, regulatory, and contractual requirements. It considered international and local regulations, including data privacy laws, consumer protection acts, and global trade agreements.

To meet these requirements, Beauty invested in legal counsel and compliance experts who continuously monitored and ensured the company's compliance with legal standards in every market they operated in. Additionally, Beauty conducted multiple information security awareness sessions for the IT team and other employees with access to confidential information, emphasizing the importance of system and network security.

Under which category does the vulnerability identified by Maya during the incident fall into?

- A. Network
- B. Site
- C. Organization

Answer: C

Question: 123

Scenario 2:

Beauty is a well-established cosmetics company in the beauty industry. The company was founded several decades ago with a passion for creating high-quality skincare, makeup, and personal care products that enhance natural beauty. Over the years, Beauty has built a strong reputation for its innovative product offerings, commitment to customer satisfaction, and dedication to ethical and sustainable business practices.

In response to the rapidly evolving landscape of consumer shopping habits, Beauty transitioned from traditional retail to an e-commerce model. To initiate this strategy, Beauty conducted a comprehensive information security risk assessment, analyzing potential threats and vulnerabilities associated with its new e-commerce venture, aligned with its business strategy and objectives. Concerning the identified risks, the company implemented several information security controls. All employees were required to sign confidentiality agreements to emphasize the importance of protecting sensitive customer data.

a. The company thoroughly reviewed user access rights, ensuring only authorized personnel could access sensitive information. In addition, since the company stores valuable products and unique formulas in the warehouse, it installed alarm systems and surveillance cameras with real-time alerts to prevent any potential act of vandalism.

After a while, the information security team analyzed the audit logs to monitor and track activities across the newly implemented security controls. Upon investigating and analyzing the audit logs, it was discovered that an attacker had accessed the system due to out-of-date anti-malware software, exposing customers' sensitive information, including names and home addresses. Following this, the IT team replaced the anti-malware software with a new one capable of automatically removing malicious code in case of similar incidents. The new software was installed on all workstations and regularly updated with the latest malware definitions, with an automatic update feature enabled. An authentication process requiring user identification and a password was also implemented to access sensitive information.

During the investigation, Maya, the information security manager of Beauty, found that information security responsibilities in job descriptions were not clearly defined, for which the company took immediate action. Recognizing that their e-commerce operations would have a global reach, Beauty diligently researched and complied with the industry's legal, statutory, regulatory, and contractual requirements. It considered international and local regulations, including data privacy laws, consumer protection acts, and global trade agreements.

To meet these requirements, Beauty invested in legal counsel and compliance experts who continuously monitored and ensured the company's compliance with legal standards in every market they operated in. Additionally, Beauty conducted multiple information security awareness sessions for the IT team and other employees with access to confidential information, emphasizing the importance of system and network security.

What type of assets were compromised in Beauty's incident?

- A. Personal virtual assets
- B. Organizational virtual assets
- C. Organizational physical assets

Answer: A

Question: 124

Scenario 2:

Beauty is a well-established cosmetics company in the beauty industry. The company was founded several decades ago with a passion for creating high-quality skincare, makeup, and personal care products that enhance natural beauty. Over the years, Beauty has built a strong reputation for its innovative product offerings, commitment to customer satisfaction, and dedication to ethical and sustainable business practices.

In response to the rapidly evolving landscape of consumer shopping habits, Beauty transitioned from traditional retail to an e-commerce model. To initiate this strategy, Beauty conducted a comprehensive information security risk assessment, analyzing potential threats and vulnerabilities associated with its new e-commerce venture, aligned with its business strategy and objectives. Concerning the identified risks, the company implemented several information security controls. All employees were required to sign confidentiality agreements to emphasize the importance of protecting sensitive customer data.

a. The company thoroughly reviewed user access rights, ensuring only authorized personnel could access sensitive information. In addition, since the company stores valuable products and unique formulas in the warehouse, it installed alarm systems and surveillance cameras with real-time alerts to prevent any potential act of vandalism.

After a while, the information security team analyzed the audit logs to monitor and track activities across the newly implemented security controls. Upon investigating and analyzing the audit logs, it was discovered that an attacker had accessed the system due to out-of-date anti-malware software, exposing customers' sensitive information, including names and home addresses. Following this, the IT team replaced the anti-malware software with a new one capable of automatically removing malicious code in case of similar incidents. The new software was installed on all workstations and regularly updated with the latest malware definitions, with an automatic update feature enabled. An

authentication process requiring user identification and a password was also implemented to access sensitive information.

During the investigation, Maya, the information security manager of Beauty, found that information security responsibilities in job descriptions were not clearly defined, for which the company took immediate action. Recognizing that their e-commerce operations would have a global reach, Beauty diligently researched and complied with the industry's legal, statutory, regulatory, and contractual requirements. It considered international and local regulations, including data privacy laws, consumer protection acts, and global trade agreements.

To meet these requirements, Beauty invested in legal counsel and compliance experts who continuously monitored and ensured the company's compliance with legal standards in every market they operated in. Additionally, Beauty conducted multiple information security awareness sessions for the IT team and other employees with access to confidential information, emphasizing the importance of system and network security.

What type of controls did Beauty implement to ensure the safety of products and unique formulas stored in the warehouse?

- A. Administrative
- B. Legal
- C. Technical

Answer: C

Question: 125

Scenario 2:

Beauty is a well-established cosmetics company in the beauty industry. The company was founded several decades ago with a passion for creating high-quality skincare, makeup, and personal care products that enhance natural beauty. Over the years, Beauty has built a strong reputation for its innovative product offerings, commitment to customer satisfaction, and dedication to ethical and sustainable business practices.

In response to the rapidly evolving landscape of consumer shopping habits, Beauty transitioned from traditional retail to an e-commerce model. To initiate this strategy, Beauty conducted a comprehensive information security risk assessment, analyzing potential threats and vulnerabilities associated with its new e-commerce venture, aligned with its business strategy and objectives. Concerning the identified risks, the company implemented several information security controls. All employees were required to sign confidentiality agreements to emphasize the importance of protecting sensitive customer data.

a. The company thoroughly reviewed user access rights, ensuring only authorized personnel could access sensitive information. In addition, since the company stores valuable products and unique formulas in the warehouse, it installed alarm systems and surveillance cameras with real-time alerts to prevent any potential act of vandalism.

After a while, the information security team analyzed the audit logs to monitor and track activities across the newly implemented security controls. Upon investigating and analyzing the audit logs, it was discovered that an attacker had accessed the system due to out-of-date anti-malware software, exposing customers' sensitive information, including names and home addresses. Following this, the

IT team replaced the anti-malware software with a new one capable of automatically removing malicious code in case of similar incidents. The new software was installed on all workstations and regularly updated with the latest malware definitions, with an automatic update feature enabled. An authentication process requiring user identification and a password was also implemented to access sensitive information.

During the investigation, Maya, the information security manager of Beauty, found that information security responsibilities in job descriptions were not clearly defined, for which the company took immediate action. Recognizing that their e-commerce operations would have a global reach, Beauty diligently researched and complied with the industry's legal, statutory, regulatory, and contractual requirements. It considered international and local regulations, including data privacy laws, consumer protection acts, and global trade agreements.

To meet these requirements, Beauty invested in legal counsel and compliance experts who continuously monitored and ensured the company's compliance with legal standards in every market they operated in. Additionally, Beauty conducted multiple information security awareness sessions for the IT team and other employees with access to confidential information, emphasizing the importance of system and network security.

Based on scenario 2, what type of controls did Beauty use during incident investigation?

- A. Preventive controls
- B. Detective controls
- C. Corrective controls

Answer: B

Question: 126

Scenario 2:

Beauty is a well-established cosmetics company in the beauty industry. The company was founded several decades ago with a passion for creating high-quality skincare, makeup, and personal care products that enhance natural beauty. Over the years, Beauty has built a strong reputation for its innovative product offerings, commitment to customer satisfaction, and dedication to ethical and sustainable business practices.

In response to the rapidly evolving landscape of consumer shopping habits, Beauty transitioned from traditional retail to an e-commerce model. To initiate this strategy, Beauty conducted a comprehensive information security risk assessment, analyzing potential threats and vulnerabilities associated with its new e-commerce venture, aligned with its business strategy and objectives. Concerning the identified risks, the company implemented several information security controls. All employees were required to sign confidentiality agreements to emphasize the importance of protecting sensitive customer data.

a. The company thoroughly reviewed user access rights, ensuring only authorized personnel could access sensitive information. In addition, since the company stores valuable products and unique formulas in the warehouse, it installed alarm systems and surveillance cameras with real-time alerts to prevent any potential act of vandalism.

After a while, the information security team analyzed the audit logs to monitor and track activities across the newly implemented security controls. Upon investigating and analyzing the audit logs, it was discovered that an attacker had accessed the system due to out-of-date anti-malware software,

exposing customers' sensitive information, including names and home addresses. Following this, the IT team replaced the anti-malware software with a new one capable of automatically removing malicious code in case of similar incidents. The new software was installed on all workstations and regularly updated with the latest malware definitions, with an automatic update feature enabled. An authentication process requiring user identification and a password was also implemented to access sensitive information.

During the investigation, Maya, the information security manager of Beauty, found that information security responsibilities in job descriptions were not clearly defined, for which the company took immediate action. Recognizing that their e-commerce operations would have a global reach, Beauty diligently researched and complied with the industry's legal, statutory, regulatory, and contractual requirements. It considered international and local regulations, including data privacy laws, consumer protection acts, and global trade agreements.

To meet these requirements, Beauty invested in legal counsel and compliance experts who continuously monitored and ensured the company's compliance with legal standards in every market they operated in. Additionally, Beauty conducted multiple information security awareness sessions for the IT team and other employees with access to confidential information, emphasizing the importance of system and network security.

Based on scenario 2, which information security requirement was NOT assessed by Beauty?

- A. Alignment of the risk assessment with the organization's strategy
- B. Compliance with legal, regulatory, and contractual obligations
- C. Principles and objectives for the information life cycle

Answer: C

Question: 127

A healthcare organization needs to ensure that patient records are available to the medical staff whenever needed. Which measure should it prioritize to achieve this?

- A. Implementing multi-factor authentication
- B. Establishing record retention policies
- C. Using version control systems for data management

Answer: B

Question: 128

An employee from Reyae Ltd. unintentionally sent an email containing critical business strategies to a competitor. Which information security principle was compromised in this case?

- A. Integrity
- B. Availability

C. Confidentiality

Answer: C

Question: 129

A tech company rapidly expanded its operations over the past few years. Its information system, consisting of servers, databases, and communication tools, is a critical part of its daily operations. However, due to the rapid growth and increased data flow, the company is now facing a saturation of its information system. This saturation has led to slower response times, increased downtime, and difficulty in managing the overwhelming volume of data.

a. In which category does this threat fall into?

- A. Infrastructure failures
- B. Technical failures
- C. Compromise of functions

Answer: A

Question: 130

Which of the following processes may involve increasing risk in order to pursue an opportunity?

- A. Risk analysis
- B. Risk treatment
- C. Risk identification

Answer: B

Question: 131

Levo Corporation has implemented a demilitarized zone (DMZ) and virtual private network (VPN) to secure its network. What controls did Levo Corporation implement in this case?

- A. Preventive controls
- B. Detective controls
- C. Corrective controls

Answer: A

Question: 132

Scenario 3: Socket Inc. is a dynamic telecommunications company specializing in wireless products and services, committed to delivering high-quality and secure communication solutions. Socket Inc. leverages innovative technology, including the MongoDB database, renowned for its high availability, scalability, and flexibility, to provide reliable, accessible, efficient, and well-organized services to its customers. Recently, the company faced a security breach where external hackers exploited the default settings of its MongoDB database due to an oversight in the configuration settings, which had not been properly addressed. Fortunately, diligent data backups and centralized logging through a server ensured no loss of information. In response to this incident, Socket Inc. undertook a thorough evaluation of its security measures. The company recognized the urgent need to improve its information security and decided to implement an information security management system (ISMS) based on ISO/IEC 27001.

To improve its data security and protect its resources, Socket Inc. implemented entry controls and secure access points. These measures were designed to prevent unauthorized access to critical areas housing sensitive data and essential assets. In compliance with relevant laws, regulations, and ethical standards, Socket Inc. implemented pre-employment background checks tailored to business needs, information classification, and associated risks. A formalized disciplinary procedure was also established to address policy violations. Additionally, security measures were implemented for personnel working remotely to safeguard information accessed, processed, or stored outside the organization's premises.

Socket Inc. safeguarded its information processing facilities against power failures and other disruptions. Unauthorized access to critical records from external sources led to the implementation of data flow control services to prevent unauthorized access between departments and external networks. In addition, Socket Inc. used data masking based on the organization's topic-level general policy on access control and other related topic-level general policies and business requirements, considering applicable legislation. It also updated and documented all operating procedures for information processing facilities and ensured that they were accessible to top management exclusively.

The company also implemented a control to define and implement rules for the effective use of cryptography, including cryptographic key management, to protect the database from unauthorized access. The implementation was based on all relevant agreements, legislation, regulations, and the information classification scheme. Network segregation using VPNs was proposed to improve security and reduce administrative efforts.

Regarding the design and description of its security controls, Socket Inc. has categorized them into groups, consolidating all controls within a single document. Lastly, Socket Inc. implemented a new system to maintain, collect, and analyze information about information security threats and integrate information security into project management.

Based on the scenario above, answer the following question:

Which of the following physical controls was NOT included in Socket Inc.'s strategy?

- A. Annex A 7.2 Physical entry
- B. Annex A 7.9 Security of assets off-premises
- C. Annex A 7.11 Supporting utilities

Answer: C

Question: 133

Scenario 3: Socket Inc. is a dynamic telecommunications company specializing in wireless products and services, committed to delivering high-quality and secure communication solutions. Socket Inc. leverages innovative technology, including the MongoDB database, renowned for its high availability, scalability, and flexibility, to provide reliable, accessible, efficient, and well-organized services to its customers. Recently, the company faced a security breach where external hackers exploited the default settings of its MongoDB database due to an oversight in the configuration settings, which had not been properly addressed. Fortunately, diligent data backups and centralized logging through a server ensured no loss of information. In response to this incident, Socket Inc. undertook a thorough evaluation of its security measures. The company recognized the urgent need to improve its information security and decided to implement an information security management system (ISMS) based on ISO/IEC 27001.

To improve its data security and protect its resources, Socket Inc. implemented entry controls and secure access points. These measures were designed to prevent unauthorized access to critical areas housing sensitive data and essential assets. In compliance with relevant laws, regulations, and ethical standards, Socket Inc. implemented pre-employment background checks tailored to business needs, information classification, and associated risks. A formalized disciplinary procedure was also established to address policy violations. Additionally, security measures were implemented for personnel working remotely to safeguard information accessed, processed, or stored outside the organization's premises.

Socket Inc. safeguarded its information processing facilities against power failures and other disruptions. Unauthorized access to critical records from external sources led to the implementation of data flow control services to prevent unauthorized access between departments and external networks. In addition, Socket Inc. used data masking based on the organization's topic-level general policy on access control and other related topic-level general policies and business requirements, considering applicable legislation. It also updated and documented all operating procedures for information processing facilities and ensured that they were accessible to top management exclusively.

The company also implemented a control to define and implement rules for the effective use of cryptography, including cryptographic key management, to protect the database from unauthorized access. The implementation was based on all relevant agreements, legislation, regulations, and the information classification scheme. Network segregation using VPNs was proposed to improve security and reduce administrative efforts.

Regarding the design and description of its security controls, Socket Inc. has categorized them into groups, consolidating all controls within a single document. Lastly, Socket Inc. implemented a new system to maintain, collect, and analyze information about information security threats and integrate information security into project management.

Based on the scenario above, answer the following question:

Which of the following controls did Socket Inc. implement by conducting pre-employment background checks? Refer to scenario 3.

- A. Annex A 6.1 Screening
- B. Annex A 6.7 Remote working

C. Annex A 6.4 Disciplinary process

Answer: A

Question: 134

Scenario 3: Socket Inc. is a dynamic telecommunications company specializing in wireless products and services, committed to delivering high-quality and secure communication solutions. Socket Inc. leverages innovative technology, including the MongoDB database, renowned for its high availability, scalability, and flexibility, to provide reliable, accessible, efficient, and well-organized services to its customers. Recently, the company faced a security breach where external hackers exploited the default settings of its MongoDB database due to an oversight in the configuration settings, which had not been properly addressed. Fortunately, diligent data backups and centralized logging through a server ensured no loss of information. In response to this incident, Socket Inc. undertook a thorough evaluation of its security measures. The company recognized the urgent need to improve its information security and decided to implement an information security management system (ISMS) based on ISO/IEC 27001.

To improve its data security and protect its resources, Socket Inc. implemented entry controls and secure access points. These measures were designed to prevent unauthorized access to critical areas housing sensitive data and essential assets. In compliance with relevant laws, regulations, and ethical standards, Socket Inc. implemented pre-employment background checks tailored to business needs, information classification, and associated risks. A formalized disciplinary procedure was also established to address policy violations. Additionally, security measures were implemented for personnel working remotely to safeguard information accessed, processed, or stored outside the organization's premises.

Socket Inc. safeguarded its information processing facilities against power failures and other disruptions. Unauthorized access to critical records from external sources led to the implementation of data flow control services to prevent unauthorized access between departments and external networks. In addition, Socket Inc. used data masking based on the organization's topic-level general policy on access control and other related topic-level general policies and business requirements, considering applicable legislation. It also updated and documented all operating procedures for information processing facilities and ensured that they were accessible to top management exclusively.

The company also implemented a control to define and implement rules for the effective use of cryptography, including cryptographic key management, to protect the database from unauthorized access. The implementation was based on all relevant agreements, legislation, regulations, and the information classification scheme. Network segregation using VPNs was proposed to improve security and reduce administrative efforts.

Regarding the design and description of its security controls, Socket Inc. has categorized them into groups, consolidating all controls within a single document. Lastly, Socket Inc. implemented a new system to maintain, collect, and analyze information about information security threats and integrate information security into project management.

Based on the scenario above, answer the following question:

Based on scenario 3, did Socket Inc. comply with ISO/IEC 27001 organizational controls regarding its

operating procedures?

- A. Yes, it did comply with ISO/IEC 27001 requirements
- B. No, operating procedures for information processing facilities should have been specifically provided to personnel who require them
- C. No, operating procedures for information processing facilities should have been exclusively available to the Information Technology Department or a similar unit within the company

Answer: A

Question: 135

Scenario 3: Socket Inc. is a dynamic telecommunications company specializing in wireless products and services, committed to delivering high-quality and secure communication solutions. Socket Inc. leverages innovative technology, including the MongoDB database, renowned for its high availability, scalability, and flexibility, to provide reliable, accessible, efficient, and well-organized services to its customers. Recently, the company faced a security breach where external hackers exploited the default settings of its MongoDB database due to an oversight in the configuration settings, which had not been properly addressed. Fortunately, diligent data backups and centralized logging through a server ensured no loss of information. In response to this incident, Socket Inc. undertook a thorough evaluation of its security measures. The company recognized the urgent need to improve its information security and decided to implement an information security management system (ISMS) based on ISO/IEC 27001.

To improve its data security and protect its resources, Socket Inc. implemented entry controls and secure access points. These measures were designed to prevent unauthorized access to critical areas housing sensitive data and essential assets. In compliance with relevant laws, regulations, and ethical standards, Socket Inc. implemented pre-employment background checks tailored to business needs, information classification, and associated risks. A formalized disciplinary procedure was also established to address policy violations. Additionally, security measures were implemented for personnel working remotely to safeguard information accessed, processed, or stored outside the organization's premises.

Socket Inc. safeguarded its information processing facilities against power failures and other disruptions. Unauthorized access to critical records from external sources led to the implementation of data flow control services to prevent unauthorized access between departments and external networks. In addition, Socket Inc. used data masking based on the organization's topic-level general policy on access control and other related topic-level general policies and business requirements, considering applicable legislation. It also updated and documented all operating procedures for information processing facilities and ensured that they were accessible to top management exclusively.

The company also implemented a control to define and implement rules for the effective use of cryptography, including cryptographic key management, to protect the database from unauthorized access. The implementation was based on all relevant agreements, legislation, regulations, and the information classification scheme. Network segregation using VPNs was proposed to improve security and reduce administrative efforts.

Regarding the design and description of its security controls, Socket Inc. has categorized them into

groups, consolidating all controls within a single document. Lastly, Socket Inc. implemented a new system to maintain, collect, and analyze information about information security threats and integrate information security into project management.

Based on the scenario above, answer the following question:

Which security function has Socket Inc. considered when implementing data flow control services to prevent unauthorized access between departments and external networks? Refer to scenario 3.

- A. Access control services
- B. Boundary control services
- C. Integrity services

Answer: B

Question: 136

Scenario 3: Socket Inc. is a dynamic telecommunications company specializing in wireless products and services, committed to delivering high-quality and secure communication solutions. Socket Inc. leverages innovative technology, including the MongoDB database, renowned for its high availability, scalability, and flexibility, to provide reliable, accessible, efficient, and well-organized services to its customers. Recently, the company faced a security breach where external hackers exploited the default settings of its MongoDB database due to an oversight in the configuration settings, which had not been properly addressed. Fortunately, diligent data backups and centralized logging through a server ensured no loss of information. In response to this incident, Socket Inc. undertook a thorough evaluation of its security measures. The company recognized the urgent need to improve its information security and decided to implement an information security management system (ISMS) based on ISO/IEC 27001.

To improve its data security and protect its resources, Socket Inc. implemented entry controls and secure access points. These measures were designed to prevent unauthorized access to critical areas housing sensitive data and essential assets. In compliance with relevant laws, regulations, and ethical standards, Socket Inc. implemented pre-employment background checks tailored to business needs, information classification, and associated risks. A formalized disciplinary procedure was also established to address policy violations. Additionally, security measures were implemented for personnel working remotely to safeguard information accessed, processed, or stored outside the organization's premises.

Socket Inc. safeguarded its information processing facilities against power failures and other disruptions. Unauthorized access to critical records from external sources led to the implementation of data flow control services to prevent unauthorized access between departments and external networks. In addition, Socket Inc. used data masking based on the organization's topic-level general policy on access control and other related topic-level general policies and business requirements, considering applicable legislation. It also updated and documented all operating procedures for information processing facilities and ensured that they were accessible to top management exclusively.

The company also implemented a control to define and implement rules for the effective use of cryptography, including cryptographic key management, to protect the database from unauthorized

access. The implementation was based on all relevant agreements, legislation, regulations, and the information classification scheme. Network segregation using VPNs was proposed to improve security and reduce administrative efforts.

Regarding the design and description of its security controls, Socket Inc. has categorized them into groups, consolidating all controls within a single document. Lastly, Socket Inc. implemented a new system to maintain, collect, and analyze information about information security threats and integrate information security into project management.

Based on the scenario above, answer the following question:

Based on scenario 3, did Socket Inc. adhere to the requirements of ISO/IEC 27001 regarding ISMS documented information?

- A. No, Socket Inc. consolidated all controls of a group into a single document while the standard requires the controls to be documented in four groups
- B. Yes, the standard requires that all security controls be included in a single document
- C. Yes, there is no mandatory requirement on how to document processes or security controls in the standard

Answer: C

Question: 137

An organization that is implementing the ISMS based on ISO/IEC 27001 has defined and communicated secure system architecture and engineering principles. However, there is no documented information related to these principles. Is this acceptable?

- A. Yes, the standard requires organizations to only communicate secure system architecture and engineering principles
- B. Yes, documented information related to secure system architecture and engineering principles is not directly required by the standard
- C. No, documenting secure system architecture and engineering principles is required by the standard

Answer: B

Question: 138

In the SABSA framework, which layer is concerned with viewing the services at a high level?

- A. Physical security architecture
- B. Logical security architecture
- C. Component security architecture

Answer: B

Question: 139

Which of the following represents an example of The Open Security Architecture (TOGAF) framework?

- A. Classifying techniques that ensure the integrity of software
- B. Choosing specific security architecture requirements
- C. Defining components for security architecture

Answer: C

Question: 140

Based on ISO/IEC 27001, what areas within the organization require establishing rules, procedures, and agreements for information transfer?

- A. Internal file-sharing platforms and shared drives
- B. Public and private cloud services and partner collaboration platforms
- C. All transfer facilities within the organization

Answer: C

Question: 141

According to ISO/IEC 27001 controls, when planning audit tests and assurance activities involving operational systems, who should be involved in the agreement process except the tester?

- A. The top management
- B. The appropriate management
- C. The board of directors

Answer: B

Question: 142

Scenario 4: TradeB is a newly established commercial bank located in Europe, with a diverse

clientele. It provides services that encompass retail banking, corporate banking, wealth management, and digital banking, all tailored to meet the evolving financial needs of individuals and businesses in the region. Recognizing the critical importance of information security in the modern banking landscape, TradeB has initiated the implementation of an information security management system (ISMS) based on ISO/IEC 27001. To ensure the successful implementation of the ISMS, the top management decided to contract two experts to lead and oversee the ISMS implementation project. As a primary strategy for implementing the ISMS, the experts chose an approach that emphasizes a swift implementation of the ISMS by initially meeting the minimum requirements of ISO/IEC 27001, followed by continual improvement over time. Additionally, under the guidance of the experts, TradeB opted for a methodological framework, which serves as a structured framework and a guideline that outlines the high-level stages of the ISMS implementation, the associated activities, and the deliverables without incorporating any specific tools.

The experts analyzed the ISO/IEC 27001 controls and listed only the security controls deemed applicable to the company and its objectives. Based on this analysis, they drafted the Statement of Applicability. Afterward, they conducted a risk assessment, during which they identified assets, such as hardware, software, and networks, as well as threats and vulnerabilities, assessed potential consequences and likelihood, and determined the level of risks based on a methodical approach that involved defining and characterizing the terms and criteria used in the assessment process, categorizing them into non-numerical levels (e.g., very low, low, moderate, high, very high). Explanatory notes were thoughtfully crafted to justify assessed values, with the primary goal of enhancing repeatability and reproducibility.

Then, they evaluated the risks based on the risk evaluation criteria, where they decided to treat only the risks of the high-risk category. Additionally, they focused primarily on the unauthorized use of administrator rights and system interruptions due to several hardware failures. To address these issues, they established a new version of the access control policy, implemented controls to manage and control user access, and introduced a control for ICT readiness to ensure business continuity. Their risk assessment report indicated that if the implemented security controls reduce the risk levels to an acceptable threshold, those risks will be accepted.

Based on the scenario above, answer the following question:

Which implementation approach did TradeB initially choose to implement its information security management system (ISMS)?

- A. The systematic approach
- B. The iterative approach
- C. The systems approach

Answer: B

Question: 143

Scenario 4: TradeB is a newly established commercial bank located in Europe, with a diverse clientele. It provides services that encompass retail banking, corporate banking, wealth management, and digital banking, all tailored to meet the evolving financial needs of individuals and businesses in the region. Recognizing the critical importance of information security in the modern banking landscape, TradeB has initiated the implementation of an information security management

system (ISMS) based on ISO/IEC 27001. To ensure the successful implementation of the ISMS, the top management decided to contract two experts to lead and oversee the ISMS implementation project. As a primary strategy for implementing the ISMS, the experts chose an approach that emphasizes a swift implementation of the ISMS by initially meeting the minimum requirements of ISO/IEC 27001, followed by continual improvement over time. Additionally, under the guidance of the experts, TradeB opted for a methodological framework, which serves as a structured framework and a guideline that outlines the high-level stages of the ISMS implementation, the associated activities, and the deliverables without incorporating any specific tools.

The experts analyzed the ISO/IEC 27001 controls and listed only the security controls deemed applicable to the company and its objectives. Based on this analysis, they drafted the Statement of Applicability. Afterward, they conducted a risk assessment, during which they identified assets, such as hardware, software, and networks, as well as threats and vulnerabilities, assessed potential consequences and likelihood, and determined the level of risks based on a methodical approach that involved defining and characterizing the terms and criteria used in the assessment process, categorizing them into non-numerical levels (e.g., very low, low, moderate, high, very high). Explanatory notes were thoughtfully crafted to justify assessed values, with the primary goal of enhancing repeatability and reproducibility.

Then, they evaluated the risks based on the risk evaluation criteria, where they decided to treat only the risks of the high-risk category. Additionally, they focused primarily on the unauthorized use of administrator rights and system interruptions due to several hardware failures. To address these issues, they established a new version of the access control policy, implemented controls to manage and control user access, and introduced a control for ICT readiness to ensure business continuity. Their risk assessment report indicated that if the implemented security controls reduce the risk levels to an acceptable threshold, those risks will be accepted.

Based on the scenario above, answer the following question:

Based on scenario 4, from which source did TradeB's ISMS implementation draw its methodological framework?

- A. ISO/IEC 27003
- B. ISO 10006
- C. COBIT 5

Answer: A

Question: 144

Scenario 4: TradeB is a newly established commercial bank located in Europe, with a diverse clientele. It provides services that encompass retail banking, corporate banking, wealth management, and digital banking, all tailored to meet the evolving financial needs of individuals and businesses in the region. Recognizing the critical importance of information security in the modern banking landscape, TradeB has initiated the implementation of an information security management system (ISMS) based on ISO/IEC 27001. To ensure the successful implementation of the ISMS, the top management decided to contract two experts to lead and oversee the ISMS implementation project. As a primary strategy for implementing the ISMS, the experts chose an approach that emphasizes a

swift implementation of the ISMS by initially meeting the minimum requirements of ISO/IEC 27001, followed by continual improvement over time. Additionally, under the guidance of the experts, TradeB opted for a methodological framework, which serves as a structured framework and a guideline that outlines the high-level stages of the ISMS implementation, the associated activities, and the deliverables without incorporating any specific tools.

The experts analyzed the ISO/IEC 27001 controls and listed only the security controls deemed applicable to the company and its objectives. Based on this analysis, they drafted the Statement of Applicability. Afterward, they conducted a risk assessment, during which they identified assets, such as hardware, software, and networks, as well as threats and vulnerabilities, assessed potential consequences and likelihood, and determined the level of risks based on a methodical approach that involved defining and characterizing the terms and criteria used in the assessment process, categorizing them into non-numerical levels (e.g., very low, low, moderate, high, very high). Explanatory notes were thoughtfully crafted to justify assessed values, with the primary goal of enhancing repeatability and reproducibility.

Then, they evaluated the risks based on the risk evaluation criteria, where they decided to treat only the risks of the high-risk category. Additionally, they focused primarily on the unauthorized use of administrator rights and system interruptions due to several hardware failures. To address these issues, they established a new version of the access control policy, implemented controls to manage and control user access, and introduced a control for ICT readiness to ensure business continuity. Their risk assessment report indicated that if the implemented security controls reduce the risk levels to an acceptable threshold, those risks will be accepted.

Based on the scenario above, answer the following question:

According to scenario 4, what type of assets were identified during the risk assessment?

- A. Supporting assets
- B. Financial assets
- C. Business assets

Answer: A

Question: 145

Scenario 4: TradeB is a newly established commercial bank located in Europe, with a diverse clientele. It provides services that encompass retail banking, corporate banking, wealth management, and digital banking, all tailored to meet the evolving financial needs of individuals and businesses in the region. Recognizing the critical importance of information security in the modern banking landscape, TradeB has initiated the implementation of an information security management system (ISMS) based on ISO/IEC 27001. To ensure the successful implementation of the ISMS, the top management decided to contract two experts to lead and oversee the ISMS implementation project. As a primary strategy for implementing the ISMS, the experts chose an approach that emphasizes a swift implementation of the ISMS by initially meeting the minimum requirements of ISO/IEC 27001, followed by continual improvement over time. Additionally, under the guidance of the experts, TradeB opted for a methodological framework, which serves as a structured framework and a guideline that outlines the high-level stages of the ISMS implementation, the associated activities,

and the deliverables without incorporating any specific tools.

The experts analyzed the ISO/IEC 27001 controls and listed only the security controls deemed applicable to the company and its objectives. Based on this analysis, they drafted the Statement of Applicability. Afterward, they conducted a risk assessment, during which they identified assets, such as hardware, software, and networks, as well as threats and vulnerabilities, assessed potential consequences and likelihood, and determined the level of risks based on a methodical approach that involved defining and characterizing the terms and criteria used in the assessment process, categorizing them into non-numerical levels (e.g., very low, low, moderate, high, very high). Explanatory notes were thoughtfully crafted to justify assessed values, with the primary goal of enhancing repeatability and reproducibility.

Then, they evaluated the risks based on the risk evaluation criteria, where they decided to treat only the risks of the high-risk category. Additionally, they focused primarily on the unauthorized use of administrator rights and system interruptions due to several hardware failures. To address these issues, they established a new version of the access control policy, implemented controls to manage and control user access, and introduced a control for ICT readiness to ensure business continuity. Their risk assessment report indicated that if the implemented security controls reduce the risk levels to an acceptable threshold, those risks will be accepted.

Based on the scenario above, answer the following question:

Which of the actions presented in scenario 4 is NOT compliant with the requirements of ISO/IEC 27001?

- A. TradeB selected only ISO/IEC 27001 controls deemed applicable to the company
- B. TradeB drafted the Statement of Applicability before conducting the risk assessment
- C. TradeB decided to treat only the risks of the high-risk category

Answer: B

Question: 146

Scenario 4: TradeB is a newly established commercial bank located in Europe, with a diverse clientele. It provides services that encompass retail banking, corporate banking, wealth management, and digital banking, all tailored to meet the evolving financial needs of individuals and businesses in the region. Recognizing the critical importance of information security in the modern banking landscape, TradeB has initiated the implementation of an information security management system (ISMS) based on ISO/IEC 27001. To ensure the successful implementation of the ISMS, the top management decided to contract two experts to lead and oversee the ISMS implementation project. As a primary strategy for implementing the ISMS, the experts chose an approach that emphasizes a swift implementation of the ISMS by initially meeting the minimum requirements of ISO/IEC 27001, followed by continual improvement over time. Additionally, under the guidance of the experts, TradeB opted for a methodological framework, which serves as a structured framework and a guideline that outlines the high-level stages of the ISMS implementation, the associated activities, and the deliverables without incorporating any specific tools.

The experts analyzed the ISO/IEC 27001 controls and listed only the security controls deemed applicable to the company and its objectives. Based on this analysis, they drafted the Statement of

Applicability. Afterward, they conducted a risk assessment, during which they identified assets, such as hardware, software, and networks, as well as threats and vulnerabilities, assessed potential consequences and likelihood, and determined the level of risks based on a methodical approach that involved defining and characterizing the terms and criteria used in the assessment process, categorizing them into non-numerical levels (e.g., very low, low, moderate, high, very high). Explanatory notes were thoughtfully crafted to justify assessed values, with the primary goal of enhancing repeatability and reproducibility.

Then, they evaluated the risks based on the risk evaluation criteria, where they decided to treat only the risks of the high-risk category. Additionally, they focused primarily on the unauthorized use of administrator rights and system interruptions due to several hardware failures. To address these issues, they established a new version of the access control policy, implemented controls to manage and control user access, and introduced a control for ICT readiness to ensure business continuity. Their risk assessment report indicated that if the implemented security controls reduce the risk levels to an acceptable threshold, those risks will be accepted.

Based on the scenario above, answer the following question:

Which risk analysis technique did the experts use to determine the level of risk? Refer to scenario 4.

- A. Qualitative risk analysis
- B. Semi-quantitative analysis
- C. Quantitative risk analysis

Answer: A

Question: 147

Scenario 5: OperazellT is a software development company that develops applications for various companies worldwide. Recently, the company conducted a risk assessment in response to the evolving digital landscape and emerging information security challenges. Through rigorous testing techniques like penetration testing and code review, the company identified issues in its IT systems, including improper user permissions, misconfigured security settings, and insecure network configurations. To resolve these issues and enhance information security, OperazellT implemented an information security management system (ISMS) based on ISO/IEC 27001.

In a collaborative effort involving the implementation team, OperazellT thoroughly assessed its business requirements and internal and external environment, identified its key processes and activities, and identified and analyzed the interested parties to establish the preliminary scope of the ISMS. Following this, the implementation team conducted a comprehensive review of the company's functional units, opting to include most of the company departments within the ISMS scope.

Additionally, the team decided to include internal and external physical locations, both external and internal issues referred to in clause 4.1, the requirements in clause 4.2, and the interfaces and dependencies between activities performed by the company. The IT manager had a pivotal role in approving the final scope, reflecting OperazellT's commitment to information security.

OperazellT's information security team created a comprehensive information security policy that aligned with the company's strategic direction and legal requirements, informed by risk assessment findings and business strategies. This policy, alongside specific policies detailing security issues and

assigning roles and responsibilities, was communicated internally and shared with external parties. The drafting, review, and approval of these policies involved active participation from top management, ensuring a robust framework for safeguarding information across all interested parties.

As OperazeIT moved forward, the company entered the policy implementation phase, with a detailed plan encompassing security definition, role assignments, and training sessions. Lastly, the policy monitoring and maintenance phase was conducted, where monitoring mechanisms were established to ensure the company's information security policy is enforced and all employees comply with its requirements.

To further strengthen its information security framework, OperazeIT initiated a comprehensive gap analysis as part of the ISMS implementation process. Rather than relying solely on internal assessments, OperazeIT decided to involve the services of external consultants to assess the state of its ISMS. The company collaborated with external consultants, which brought a fresh perspective and valuable insights to the gap analysis process, enabling OperazeIT to identify vulnerabilities and areas for improvement with a higher degree of objectivity. Lastly, OperazeIT created a committee whose mission includes ensuring the proper operation of the ISMS, overseeing the company's risk assessment process, managing information security-related issues, recommending solutions to nonconformities, and monitoring the implementation of corrections and corrective actions.

Based on the scenario above, answer the following question:

Which phase of information security policy development at OperazeIT did NOT encompass all the necessary components?

- A. Risk assessment
- B. Policy construction
- C. Policy implementation

Answer: B

Question: 148

Scenario 5: OperazeIT is a software development company that develops applications for various companies worldwide. Recently, the company conducted a risk assessment in response to the evolving digital landscape and emerging information security challenges. Through rigorous testing techniques like penetration testing and code review, the company identified issues in its IT systems, including improper user permissions, misconfigured security settings, and insecure network configurations. To resolve these issues and enhance information security, OperazeIT implemented an information security management system (ISMS) based on ISO/IEC 27001.

In a collaborative effort involving the implementation team, OperazeIT thoroughly assessed its business requirements and internal and external environment, identified its key processes and activities, and identified and analyzed the interested parties to establish the preliminary scope of the ISMS. Following this, the implementation team conducted a comprehensive review of the company's functional units, opting to include most of the company departments within the ISMS scope. Additionally, the team decided to include internal and external physical locations, both external and internal issues referred to in clause 4.1, the requirements in clause 4.2, and the interfaces and

dependencies between activities performed by the company. The IT manager had a pivotal role in approving the final scope, reflecting OperazellT's commitment to information security.

OperazellT's information security team created a comprehensive information security policy that aligned with the company's strategic direction and legal requirements, informed by risk assessment findings and business strategies. This policy, alongside specific policies detailing security issues and assigning roles and responsibilities, was communicated internally and shared with external parties. The drafting, review, and approval of these policies involved active participation from top management, ensuring a robust framework for safeguarding information across all interested parties.

As OperazellT moved forward, the company entered the policy implementation phase, with a detailed plan encompassing security definition, role assignments, and training sessions. Lastly, the policy monitoring and maintenance phase was conducted, where monitoring mechanisms were established to ensure the company's information security policy is enforced and all employees comply with its requirements.

To further strengthen its information security framework, OperazellT initiated a comprehensive gap analysis as part of the ISMS implementation process. Rather than relying solely on internal assessments, OperazellT decided to involve the services of external consultants to assess the state of its ISMS. The company collaborated with external consultants, which brought a fresh perspective and valuable insights to the gap analysis process, enabling OperazellT to identify vulnerabilities and areas for improvement with a higher degree of objectivity. Lastly, OperazellT created a committee whose mission includes ensuring the proper operation of the ISMS, overseeing the company's risk assessment process, managing information security-related issues, recommending solutions to nonconformities, and monitoring the implementation of corrections and corrective actions.

Based on the scenario above, answer the following question:

Which ISMS boundaries did OperazellT include in its ISMS scope?

- A. Solely information system boundaries
- B. Physical boundaries only
- C. Organizational and physical boundaries

Answer: C

Question: 149

Scenario 5: OperazellT is a software development company that develops applications for various companies worldwide. Recently, the company conducted a risk assessment in response to the evolving digital landscape and emerging information security challenges. Through rigorous testing techniques like penetration testing and code review, the company identified issues in its IT systems, including improper user permissions, misconfigured security settings, and insecure network configurations. To resolve these issues and enhance information security, OperazellT implemented an information security management system (ISMS) based on ISO/IEC 27001.

In a collaborative effort involving the implementation team, OperazellT thoroughly assessed its business requirements and internal and external environment, identified its key processes and activities, and identified and analyzed the interested parties to establish the preliminary scope of the

ISMS. Following this, the implementation team conducted a comprehensive review of the company's functional units, opting to include most of the company departments within the ISMS scope. Additionally, the team decided to include internal and external physical locations, both external and internal issues referred to in clause 4.1, the requirements in clause 4.2, and the interfaces and dependencies between activities performed by the company. The IT manager had a pivotal role in approving the final scope, reflecting OperazellT's commitment to information security. OperazellT's information security team created a comprehensive information security policy that aligned with the company's strategic direction and legal requirements, informed by risk assessment findings and business strategies. This policy, alongside specific policies detailing security issues and assigning roles and responsibilities, was communicated internally and shared with external parties. The drafting, review, and approval of these policies involved active participation from top management, ensuring a robust framework for safeguarding information across all interested parties.

As OperazellT moved forward, the company entered the policy implementation phase, with a detailed plan encompassing security definition, role assignments, and training sessions. Lastly, the policy monitoring and maintenance phase was conducted, where monitoring mechanisms were established to ensure the company's information security policy is enforced and all employees comply with its requirements.

To further strengthen its information security framework, OperazellT initiated a comprehensive gap analysis as part of the ISMS implementation process. Rather than relying solely on internal assessments, OperazellT decided to involve the services of external consultants to assess the state of its ISMS. The company collaborated with external consultants, which brought a fresh perspective and valuable insights to the gap analysis process, enabling OperazellT to identify vulnerabilities and areas for improvement with a higher degree of objectivity. Lastly, OperazellT created a committee whose mission includes ensuring the proper operation of the ISMS, overseeing the company's risk assessment process, managing information security-related issues, recommending solutions to nonconformities, and monitoring the implementation of corrections and corrective actions.

Based on the scenario above, answer the following question:

Did OperazellT include all the necessary factors when determining its scope?

- A. Yes, the company adhered to the requirements of ISO/IEC 27001
- B. No, it should have included the interfaces and dependencies between activities performed by other organizations as well
- C. No, it should have only considered external issues referred to in 4.1 and the requirements referred to in 4.2

Answer: A

Question: 150

Scenario 5: OperazellT is a software development company that develops applications for various companies worldwide. Recently, the company conducted a risk assessment in response to the evolving digital landscape and emerging information security challenges. Through rigorous testing techniques like penetration testing and code review, the company identified issues in its IT systems,

including improper user permissions, misconfigured security settings, and insecure network configurations. To resolve these issues and enhance information security, Operazelt implemented an information security management system (ISMS) based on ISO/IEC 27001.

In a collaborative effort involving the implementation team, Operazelt thoroughly assessed its business requirements and internal and external environment, identified its key processes and activities, and identified and analyzed the interested parties to establish the preliminary scope of the ISMS. Following this, the implementation team conducted a comprehensive review of the company's functional units, opting to include most of the company departments within the ISMS scope.

Additionally, the team decided to include internal and external physical locations, both external and internal issues referred to in clause 4.1, the requirements in clause 4.2, and the interfaces and dependencies between activities performed by the company. The IT manager had a pivotal role in approving the final scope, reflecting Operazelt's commitment to information security.

Operazelt's information security team created a comprehensive information security policy that aligned with the company's strategic direction and legal requirements, informed by risk assessment findings and business strategies. This policy, alongside specific policies detailing security issues and assigning roles and responsibilities, was communicated internally and shared with external parties. The drafting, review, and approval of these policies involved active participation from top management, ensuring a robust framework for safeguarding information across all interested parties.

As Operazelt moved forward, the company entered the policy implementation phase, with a detailed plan encompassing security definition, role assignments, and training sessions. Lastly, the policy monitoring and maintenance phase was conducted, where monitoring mechanisms were established to ensure the company's information security policy is enforced and all employees comply with its requirements.

To further strengthen its information security framework, Operazelt initiated a comprehensive gap analysis as part of the ISMS implementation process. Rather than relying solely on internal assessments, Operazelt decided to involve the services of external consultants to assess the state of its ISMS. The company collaborated with external consultants, which brought a fresh perspective and valuable insights to the gap analysis process, enabling Operazelt to identify vulnerabilities and areas for improvement with a higher degree of objectivity. Lastly, Operazelt created a committee whose mission includes ensuring the proper operation of the ISMS, overseeing the company's risk assessment process, managing information security-related issues, recommending solutions to nonconformities, and monitoring the implementation of corrections and corrective actions.

Based on the scenario above, answer the following question:

Was there any issue with how Operazelt determined its current ISMS state?

- A. Yes, as the ISMS state must be determined by the implementation team
- B. Yes, as it is the top management's responsibility to determine the ISMS state
- C. No, as the ISMS state can be determined by outsourced external consultants

Answer: C

Question: 151

Scenario 5: Operazelt is a software development company that develops applications for various companies worldwide. Recently, the company conducted a risk assessment in response to the evolving digital landscape and emerging information security challenges. Through rigorous testing techniques like penetration testing and code review, the company identified issues in its IT systems, including improper user permissions, misconfigured security settings, and insecure network configurations. To resolve these issues and enhance information security, Operazelt implemented an information security management system (ISMS) based on ISO/IEC 27001.

In a collaborative effort involving the implementation team, Operazelt thoroughly assessed its business requirements and internal and external environment, identified its key processes and activities, and identified and analyzed the interested parties to establish the preliminary scope of the ISMS. Following this, the implementation team conducted a comprehensive review of the company's functional units, opting to include most of the company departments within the ISMS scope.

Additionally, the team decided to include internal and external physical locations, both external and internal issues referred to in clause 4.1, the requirements in clause 4.2, and the interfaces and dependencies between activities performed by the company. The IT manager had a pivotal role in approving the final scope, reflecting Operazelt's commitment to information security.

Operazelt's information security team created a comprehensive information security policy that aligned with the company's strategic direction and legal requirements, informed by risk assessment findings and business strategies. This policy, alongside specific policies detailing security issues and assigning roles and responsibilities, was communicated internally and shared with external parties. The drafting, review, and approval of these policies involved active participation from top management, ensuring a robust framework for safeguarding information across all interested parties.

As Operazelt moved forward, the company entered the policy implementation phase, with a detailed plan encompassing security definition, role assignments, and training sessions. Lastly, the policy monitoring and maintenance phase was conducted, where monitoring mechanisms were established to ensure the company's information security policy is enforced and all employees comply with its requirements.

To further strengthen its information security framework, Operazelt initiated a comprehensive gap analysis as part of the ISMS implementation process. Rather than relying solely on internal assessments, Operazelt decided to involve the services of external consultants to assess the state of its ISMS. The company collaborated with external consultants, which brought a fresh perspective and valuable insights to the gap analysis process, enabling Operazelt to identify vulnerabilities and areas for improvement with a higher degree of objectivity. Lastly, Operazelt created a committee whose mission includes ensuring the proper operation of the ISMS, overseeing the company's risk assessment process, managing information security-related issues, recommending solutions to nonconformities, and monitoring the implementation of corrections and corrective actions.

Based on the scenario above, answer the following question:

What committee did Operazelt establish to guarantee the proper operation of the ISMS?

- A. Information security committee
- B. Management committee
- C. Operational committee

Answer: A

Question: 152

Who is responsible for ensuring that the information security management system (ISMS) achieves its intended outcome(s)?

- A. The organization's IT department
- B. The top management of the organization
- C. The ISMS project manager

Answer: B

Question: 153

Which of the following statements is accurate regarding the methodology for managing the implementation of an ISMS?

- A. Organizations must strictly follow a specific methodology to meet the minimum requirements
- B. The sequence of steps must remain fixed throughout the ISMS implementation
- C. Organizations can adapt the methodology to their specific context, and steps can be modified as needed

Answer: C

Question: 154

Scenario 6: Skyver manufactures electronic products, such as gaming consoles, flat-screen TVs, computers, and printers. In order to ensure information security, the company has decided to implement an information security management system (ISMS) based on ISO/IEC 27001. Colin, the company's information security manager, decided to conduct a training and awareness session for the company's staff about the information security risks and the controls implemented to mitigate them. The session covered various topics, including Skyver's information security approaches, techniques for mitigating phishing and malware, and a dedicated segment on securing cloud infrastructure and services. This particular segment explored the shared responsibility model and concepts such as identity and access management in the cloud. Colin organized the training and awareness sessions through engaging presentations, interactive discussions, and practical demonstrations to ensure that the personnel were well-informed by security principles and practices.

One of the participants in the session was Lisa, who works in the HR Department. Although Colin explained Skyver's information security policies and procedures in an honest and fair manner, she found some of the issues being discussed too technical and did not fully understand the session. Therefore, in many cases, she would request additional help from the trainer and her colleagues. In a

supportive manner, Colin suggested Lisa consider attending the session again.

Skyver has been exploring the implementation of AI solutions to help understand customer preferences and provide personalized recommendations for electronic products. The aim was to utilize AI technologies to enhance problem-solving capabilities and provide suggestions to customers. This strategic initiative aligned with Skyver's commitment to improving the customer experience through data-driven insights.

Additionally, Skyver looked for a flexible cloud infrastructure that allows the company to host certain services on internal and secure infrastructure and other services on external and scalable platforms that can be accessed from anywhere. This setup would enable various deployment options and enhance information security, crucial for Skyver's electronic product development.

According to Skyver, implementing additional controls in the ISMS implementation plan has been successfully executed, and the company was ready to transition into operational mode. Skyver assigned Colin the responsibility of determining the materiality of this change within the company. Based on the scenario above, answer the following question:

As part of its strategic initiative to improve customer experiences, Skyver is exploring the implementation of advanced AI solutions. Which type of AI is the company likely considering for this purpose?

- A. Weak AI
- B. Machine learning
- C. Strong AI

Answer: B

Question: 155

Scenario 6: Skyver manufactures electronic products, such as gaming consoles, flat-screen TVs, computers, and printers. In order to ensure information security, the company has decided to implement an information security management system (ISMS) based on ISO/IEC 27001.

Colin, the company's information security manager, decided to conduct a training and awareness session for the company's staff about the information security risks and the controls implemented to mitigate them. The session covered various topics, including Skyver's information security approaches, techniques for mitigating phishing and malware, and a dedicated segment on securing cloud infrastructure and services. This particular segment explored the shared responsibility model and concepts such as identity and access management in the cloud. Colin organized the training and awareness sessions through engaging presentations, interactive discussions, and practical demonstrations to ensure that the personnel were well-informed by security principles and practices.

One of the participants in the session was Lisa, who works in the HR Department. Although Colin explained Skyver's information security policies and procedures in an honest and fair manner, she found some of the issues being discussed too technical and did not fully understand the session. Therefore, in many cases, she would request additional help from the trainer and her colleagues. In a supportive manner, Colin suggested Lisa consider attending the session again. Skyver has been exploring the implementation of AI solutions to help understand customer

preferences and provide personalized recommendations for electronic products. The aim was to utilize AI technologies to enhance problem-solving capabilities and provide suggestions to customers. This strategic initiative aligned with Skyver's commitment to improving the customer experience through data-driven insights.

Additionally, Skyver looked for a flexible cloud infrastructure that allows the company to host certain services on internal and secure infrastructure and other services on external and scalable platforms that can be accessed from anywhere. This setup would enable various deployment options and enhance information security, crucial for Skyver's electronic product development.

According to Skyver, implementing additional controls in the ISMS implementation plan has been successfully executed, and the company was ready to transition into operational mode. Skyver assigned Colin the responsibility of determining the materiality of this change within the company. Based on the scenario above, answer the following question:

Which cloud computing model best aligns with Skyver's requirements?

- A. Public cloud
- B. Private cloud
- C. Hybrid cloud

Answer: C

Question: 156

Scenario 6: Skyver manufactures electronic products, such as gaming consoles, flat-screen TVs, computers, and printers. In order to ensure information security, the company has decided to implement an information security management system (ISMS) based on ISO/IEC 27001.

Colin, the company's information security manager, decided to conduct a training and awareness session for the company's staff about the information security risks and the controls implemented to mitigate them. The session covered various topics, including Skyver's information security approaches, techniques for mitigating phishing and malware, and a dedicated segment on securing cloud infrastructure and services. This particular segment explored the shared responsibility model and concepts such as identity and access management in the cloud. Colin organized the training and awareness sessions through engaging presentations, interactive discussions, and practical demonstrations to ensure that the personnel were well-informed by security principles and practices.

One of the participants in the session was Lisa, who works in the HR Department. Although Colin explained Skyver's information security policies and procedures in an honest and fair manner, she found some of the issues being discussed too technical and did not fully understand the session. Therefore, in many cases, she would request additional help from the trainer and her colleagues. In a supportive manner, Colin suggested Lisa consider attending the session again.

Skyver has been exploring the implementation of AI solutions to help understand customer preferences and provide personalized recommendations for electronic products. The aim was to utilize AI technologies to enhance problem-solving capabilities and provide suggestions to customers. This strategic initiative aligned with Skyver's commitment to improving the customer experience through data-driven insights.

Additionally, Skyver looked for a flexible cloud infrastructure that allows the company to host certain services on internal and secure infrastructure and other services on external and scalable platforms that can be accessed from anywhere. This setup would enable various deployment options and enhance information security, crucial for Skyver's electronic product development.

According to Skyver, implementing additional controls in the ISMS implementation plan has been successfully executed, and the company was ready to transition into operational mode. Skyver assigned Colin the responsibility of determining the materiality of this change within the company. Based on the scenario above, answer the following question:

Did Skyver assign the adequate person for determining the materiality of the transition into operational mode of the ISMS?

- A. Yes, the materiality of this change should be decided by the information security manager
- B. No, the top management should be responsible for this decision
- C. No, the ISMS implementation team should be responsible for this decision

Answer: A

Question: 157

Scenario 7: InfoSec, based in Boston, MA, is a multinational corporation offering professional electronics, gaming, and entertainment products. Following several information security incidents, InfoSec has decided to establish teams of experts and implement measures to prevent potential incidents in the future.

Emma, Bob, and Anna were hired as the new members of InfoSec's information security team, which consists of a security architecture team, an incident response team (IRT), and a forensics team. Emma's job is to create information security plans, policies, protocols, and training to prepare InfoSec to respond to incidents effectively. Emma and Bob would be full-time employees of InfoSec, whereas Anna was contracted as an external consultant.

Bob, a network expert, will implement a screened subnet network architecture. This architecture will isolate the demilitarized zone (DMZ), to which hosted public services are attached, and InfoSec's publicly accessible resources from their private network. Thus, InfoSec will be able to block potential attackers from causing unwanted events inside the company's network. Bob is also responsible for ensuring a thorough evaluation of the nature of an unexpected event, including how the event happened and what or whom it might affect.

On the other hand, Anna will create records of the data, reviews, analyses, and reports to keep evidence for disciplinary and legal action and use them to prevent future incidents. To do the work accordingly, she should be aware of the company's information security incident management policy beforehand. Among others, this policy specifies the type of records to be created, the place where they should be kept, and the format and content that specific record types should have.

As part of InfoSec's initiative to strengthen information security measures, Anna will conduct information security risk assessments only when significant changes are proposed and will document the results of these risk assessments. Upon completion of the risk assessment process, Anna is responsible for developing and implementing a plan for treating information security risks and documenting the risk treatment results.

Furthermore, while implementing the communication plan for information security, InfoSec's top management was responsible for creating a roadmap for new product development. This approach helps the company to align its security measures with the product development efforts, demonstrating a commitment to integrating security into every aspect of its business operations. InfoSec uses a cloud service model that includes cloud-based apps accessed through the web or an application programming interface (API). All cloud services are provided by the cloud service provider, while data is managed by InfoSec. This introduces unique security considerations and becomes a primary focus for the information security team to ensure data and systems are protected in this environment.

Based on this scenario, answer the following question:

Which of the following cloud service models did InfoSec use?

- A. Infrastructure as a Service
- B. Platform as a Service
- C. Software as a Service

Answer: C

Question: 158

Scenario 7: InfoSec, based in Boston, MA, is a multinational corporation offering professional electronics, gaming, and entertainment products. Following several information security incidents, InfoSec has decided to establish teams of experts and implement measures to prevent potential incidents in the future.

Emma, Bob, and Anna were hired as the new members of InfoSec's information security team, which consists of a security architecture team, an incident response team (IRT), and a forensics team. Emma's job is to create information security plans, policies, protocols, and training to prepare InfoSec to respond to incidents effectively. Emma and Bob would be full-time employees of InfoSec, whereas Anna was contracted as an external consultant.

Bob, a network expert, will implement a screened subnet network architecture. This architecture will isolate the demilitarized zone (DMZ), to which hosted public services are attached, and InfoSec's publicly accessible resources from their private network. Thus, InfoSec will be able to block potential attackers from causing unwanted events inside the company's network. Bob is also responsible for ensuring a thorough evaluation of the nature of an unexpected event, including how the event happened and what or whom it might affect.

On the other hand, Anna will create records of the data, reviews, analyses, and reports to keep evidence for disciplinary and legal action and use them to prevent future incidents. To do the work accordingly, she should be aware of the company's information security incident management policy beforehand. Among others, this policy specifies the type of records to be created, the place where they should be kept, and the format and content that specific record types should have.

As part of InfoSec's initiative to strengthen information security measures, Anna will conduct information security risk assessments only when significant changes are proposed and will document the results of these risk assessments. Upon completion of the risk assessment process, Anna is responsible for developing and implementing a plan for treating information security risks and

documenting the risk treatment results.

Furthermore, while implementing the communication plan for information security, InfoSec's top management was responsible for creating a roadmap for new product development. This approach helps the company to align its security measures with the product development efforts, demonstrating a commitment to integrating security into every aspect of its business operations. InfoSec uses a cloud service model that includes cloud-based apps accessed through the web or an application programming interface (API). All cloud services are provided by the cloud service provider, while data is managed by InfoSec. This introduces unique security considerations and becomes a primary focus for the information security team to ensure data and systems are protected in this environment.

Based on this scenario, answer the following question:

Does InfoSec adhere to the requirements of ISO/IEC 27001 when conducting information security risk assessments?

- A. Yes, it adhered to ISO/IEC 27001 requirements
- B. No, as it should perform them at planned intervals as well
- C. No, as it should perform them twice a year, regardless of significant changes

Answer: B

Question: 159

Scenario 7: InfoSec, based in Boston, MA, is a multinational corporation offering professional electronics, gaming, and entertainment products. Following several information security incidents, InfoSec has decided to establish teams of experts and implement measures to prevent potential incidents in the future.

Emma, Bob, and Anna were hired as the new members of InfoSec's information security team, which consists of a security architecture team, an incident response team (IRT), and a forensics team. Emma's job is to create information security plans, policies, protocols, and training to prepare InfoSec to respond to incidents effectively. Emma and Bob would be full-time employees of InfoSec, whereas Anna was contracted as an external consultant.

Bob, a network expert, will implement a screened subnet network architecture. This architecture will isolate the demilitarized zone (DMZ), to which hosted public services are attached, and InfoSec's publicly accessible resources from their private network. Thus, InfoSec will be able to block potential attackers from causing unwanted events inside the company's network. Bob is also responsible for ensuring a thorough evaluation of the nature of an unexpected event, including how the event happened and what or whom it might affect.

On the other hand, Anna will create records of the data, reviews, analyses, and reports to keep evidence for disciplinary and legal action and use them to prevent future incidents. To do the work accordingly, she should be aware of the company's information security incident management policy beforehand. Among others, this policy specifies the type of records to be created, the place where they should be kept, and the format and content that specific record types should have.

As part of InfoSec's initiative to strengthen information security measures, Anna will conduct information security risk assessments only when significant changes are proposed and will document

the results of these risk assessments. Upon completion of the risk assessment process, Anna is responsible for developing and implementing a plan for treating information security risks and documenting the risk treatment results.

Furthermore, while implementing the communication plan for information security, InfoSec's top management was responsible for creating a roadmap for new product development. This approach helps the company to align its security measures with the product development efforts, demonstrating a commitment to integrating security into every aspect of its business operations. InfoSec uses a cloud service model that includes cloud-based apps accessed through the web or an application programming interface (API). All cloud services are provided by the cloud service provider, while data is managed by InfoSec. This introduces unique security considerations and becomes a primary focus for the information security team to ensure data and systems are protected in this environment.

Based on this scenario, answer the following question:

Is the responsibility of InfoSec's top management appropriately established in implementing the communication plan for information security?

- A. No, the top management is responsible for allocating resources for communication activities
- B. Yes, the top management is responsible for creating a new product development roadmap as an activity during the communication plan implementation
- C. No, the top management is responsible for communicating only technical specifications for products

Answer: B

Question: 160

Scenario 7: InfoSec, based in Boston, MA, is a multinational corporation offering professional electronics, gaming, and entertainment products. Following several information security incidents, InfoSec has decided to establish teams of experts and implement measures to prevent potential incidents in the future.

Emma, Bob, and Anna were hired as the new members of InfoSec's information security team, which consists of a security architecture team, an incident response team (IRT), and a forensics team. Emma's job is to create information security plans, policies, protocols, and training to prepare InfoSec to respond to incidents effectively. Emma and Bob would be full-time employees of InfoSec, whereas Anna was contracted as an external consultant.

Bob, a network expert, will implement a screened subnet network architecture. This architecture will isolate the demilitarized zone (DMZ), to which hosted public services are attached, and InfoSec's publicly accessible resources from their private network. Thus, InfoSec will be able to block potential attackers from causing unwanted events inside the company's network. Bob is also responsible for ensuring a thorough evaluation of the nature of an unexpected event, including how the event happened and what or whom it might affect.

On the other hand, Anna will create records of the data, reviews, analyses, and reports to keep evidence for disciplinary and legal action and use them to prevent future incidents. To do the work accordingly, she should be aware of the company's information security incident management policy

beforehand. Among others, this policy specifies the type of records to be created, the place where they should be kept, and the format and content that specific record types should have.

As part of InfoSec's initiative to strengthen information security measures, Anna will conduct information security risk assessments only when significant changes are proposed and will document the results of these risk assessments. Upon completion of the risk assessment process, Anna is responsible for developing and implementing a plan for treating information security risks and documenting the risk treatment results.

Furthermore, while implementing the communication plan for information security, InfoSec's top management was responsible for creating a roadmap for new product development. This approach helps the company to align its security measures with the product development efforts, demonstrating a commitment to integrating security into every aspect of its business operations. InfoSec uses a cloud service model that includes cloud-based apps accessed through the web or an application programming interface (API). All cloud services are provided by the cloud service provider, while data is managed by InfoSec. This introduces unique security considerations and becomes a primary focus for the information security team to ensure data and systems are protected in this environment.

Based on this scenario, answer the following question:

Does InfoSec comply with ISO/IEC 27001 requirements regarding the information security risk treatment plan?

- A. Yes, it complies with ISO/IEC 27001 requirements by implementing a risk treatment plan and documenting risk treatment results
- B. No, it should only retain documented information for risk assessment results
- C. No, the information security risk treatment plan should be developed only by the top management

Answer: A

Question: 161

What does the organization still need to manage when using Platform as a Service (PaaS)?

- A. Operating system and virtualization
- B. Servers and storage
- C. Application and data

Answer: C

Question: 162

The Incident Response Team (IRT) has been notified of a potential compromise in the organization's network. Which type of services would be most appropriate for the IRT to provide in this situation?

- A. Proactive services
- B. Reactive services
- C. Security quality management services

Answer: B

Question: 163

Scenario 8: SunDee is a biopharmaceutical firm headquartered in California, US. Renowned for its pioneering work in the field of human therapeutics, SunDee places a strong emphasis on addressing critical healthcare concerns, particularly in the domains of cardiovascular diseases, oncology, bone health, and inflammation. SunDee has demonstrated its commitment to data security and integrity by maintaining an effective information security management system (ISMS) based on ISO/IEC 27001 for the past two years.

In preparation for the recertification audit, SunDee conducted an internal audit. The company's top management appointed Alex, who has actively managed the Compliance Department's day-to-day operations for the last six months, as the internal auditor. With this dual role assignment, Alex is tasked with conducting an audit that ensures compliance and provides valuable recommendations to improve operational efficiency.

During the internal audit, a few nonconformities were identified. To address them comprehensively, the company created action plans for each nonconformity, working closely with the audit team leader.

SunDee's senior management conducted a comprehensive review of the ISMS to evaluate its appropriateness, sufficiency, and efficiency. This was integrated into their regular management meetings. Essential documents, including audit reports, action plans, and review outcomes, were distributed to all members before the meeting. The agenda covered the status of previous review actions, changes affecting the ISMS, feedback, stakeholder inputs, and opportunities for improvement. Decisions and actions targeting ISMS improvements were made, with a significant role played by the ISMS coordinator and the internal audit team in preparing follow-up action plans, which were then approved by top management.

In response to the review outcomes, SunDee promptly implemented corrective actions, strengthening its information security measures. Additionally, dashboard tools were introduced to provide a high-level overview of key performance indicators essential for monitoring the organization's information security management. These indicators included metrics on security incidents, their costs, system vulnerability tests, nonconformity detection, and resolution times, facilitating effective recording, reporting, and tracking of monitoring activities. Furthermore, SunDee embarked on a comprehensive measurement process to assess the progress and outcomes of ongoing projects, implementing extensive measures across all processes. The top management determined that the individual responsible for the information, aside from owning the data that contributes to the measures, would also be designated accountable for executing these measurement activities.

Based on the scenario above, answer the following question:

Is Alex suitable for the position of internal auditor within the company?

- A. Yes, Alex's recent experience in the day-to-day operations of the Compliance Department would benefit the internal auditor role
- B. No, Alex should wait for a reasonable period of time to pass before transitioning to the internal auditor position
- C. No, the internal audit can be conducted only by individuals who have not had operational roles

Answer: C

Question: 164

Scenario 8: SunDee is a biopharmaceutical firm headquartered in California, US. Renowned for its pioneering work in the field of human therapeutics, SunDee places a strong emphasis on addressing critical healthcare concerns, particularly in the domains of cardiovascular diseases, oncology, bone health, and inflammation. SunDee has demonstrated its commitment to data security and integrity by maintaining an effective information security management system (ISMS) based on ISO/IEC 27001 for the past two years.

In preparation for the recertification audit, SunDee conducted an internal audit. The company's top management appointed Alex, who has actively managed the Compliance Department's day-to-day operations for the last six months, as the internal auditor. With this dual role assignment, Alex is tasked with conducting an audit that ensures compliance and provides valuable recommendations to improve operational efficiency.

During the internal audit, a few nonconformities were identified. To address them comprehensively, the company created action plans for each nonconformity, working closely with the audit team leader.

SunDee's senior management conducted a comprehensive review of the ISMS to evaluate its appropriateness, sufficiency, and efficiency. This was integrated into their regular management meetings. Essential documents, including audit reports, action plans, and review outcomes, were distributed to all members before the meeting. The agenda covered the status of previous review actions, changes affecting the ISMS, feedback, stakeholder inputs, and opportunities for improvement. Decisions and actions targeting ISMS improvements were made, with a significant role played by the ISMS coordinator and the internal audit team in preparing follow-up action plans, which were then approved by top management.

In response to the review outcomes, SunDee promptly implemented corrective actions, strengthening its information security measures. Additionally, dashboard tools were introduced to provide a high-level overview of key performance indicators essential for monitoring the organization's information security management. These indicators included metrics on security incidents, their costs, system vulnerability tests, nonconformity detection, and resolution times, facilitating effective recording, reporting, and tracking of monitoring activities. Furthermore, SunDee embarked on a comprehensive measurement process to assess the progress and outcomes of ongoing projects, implementing extensive measures across all processes. The top management determined that the individual responsible for the information, aside from owning the data that contributes to the measures, would also be designated accountable for executing these measurement activities.

Based on the scenario above, answer the following question:

Based on scenario 8, which of the following performance indicators was NOT established by SunDee?

- A. Information security cases
- B. Training
- C. ISMS weaknesses

Answer: B

Question: 165

Scenario 8: SunDee is a biopharmaceutical firm headquartered in California, US. Renowned for its pioneering work in the field of human therapeutics, SunDee places a strong emphasis on addressing critical healthcare concerns, particularly in the domains of cardiovascular diseases, oncology, bone health, and inflammation. SunDee has demonstrated its commitment to data security and integrity by maintaining an effective information security management system (ISMS) based on ISO/IEC 27001 for the past two years.

In preparation for the recertification audit, SunDee conducted an internal audit. The company's top management appointed Alex, who has actively managed the Compliance Department's day-to-day operations for the last six months, as the internal auditor. With this dual role assignment, Alex is tasked with conducting an audit that ensures compliance and provides valuable recommendations to improve operational efficiency.

During the internal audit, a few nonconformities were identified. To address them comprehensively, the company created action plans for each nonconformity, working closely with the audit team leader.

SunDee's senior management conducted a comprehensive review of the ISMS to evaluate its appropriateness, sufficiency, and efficiency. This was integrated into their regular management meetings. Essential documents, including audit reports, action plans, and review outcomes, were distributed to all members before the meeting. The agenda covered the status of previous review actions, changes affecting the ISMS, feedback, stakeholder inputs, and opportunities for improvement. Decisions and actions targeting ISMS improvements were made, with a significant role played by the ISMS coordinator and the internal audit team in preparing follow-up action plans, which were then approved by top management.

In response to the review outcomes, SunDee promptly implemented corrective actions, strengthening its information security measures. Additionally, dashboard tools were introduced to provide a high-level overview of key performance indicators essential for monitoring the organization's information security management. These indicators included metrics on security incidents, their costs, system vulnerability tests, nonconformity detection, and resolution times, facilitating effective recording, reporting, and tracking of monitoring activities. Furthermore, SunDee embarked on a comprehensive measurement process to assess the progress and outcomes of ongoing projects, implementing extensive measures across all processes. The top management determined that the individual responsible for the information, aside from owning the data that contributes to the measures, would also be designated accountable for executing these measurement activities.

Based on the scenario above, answer the following question:

Based on scenario 8, which of the following dashboards did SunDee utilize?

- A. Operational dashboards
- B. Tactical dashboards
- C. Strategic dashboards

Answer: C

Question: 166

Scenario 8: SunDee is a biopharmaceutical firm headquartered in California, US. Renowned for its pioneering work in the field of human therapeutics, SunDee places a strong emphasis on addressing critical healthcare concerns, particularly in the domains of cardiovascular diseases, oncology, bone health, and inflammation. SunDee has demonstrated its commitment to data security and integrity by maintaining an effective information security management system (ISMS) based on ISO/IEC 27001 for the past two years.

In preparation for the recertification audit, SunDee conducted an internal audit. The company's top management appointed Alex, who has actively managed the Compliance Department's day-to-day operations for the last six months, as the internal auditor. With this dual role assignment, Alex is tasked with conducting an audit that ensures compliance and provides valuable recommendations to improve operational efficiency.

During the internal audit, a few nonconformities were identified. To address them comprehensively, the company created action plans for each nonconformity, working closely with the audit team leader.

SunDee's senior management conducted a comprehensive review of the ISMS to evaluate its appropriateness, sufficiency, and efficiency. This was integrated into their regular management meetings. Essential documents, including audit reports, action plans, and review outcomes, were distributed to all members before the meeting. The agenda covered the status of previous review actions, changes affecting the ISMS, feedback, stakeholder inputs, and opportunities for improvement. Decisions and actions targeting ISMS improvements were made, with a significant role played by the ISMS coordinator and the internal audit team in preparing follow-up action plans, which were then approved by top management.

In response to the review outcomes, SunDee promptly implemented corrective actions, strengthening its information security measures. Additionally, dashboard tools were introduced to provide a high-level overview of key performance indicators essential for monitoring the organization's information security management. These indicators included metrics on security incidents, their costs, system vulnerability tests, nonconformity detection, and resolution times, facilitating effective recording, reporting, and tracking of monitoring activities. Furthermore, SunDee embarked on a comprehensive measurement process to assess the progress and outcomes of ongoing projects, implementing extensive measures across all processes. The top management determined that the individual responsible for the information, aside from owning the data that contributes to the measures, would also be designated accountable for executing these measurement activities.

Based on the scenario above, answer the following question:

Does SunDee's approach align with the best practices for evaluating and maintaining the effectiveness of an ISMS?

- A. Yes, because comprehensive coverage is essential to achieve ISMS objectives
- B. Yes, because a diverse set of measures minimizes the likelihood of overlooking any potential security risks
- C. No, as an excessive number of measures may distort SunDee's focus and obscure what is genuinely important

Answer: B

Question: 167

Scenario 8: SunDee is a biopharmaceutical firm headquartered in California, US. Renowned for its pioneering work in the field of human therapeutics, SunDee places a strong emphasis on addressing critical healthcare concerns, particularly in the domains of cardiovascular diseases, oncology, bone health, and inflammation. SunDee has demonstrated its commitment to data security and integrity by maintaining an effective information security management system (ISMS) based on ISO/IEC 27001 for the past two years.

In preparation for the recertification audit, SunDee conducted an internal audit. The company's top management appointed Alex, who has actively managed the Compliance Department's day-to-day operations for the last six months, as the internal auditor. With this dual role assignment, Alex is tasked with conducting an audit that ensures compliance and provides valuable recommendations to improve operational efficiency.

During the internal audit, a few nonconformities were identified. To address them comprehensively, the company created action plans for each nonconformity, working closely with the audit team leader.

SunDee's senior management conducted a comprehensive review of the ISMS to evaluate its appropriateness, sufficiency, and efficiency. This was integrated into their regular management meetings. Essential documents, including audit reports, action plans, and review outcomes, were distributed to all members before the meeting. The agenda covered the status of previous review actions, changes affecting the ISMS, feedback, stakeholder inputs, and opportunities for improvement. Decisions and actions targeting ISMS improvements were made, with a significant role played by the ISMS coordinator and the internal audit team in preparing follow-up action plans, which were then approved by top management.

In response to the review outcomes, SunDee promptly implemented corrective actions, strengthening its information security measures. Additionally, dashboard tools were introduced to provide a high-level overview of key performance indicators essential for monitoring the organization's information security management. These indicators included metrics on security incidents, their costs, system vulnerability tests, nonconformity detection, and resolution times, facilitating effective recording, reporting, and tracking of monitoring activities. Furthermore, SunDee embarked on a comprehensive measurement process to assess the progress and outcomes of ongoing projects, implementing extensive measures across all processes. The top management determined that the individual responsible for the information, aside from owning the data that

contributes to the measures, would also be designated accountable for executing these measurement activities.

Based on the scenario above, answer the following question:

Did SunDee define the roles for measurement activities correctly?

- A. Yes, the information owner can also be responsible for conducting measurement activities
- B. No, as the information owner cannot perform different measurement-related roles and responsibilities
- C. No, as the responsibility for conducting measurement activities should have been assigned to the information communicator

Answer: A

Question: 168

Which of the following traits is NOT associated with an external audit?

- A. It is always conducted in a planned and timely manner
- B. It assesses the effectiveness and efficiency of ISMS
- C. It has no advisory role within the organization

Answer: C

Question: 169

Which of the following is the most suitable option for presenting raw data in a user-friendly, easy-to-read format?

- A. Scorecards
- B. Reports
- C. Gages

Answer: A

Question: 170

Scenario 9:

OpenTech, headquartered in San Francisco, specializes in information and communication

technology (ICT) solutions. Its clientele primarily includes data communication enterprises and network operators. The company's core objective is to enable its clients to transition smoothly into multi-service providers, aligning their operations with the complex demands of the digital landscape. Recently, Tim, the internal auditor of OpenTech, conducted an internal audit that uncovered nonconformities related to their monitoring procedures and system vulnerabilities. In response to these nonconformities, OpenTech decided to employ a comprehensive problem-solving approach to address the issues systematically. This method encompasses a team-oriented approach, aiming to identify, correct, and eliminate the root causes of the issues. The approach involves several steps: First, establish a group of experts with deep knowledge of processes and controls. Next, break down the nonconformity into measurable components and implement interim containment measures. Then, identify potential root causes and select and verify permanent corrective actions. Finally, put those actions into practice, validate them, take steps to prevent recurrence, and recognize and acknowledge the team's efforts.

Following the analysis of the root causes of the nonconformities, OpenTech's ISMS project manager, Julia, developed a list of potential actions to address the identified nonconformities. Julia carefully evaluated the list to ensure that each action would effectively eliminate the root cause of the respective nonconformity. While assessing potential corrective actions, Julia identified one issue as significant and assessed a high likelihood of its recurrence. Consequently, she chose to implement temporary corrective actions. Julia then combined all the nonconformities into a single action plan and sought approval from top management. The submitted action plan was written as follows: "A new version of the access control policy will be established and new restrictions will be created to ensure that network access is effectively managed and monitored by the Information and Communication Technology (ICT) Department."

However, Julia's submitted action plan was not approved by top management. The reason cited was that a general action plan meant to address all nonconformities was deemed unacceptable. Consequently, Julia revised the action plan and submitted separate ones for approval. Unfortunately, Julia did not adhere to the organization's specified deadline for submission, resulting in a delay in the corrective action process. Additionally, the revised action plans lacked a defined schedule for execution.

Which method did OpenTech choose to use for addressing and preventing reoccurring problems after identifying the nonconformities?

- A. The Eight Disciplines Problem Solving (8Ds) method
- B. DMAIC (Define, Measure, Analyze, Improve, Control) method
- C. Lean Six Sigma method

Answer: A

Question: 171

Scenario 9:

OpenTech, headquartered in San Francisco, specializes in information and communication technology (ICT) solutions. Its clientele primarily includes data communication enterprises and network operators. The company's core objective is to enable its clients to transition smoothly into

multi-service providers, aligning their operations with the complex demands of the digital landscape. Recently, Tim, the internal auditor of OpenTech, conducted an internal audit that uncovered nonconformities related to their monitoring procedures and system vulnerabilities. In response to these nonconformities, OpenTech decided to employ a comprehensive problem-solving approach to address the issues systematically. This method encompasses a team-oriented approach, aiming to identify, correct, and eliminate the root causes of the issues. The approach involves several steps: First, establish a group of experts with deep knowledge of processes and controls. Next, break down the nonconformity into measurable components and implement interim containment measures. Then, identify potential root causes and select and verify permanent corrective actions. Finally, put those actions into practice, validate them, take steps to prevent recurrence, and recognize and acknowledge the team's efforts.

Following the analysis of the root causes of the nonconformities, OpenTech's ISMS project manager, Julia, developed a list of potential actions to address the identified nonconformities. Julia carefully evaluated the list to ensure that each action would effectively eliminate the root cause of the respective nonconformity. While assessing potential corrective actions, Julia identified one issue as significant and assessed a high likelihood of its recurrence. Consequently, she chose to implement temporary corrective actions. Julia then combined all the nonconformities into a single action plan and sought approval from top management. The submitted action plan was written as follows:

"A new version of the access control policy will be established and new restrictions will be created to ensure that network access is effectively managed and monitored by the Information and Communication Technology (ICT) Department."

However, Julia's submitted action plan was not approved by top management. The reason cited was that a general action plan meant to address all nonconformities was deemed unacceptable.

Consequently, Julia revised the action plan and submitted separate ones for approval. Unfortunately, Julia did not adhere to the organization's specified deadline for submission, resulting in a delay in the corrective action process. Additionally, the revised action plans lacked a defined schedule for execution.

Did Julia's approach to submitting action plans for addressing nonconformities align with best practices?

- A. Yes, as action plan submission can be flexible
- B. No, as action plans are typically expected to meet specified deadlines
- C. Yes, Julia revised the action plan to ensure alignment with best practices

Answer: B

Question: 172

Scenario 9:

OpenTech, headquartered in San Francisco, specializes in information and communication technology (ICT) solutions. Its clientele primarily includes data communication enterprises and network operators. The company's core objective is to enable its clients to transition smoothly into multi-service providers, aligning their operations with the complex demands of the digital landscape. Recently, Tim, the internal auditor of OpenTech, conducted an internal audit that uncovered

nonconformities related to their monitoring procedures and system vulnerabilities. In response to these nonconformities, OpenTech decided to employ a comprehensive problem-solving approach to address the issues systematically. This method encompasses a team-oriented approach, aiming to identify, correct, and eliminate the root causes of the issues. The approach involves several steps: First, establish a group of experts with deep knowledge of processes and controls. Next, break down the nonconformity into measurable components and implement interim containment measures. Then, identify potential root causes and select and verify permanent corrective actions. Finally, put those actions into practice, validate them, take steps to prevent recurrence, and recognize and acknowledge the team's efforts.

Following the analysis of the root causes of the nonconformities, OpenTech's ISMS project manager, Julia, developed a list of potential actions to address the identified nonconformities. Julia carefully evaluated the list to ensure that each action would effectively eliminate the root cause of the respective nonconformity. While assessing potential corrective actions, Julia identified one issue as significant and assessed a high likelihood of its recurrence. Consequently, she chose to implement temporary corrective actions. Julia then combined all the nonconformities into a single action plan and sought approval from top management. The submitted action plan was written as follows:

"A new version of the access control policy will be established and new restrictions will be created to ensure that network access is effectively managed and monitored by the Information and Communication Technology (ICT) Department."

However, Julia's submitted action plan was not approved by top management. The reason cited was that a general action plan meant to address all nonconformities was deemed unacceptable.

Consequently, Julia revised the action plan and submitted separate ones for approval. Unfortunately, Julia did not adhere to the organization's specified deadline for submission, resulting in a delay in the corrective action process. Additionally, the revised action plans lacked a defined schedule for execution.

Based on scenario 9, was it acceptable that the top management rejected the action plan submitted by Julia?

- A. Yes, an action plan must be submitted to address each nonconformity separately
- B. No, top management should have approved the action plan submitted by Julia
- C. No, a general action plan can be submitted to address all nonconformities at once

Answer: A

Question: 173

Scenario 9:

OpenTech, headquartered in San Francisco, specializes in information and communication technology (ICT) solutions. Its clientele primarily includes data communication enterprises and network operators. The company's core objective is to enable its clients to transition smoothly into multi-service providers, aligning their operations with the complex demands of the digital landscape. Recently, Tim, the internal auditor of OpenTech, conducted an internal audit that uncovered nonconformities related to their monitoring procedures and system vulnerabilities. In response to these nonconformities, OpenTech decided to employ a comprehensive problem-solving approach to

address the issues systematically. This method encompasses a team-oriented approach, aiming to identify, correct, and eliminate the root causes of the issues. The approach involves several steps: First, establish a group of experts with deep knowledge of processes and controls. Next, break down the nonconformity into measurable components and implement interim containment measures. Then, identify potential root causes and select and verify permanent corrective actions. Finally, put those actions into practice, validate them, take steps to prevent recurrence, and recognize and acknowledge the team's efforts.

Following the analysis of the root causes of the nonconformities, OpenTech's ISMS project manager, Julia, developed a list of potential actions to address the identified nonconformities. Julia carefully evaluated the list to ensure that each action would effectively eliminate the root cause of the respective nonconformity. While assessing potential corrective actions, Julia identified one issue as significant and assessed a high likelihood of its recurrence. Consequently, she chose to implement temporary corrective actions. Julia then combined all the nonconformities into a single action plan and sought approval from top management. The submitted action plan was written as follows:

"A new version of the access control policy will be established and new restrictions will be created to ensure that network access is effectively managed and monitored by the Information and Communication Technology (ICT) Department."

However, Julia's submitted action plan was not approved by top management. The reason cited was that a general action plan meant to address all nonconformities was deemed unacceptable.

Consequently, Julia revised the action plan and submitted separate ones for approval. Unfortunately, Julia did not adhere to the organization's specified deadline for submission, resulting in a delay in the corrective action process. Additionally, the revised action plans lacked a defined schedule for execution.

Did OpenTech have a plan in place to implement permanent corrective action to address the identified nonconformities?

- A. Yes, OpenTech had a comprehensive plan in place to implement permanent corrective actions
- B. No, OpenTech did not have a clear plan to implement a permanent corrective action
- C. No, OpenTech decided not to pursue this course of action

Answer: B

Question: 174

Scenario 9:

OpenTech, headquartered in San Francisco, specializes in information and communication technology (ICT) solutions. Its clientele primarily includes data communication enterprises and network operators. The company's core objective is to enable its clients to transition smoothly into multi-service providers, aligning their operations with the complex demands of the digital landscape. Recently, Tim, the internal auditor of OpenTech, conducted an internal audit that uncovered nonconformities related to their monitoring procedures and system vulnerabilities. In response to these nonconformities, OpenTech decided to employ a comprehensive problem-solving approach to address the issues systematically. This method encompasses a team-oriented approach, aiming to identify, correct, and eliminate the root causes of the issues. The approach involves several steps:

First, establish a group of experts with deep knowledge of processes and controls. Next, break down the nonconformity into measurable components and implement interim containment measures. Then, identify potential root causes and select and verify permanent corrective actions. Finally, put those actions into practice, validate them, take steps to prevent recurrence, and recognize and acknowledge the team's efforts.

Following the analysis of the root causes of the nonconformities, OpenTech's ISMS project manager, Julia, developed a list of potential actions to address the identified nonconformities. Julia carefully evaluated the list to ensure that each action would effectively eliminate the root cause of the respective nonconformity. While assessing potential corrective actions, Julia identified one issue as significant and assessed a high likelihood of its recurrence. Consequently, she chose to implement temporary corrective actions. Julia then combined all the nonconformities into a single action plan and sought approval from top management. The submitted action plan was written as follows:

"A new version of the access control policy will be established and new restrictions will be created to ensure that network access is effectively managed and monitored by the Information and Communication Technology (ICT) Department."

However, Julia's submitted action plan was not approved by top management. The reason cited was that a general action plan meant to address all nonconformities was deemed unacceptable.

Consequently, Julia revised the action plan and submitted separate ones for approval. Unfortunately, Julia did not adhere to the organization's specified deadline for submission, resulting in a delay in the corrective action process. Additionally, the revised action plans lacked a defined schedule for execution.

Did Julia make an appropriate decision regarding the nonconformities with a high likelihood of reoccurrence?

- A. Yes, Julia's decision to implement temporary corrective actions was consistent with best practices
- B. No, as temporary corrective actions are not allowed in the evaluation phase
- C. No, implementing temporary actions during the corrective action process is not recommended

Answer: A

Question: 175

What is the primary requirement for the documented information of an ISMS?

- A. It must exist solely in a digital format to ensure modern compatibility
- B. It must be sufficiently flexible to adapt to any identified change triggers
- C. It must be accessible to the public at all times to maintain transparency

Answer: B

Question: 176

Scenario 10:

NetworkFuse is a leading company that specializes in the design, production, and distribution of network hardware products. Over the past two years, NetworkFuse has maintained an operational Information Security Management System (ISMS) based on ISO/IEC 27001 requirements and a Quality Management System (QMS) based on ISO 9001. These systems are designed to ensure the company's commitment to both information security and the highest quality standards. To further demonstrate its dedication to best practices and industry standards, NetworkFuse recently scheduled a combined certification audit. This audit seeks to validate NetworkFuse's compliance with both ISO/IEC 27001 and ISO 9001, showcasing the company's strong commitment to maintaining high standards in information security management and quality management. The process began with the careful selection of a certification body. NetworkFuse then took steps to prepare its employees for the audit, which was crucial for ensuring a smooth and successful audit process. Additionally, NetworkFuse appointed individuals to manage the ISMS and the QMS. NetworkFuse decided not to conduct a self-evaluation before the audit, a step often taken by organizations to proactively identify potential areas for improvement. The company's top management believed such an evaluation was unnecessary, confident in their existing systems and practices. This decision reflected their trust in the robustness of their ISMS and QMS. As part of the preparations, NetworkFuse took careful measures to ensure that all necessary documented information—including internal audit reports, management reviews, technological infrastructure, and the overall functioning of the ISMS and QMS—was readily available for the audit. This information would be vital in demonstrating their compliance with the ISO standards. During the audit, NetworkFuse requested that the certification body not carry documentation off-site. This request stemmed from their commitment to safeguarding sensitive and proprietary information, reflecting their desire for maximum security and control during the audit process. Despite meticulous preparations, the actual audit did not proceed as scheduled. NetworkFuse raised concerns about the assigned audit team leader and requested a replacement. The company asserted that the same audit team leader had previously issued a recommendation for certification to one of NetworkFuse's main competitors. This potential conflict of interest raised concerns among the company's top management. However, the certification body rejected NetworkFuse's request for a replacement, and the audit process was canceled.

Which of the following actions is NOT a requirement for NetworkFuse in preparing for the certification audit?

- A. Identifying subject matter experts
- B. Preparing the personnel
- C. Gathering documented information

Answer: A

Question: 177

An organization uses Platform as a Service (PaaS) to host its cloud-based services. As such, the cloud provider manages the majority of the services provided to the organization. What does the organization still need to manage when using PaaS?

- A. Operating system and virtualization
- B. Servers and storage
- C. Application and data

Answer: C

Question: 178

Scenario 6: Skyver manufactures electronic products, such as gaming consoles, flat-screen TVs, computers, and printers. In order to ensure information security, the company has decided to implement an information security management system (ISMS) based on ISO/IEC 27001. Colin, the company's information security manager, decided to conduct a training and awareness session for the company's staff about the information security risks and the controls implemented to mitigate them. The session covered various topics, including Skyver's information security approaches, techniques for mitigating phishing and malware, and a dedicated segment on securing cloud infrastructure and services. This particular segment explored the shared responsibility model and concepts such as identity and access management in the cloud. Colin organized the training and awareness sessions through engaging presentations, interactive discussions, and practical demonstrations to ensure that the personnel were well informed by security principles and practices. One of the participants in the session was Lisa, who works in the HR Department. Although Colin explained the existing Skyver's information security policies and procedures in an honest and fair manner, she found some of the issues being discussed too technical and did not fully understand the session. Therefore, in many cases, she would request additional help from the trainer and her colleagues. In a supportive manner, Colin suggested Lisa to consider attending the session again. Skyver has been exploring the implementation of AI solutions to help understand customer preferences and provide personalized recommendations for electronic products. The aim was to utilize AI technologies to enhance problem-solving capabilities and provide suggestions to customers. This strategic initiative aligned with Skyver's commitment to improving the customer experience through data-driven insights. Additionally, Skyver looked for a flexible cloud infrastructure that allows the company to host certain services on internal and secure infrastructure and other services on external and scalable platforms that can be accessed from anywhere. This setup would enable various deployment options and enhance information security, crucial for Skyver's electronic product development. According to Skyver, implementing additional controls in the ISMS implementation plan has been successfully executed, and the company was ready to transition into operational mode. Skyver assigned Colin the responsibility of determining the materiality of this change within the company. Based on the scenario above, answer the following question:
How should Colin have handled the situation with Lisa?

- A. Assign an individual the responsibility to provide Lisa with personalized explanations for her technical issues
- B. Organize separate technical training sessions exclusively for Lisa
- C. Deliver training and awareness sessions for employees with the same level of competence needs based on the activities they perform within the company

Answer: C

Question: 179

Scenario:

An employee at Reyae Ltd unintentionally sent an email containing critical business strategies to a competitor due to an autofill email suggestion error. The email included proprietary trade secrets and confidential client data

a. Upon receiving the email, the competitor altered the information and attempted to use it to mislead clients into switching services.

Which of the following statements correctly describes the security principles affected in this situation?

A. Reyae Ltd's confidentiality was compromised first, while the competitor's actions led to an integrity violation

B. Reyae Ltd's integrity was compromised first, while the competitor's actions led to an availability violation

C. Reyae Ltd's availability was compromised first, while the competitor's actions led to an integrity violation

Answer: A

Question: 180

An organization has implemented additional controls from other sources alongside the ISO/IEC 27001 Annex A controls. Is this acceptable?

A. Yes, organizations can incorporate additional controls from other sources

B. No, organizations must only implement the controls listed in Annex A

C. Yes, but only if the additional controls replace existing Annex A controls

Answer: A

Question: 181

What is the purpose of ISO/IEC 27002:2022 Clause 8.28?

A. To ensure all security requirements are addressed during application development

- B. To ensure software is written securely to reduce information security vulnerabilities
- C. To ensure secure system design principles are followed

Answer: C

Question: 182

Which of the following statements best represents The Open Security Architecture (OSA) framework?

- A. A framework that explains the functionality and technical controls of security, presenting a holistic view of crucial security concerns
- B. A framework that assists organizations in determining the objectives of developing their security architecture, focusing on the initial stages of security architecture
- C. A framework that helps organize enterprise architecture artifacts, including documents, specifications, and models, by considering the impact of these artifacts on various stakeholders

Answer: A

Question: 183

According to ISO/IEC 27001 controls, why should the use of privileged utility programs be restricted and tightly controlled?

- A. To ensure that utility programs are compatible with existing system software
- B. To prevent misuse of utility programs that could override system and application controls
- C. To enable the correlation and analysis of security-related events

Answer: B

Question: 184

Scenario 4: FinSecure

Finsecure is a financial institution based in Finland, providing services to a diverse clientele, encompassing retail banking, corporate banking, wealth management, and digital banking, all tailored to meet the evolving financial needs of individuals and businesses in the region. Recognizing the critical importance of information security in the modern banking landscape, FinSecure has initiated the implementation of an information security management system (ISMS) based on ISO/IEC 27001. To ensure the successful implementation of the ISMS, the top management decided

to contract two experts to lead and oversee the ISMS implementation project.

As a primary strategy for implementing the ISMS, the experts chose an approach that emphasizes a swift implementation of the ISMS by initially meeting the minimum requirements of ISO/IEC 27001, followed by continual improvement over time. Additionally, under the guidance of experts, FinSecure opted for a methodological framework, which serves as a structured framework that outlines the high-level stages of the ISMS implementation, the associated activities, and the deliverables without incorporating any specific tools.

The experts conducted a risk assessment, identifying all the supporting assets, which were the most tangible ones. They assessed the potential consequences and likelihood of various risks, determining the level of risks using a methodical approach that involved defining and characterizing the terms and criteria used in the assessment process. These risks were categorized into nonnumerical levels (e.g., very low, low, moderate, high, very high). Explanatory notes were thoughtfully crafted to justify assessed values, with the primary goal of enhancing repeatability and reproducibility.

After completing the risk assessment, the experts reviewed a selected number of the security controls from Annex A of ISO/IEC 27001 to determine which ones were applicable to the company's specific context. The decision to implement security controls was justified by the risk assessment results. Based on this review, they drafted the Statement of Applicability (SoA). They focused on treating only the high-risk category particularly addressing unauthorized use of administrator rights and system interruptions due to several hardware failures. To address these issues, they established a new version of the access control policy, implemented controls to manage and control user access, and introduced a control for ICT readiness to ensure business continuity.

Their risk assessment report indicated that if the implemented security controls reduce the risk levels to an acceptable threshold, those risks will be accepted

Did FinSecure identify information system components on which one or several business assets are based?

- A. Yes – the company identified all supporting assets as part of the asset identification process
- B. No – the company identified only the valuable information and some organizational processes
- C. No – the company identified only business assets

Answer: A

Question: 185

Refer to Scenario 4 (FinSecure)

Finsecure is a financial institution based in Finland, providing services to a diverse clientele, encompassing retail banking, corporate banking, wealth management, and digital banking, all tailored to meet the evolving financial needs of individuals and businesses in the region. Recognizing the critical importance of information security in the modern banking landscape, FinSecure has initiated the implementation of an information security management system (ISMS) based on ISO/IEC 27001. To ensure the successful implementation of the ISMS, the top management decided to contract two experts to lead and oversee the ISMS implementation project.

As a primary strategy for implementing the ISMS, the experts chose an approach that emphasizes a swift implementation of the ISMS by initially meeting the minimum requirements of ISO/IEC 27001, followed by continual improvement over time. Additionally, under the guidance of experts,

FinSecure opted for a methodological framework, which serves as a structured framework that outlines the high-level stages of the ISMS implementation, the associated activities, and the deliverables without incorporating any specific tools.

The experts conducted a risk assessment, identifying all the supporting assets, which were the most tangible ones. They assessed the potential consequences and likelihood of various risks, determining the level of risks using a methodical approach that involved defining and characterizing the terms and criteria used in the assessment process. These risks were categorized into nonnumerical levels (e.g., very low, low, moderate, high, very high). Explanatory notes were thoughtfully crafted to justify assessed values, with the primary goal of enhancing repeatability and reproducibility.

After completing the risk assessment, the experts reviewed a selected number of the security controls from Annex A of ISO/IEC 27001 to determine which ones were applicable to the company's specific context. The decision to implement security controls was justified by the risk assessment results. Based on this review, they drafted the Statement of Applicability (SoA). They focused on treating only the high-risk category particularly addressing unauthorized use of administrator rights and system interruptions due to several hardware failures. To address these issues, they established a new version of the access control policy, implemented controls to manage and control user access, and introduced a control for ICT readiness to ensure business continuity.

Their risk assessment report indicated that if the implemented security controls reduce the risk levels to an acceptable threshold, those risks will be accepted

Did the experts draft the Statement of Applicability (SoA) in accordance with ISO/IEC 27001?

- A. Yes – because they reviewed a selected number of the controls from Annex A of ISO/IEC 27001
- B. No – because they did not review all of the controls from Annex A of ISO/IEC 27001
- C. No – because the SoA should have been drafted just before the risk assessment was finalized

Answer: A

Question: 186

Scenario:

Evergreen tailored the format and naming convention of their information security policy to align with their internal structure and needs.

Is this acceptable?

- A. No – the policy must adhere to the predefined template set by ISO/IEC 27001
- B. Yes – the organization can determine the formats and names of these policy documents that meet the organization's needs
- C. No – the policy format and naming conventions must be approved by an external auditor before being implemented

Answer: B

Question: 187

Scenario 5: Evergreen

Evergreen is undergoing ISMS implementation. In their structure, there exists an Information Security Committee (ISC), which leads and governs security operations.

Can the information security committee at Evergreen take on the role of the emergency committee in the event of a major incident?

- A. No – no one should assume the role of the emergency committee to prevent the mismanagement of major incidents
- B. Yes – can assume the role of the emergency committee in the event of a major incident
- C. No – only the steering committee can assume the role of the emergency committee

Answer: B

Question: 188

Which statement best describes an organization that has achieved the “Defined” maturity level?

- A. The organization has implemented some processes, but there is no standardized procedure
- B. The organization has fully automated and integrated its workflows for continuous improvement
- C. The organization has standardized, documented, and communicated its procedures through training sessions

Answer: C

Question: 189

Which statement regarding organizational roles, responsibilities, and authorities is NOT correct?

- A. Top management is responsible for reporting on the performance of the ISMS and cannot assign this responsibility to someone else
- B. A project manager can have information security responsibilities as well
- C. Top management must assign the responsibility for ensuring that the ISMS conforms to ISO/IEC 27001

Answer: A

Question: 190

What action should an organization take to ensure the security of information when it is transferred or treated by an external party?

- A. Rely on external parties to implement their own security measures
- B. Include security clauses in a contractual agreement with the external party
- C. Exclude external parties from the ISMS scope to limit risk exposure

Answer: B

Question: 191

Which of the following would be an acceptable justification for excluding the Annex A 6.1 Screening control?

- A. The organization considers background verification checks unnecessary for its operations
- B. A collective agreement with employees prohibits security checks
- C. The organization voluntarily performs comprehensive criminal background checks on all employees

Answer: B

Question: 192

Who is responsible for ensuring that the ISMS achieves its intended outcomes?

- A. IT Department
- B. Top management
- C. ISMS project manager

Answer: B

Question: 193

Whom should an organization interview to obtain information regarding information security risks in their respective fields?

- A. Experts who are directly responsible for information security only
- B. Employees involved in information security activities and tasks only
- C. All interested parties' members, whether they are experts or not

Answer: C

Question: 194

Scenario:

A manufacturing company faced a risk of production delays due to potential supply chain disruptions. After assessing the potential impact, the company concluded the disruption was unlikely to significantly affect operations. The company decided to accept the risk.

Which risk treatment option did the company select in this case?

- A. Risk avoidance
- B. Risk retention
- C. Risk deflection

Answer: B

Question: 195

Scenario 6: GreenWave

GreenWave, a manufacturer of sustainable and energy efficient home appliances, specializes in solar-powered devices, EV chargers, and smart thermostats. To ensure the protection of customer data and internal operations against digital threats, the company has implemented an ISO/IEC 27001-based information security management system (ISMS). GreenWave is also exploring innovative IoT solutions to further improve energy efficiency in buildings

GreenWave is committed to maintaining a high standard of information security within its operations. As part of its continuous improvement approach, the company is in the process of determining the competence levels required to manage its ISMS. GreenWave considered various factors when defining these competence requirements, including technological advancements, regulatory requirements, the company's mission, strategic objectives, available resources, as well as the needs and expectations of its customers

Furthermore, the company remained committed to complying with ISO/IEC 27001's communication requirements. It established clear guidelines for internal and external communication related to the ISMS, defining what information to share, when to share it, with whom, and through which channels. However, not all communications were formally documented; instead, the company classified and

managed communication based on its needs, ensuring that documentation was maintained only to the extent necessary for the ISMS effectiveness .

GreenWave has been exploring the implementation of AI solutions to help understand customer preferences and provide personalized recommendations for electronic products. The aim was to utilize AI technologies to enhance problem-solving capabilities and provide suggestions to customers. This strategic initiative aligned with GreenWave's commitment to improving the customer experience through data-driven insights.

Additionally, GreenWave looked for a flexible cloud infrastructure that allows the company to host certain services on internal and secure infrastructure and other services on external and scalable platforms that can be accessed from anywhere. This setup would enable various deployment options and enhance information security, crucial for GreenWave's electronic product development

According to GreenWave, implementing additional controls in the ISMS implementation plan has been successfully executed, and the company was ready to transition into operational mode.

GreenWave assigned Colin the responsibility of determining the materiality of this change within the company.

Did GreenWave appropriately determine the competence levels required to support their ISMS?

A. Yes – because GreenWave considered only the internal factors, which are the most important for its operations

B. No – because GreenWave did not consider external issues, which are relevant to the ISMS

C. Yes – because GreenWave considered external issues, internal factors, and needs and expectations of relevant interested parties

Answer: C

Question: 196

Scenario 6: GreenWave

GreenWave, a manufacturer of sustainable and energy efficient home appliances, specializes in solar-powered devices, EV chargers, and smart thermostats. To ensure the protection of customer data and internal operations against digital threats, the company has implemented an ISO/IEC 27001-based information security management system (ISMS). GreenWave is also exploring innovative IoT solutions to further improve energy efficiency in buildings

GreenWave is committed to maintaining a high standard of information security within its operations. As part of its continuous improvement approach, the company is in the process of determining the competence levels required to manage its ISMS. GreenWave considered various factors when defining these competence requirements, including technological advancements, regulatory requirements, the company's mission, strategic objectives, available resources, as well as the needs and expectations of its customers

Furthermore, the company remained committed to complying with ISO/IEC 27001's communication requirements. It established clear guidelines for internal and external communication related to the ISMS, defining what information to share, when to share it, with whom, and through which channels. However, not all communications were formally documented; instead, the company classified and managed communication based on its needs, ensuring that documentation was maintained only to the extent necessary for the ISMS effectiveness .

GreenWave has been exploring the implementation of AI solutions to help understand customer preferences and provide personalized recommendations for electronic products. The aim was to utilize AI technologies to enhance problem-solving capabilities and provide suggestions to customers. This strategic initiative aligned with GreenWave's commitment to improving the customer experience through data-driven insights.

Additionally, GreenWave looked for a flexible cloud infrastructure that allows the company to host certain services on internal and secure infrastructure and other services on external and scalable platforms that can be accessed from anywhere. This setup would enable various deployment options and enhance information security, crucial for GreenWave's electronic product development. According to GreenWave, implementing additional controls in the ISMS implementation plan has been successfully executed, and the company was ready to transition into operational mode. GreenWave assigned Colin the responsibility of determining the materiality of this change within the company.

Is GreenWave's approach to documenting communication acceptable?

- A. No – as ISO/IEC 27001 requires all ISMS-related communication to be formally documented
- B. No – as ISO/IEC 27001 provides a predefined structure for all ISMS communication
- C. Yes – as the organization can determine the extent and format of documented communication based on what is necessary for the effectiveness of its ISMS

Answer: C

Question: 197

Scenario 7: CyTekShield

CyTekShield based in Dublin, Ireland, is a cybersecurity consulting provider specializing in digital risk management and enterprise security solutions. After facing multiple security incidents.

CyberTekShield formed expanded its information security team by bringing in Sadie and Niamh as part of the team. This team is structured into three key divisions: incident response, security architecture and forensics

Sadie will separate the demilitarized zone from CyTekShield's private network and publicly accessible resources, as part of implementing a screened subnet network architecture. In addition, Sadie will carry out comprehensive evaluations of any unexpected incidents, analyzing their causes and assessing their potential impact. She also developed security strategies and policies. Whereas Niamh, a specialized expert in forensic investigations, will be responsible for creating records of different data for evidence purposes. To do this effectively, she first reviewed the company's information security incident management policy, which outlines the types of records to be created, their storage location, and the required format and content for specific record types.

To support the process of handling of evidence related to information security events, CyTekShield has established internal procedures. These procedures ensure that evidence is properly identified, collected, and preserved within the company. CyTekShield's procedures specify how to handle records in various storage mediums, ensuring that all evidence is safeguarded in its original state, whether the devices are powered on or off.

As part of CyTekShield's initiative to strengthen information security measures, Niamh will conduct information security risk assessments only when significant changes are proposed and will document

the results of these risk assessments Upon completion of the risk assessment process, Niamh is responsible to develop and implement a plan for treating information security risks and document the risk treatment results.

Furthermore, while implementing the communication plan for information security, the CyTekShield's top management was responsible for creating a roadmap for new product development. This approach helps the company to align its security measures with the product development efforts, demonstrating a commitment to integrating security into every aspect of its business operations. CyTekShield uses a cloud service model that includes cloud-based apps accessed through the web or an application programming interface (API). All cloud services are provided by the cloud service provider, while data is managed by CyTekShield This introduces unique security considerations and becomes a primary focus for the information security team to ensure data and systems are protected in this environment. CyTekShield uses a cloud service model that includes cloud-based apps accessed through the web or an application programming interface (API). All cloud services are provided by the cloud service provider, while data is managed by CyTekShield This introduces unique security considerations and becomes a primary focus for the information security team to ensure data and systems are protected in this environment.

Has CyTekShield appropriately addressed the handling of evidence related to information security events?

- A. No – as it does not include proper training for staff involved in evidence handling
- B. Yes – it has appropriately addressed the handling of evidence
- C. No – because the process of evidence acquisition was not fully detailed

Answer: B

Question: 198

Scenario 7: CyTekShield

CyTekShield based in Dublin, Ireland, is a cybersecurity consulting provider specializing in digital risk management and enterprise security solutions. After facing multiple security incidents.

CyberTekShield formed expanded its information security team by bringing in Sadie and Niamh as part of the team. This team is structured into three key divisions: incident response, security architecture and forensics

Sadie will separate the demilitarized zone from CyTekShield's private network and publicly accessible resources, as part of implementing a screened subnet network architecture. In addition, Sadie will carry out comprehensive evaluations of any unexpected incidents, analyzing their causes and assessing their potential impact. She also developed security strategies and policies. Whereas Niamh, a specialized expert in forensic investigations, will be responsible for creating records of different data for evidence purposes To do this effectively, she first reviewed the company's information security incident management policy, which outlines the types of records to be created, their storage location, and the required format and content for specific record types.

To support the process of handling of evidence related to information security events. CyTekShield has established internal procedures. These procedures ensure that evidence is properly identified, collected, and preserved within the company CyTekShield's procedures specify how to handle records in various storage mediums, ensuring that all evidence is safeguarded in its original state,

whether the devices are powered on or off.

As part of CyTekShield's initiative to strengthen information security measures, Niamh will conduct information security risk assessments only when significant changes are proposed and will document the results of these risk assessments. Upon completion of the risk assessment process, Niamh is responsible to develop and implement a plan for treating information security risks and document the risk treatment results.

Furthermore, while implementing the communication plan for information security, the CyTekShield's top management was responsible for creating a roadmap for new product development. This approach helps the company to align its security measures with the product development efforts, demonstrating a commitment to integrating security into every aspect of its business operations. CyTekShield uses a cloud service model that includes cloud-based apps accessed through the web or an application programming interface (API). All cloud services are provided by the cloud service provider, while data is managed by CyTekShield. This introduces unique security considerations and becomes a primary focus for the information security team to ensure data and systems are protected in this environment. CyTekShield uses a cloud service model that includes cloud-based apps accessed through the web or an application programming interface (API). All cloud services are provided by the cloud service provider, while data is managed by CyTekShield. This introduces unique security considerations and becomes a primary focus for the information security team to ensure data and systems are protected in this environment.

Niamh, the forensics expert, conducted information security risk assessments upon significant changes and developed a risk treatment plan. The results of both were documented.

Does CyTekShield comply with ISO/IEC 27001 requirements regarding the information security risk treatment plan?

- A. Yes – by implementing a risk treatment plan and documenting risk treatment results
- B. No – it should only retain documented information for risk assessment results
- C. No – the information security risk treatment plan should be developed only by the top management

Answer: A

Question: 199

How should the level of detail in risk identification evolve over time?

- A. It should be refined gradually through iterative assessments, increasing the level of detail over time
- B. It should be performed in full detail only when significant changes occur in the organization
- C. It should focus on highly detailed assessments conducted on an ad-hoc basis rather than broad risk assessments

Answer: A

Question: 200

Scenario:

Jane is a developer deploying an application using a language supported by her cloud provider. She doesn't manage the underlying infrastructure but needs control over the application and its environment.

Which cloud service model does Jane need?

- A. Infrastructure as a Service
- B. Platform as a Service
- C. Software as a Service

Answer: B

Question: 201

During a security audit, analysts discover that an attacker repeatedly queried a black-box ML model to infer if specific data points were in the training set. The attacker could determine if an individual's data was used during training. What threat does this attack represent?

- A. Backdoor in the training set
- B. Data poisoning
- C. Membership inference attack

Answer: C

Question: 202

Scenario 8: BioVitalis

BioVitalis is a biopharmaceutical firm headquartered in California, the US. Renowned for its pioneering work in the field of human therapeutics, BioVitalis places a strong emphasis on addressing critical healthcare concerns, particularly in the domains of cardiovascular diseases, oncology, bone health, and inflammation. BioVitalis has demonstrated its commitment to data security and integrity by maintaining an effective information security management system (ISMS) based on ISO/IEC 27001 for the past two years.

In preparation for the recertification audit, BioVitalis conducted an internal audit. The company's top

management appointed Alex, who has actively managed the Compliance Department's day-to-day operations for the last six months, as the internal auditor. With this dual role assignment, Alex is tasked with conducting an audit that ensures compliance and provides valuable recommendations to improve operational efficiency.

During the internal audit, a few nonconformities were identified. To address them comprehensively, the company created action plans for each nonconformity, working closely with the audit team leader

BioVitalis's senior management conducted a comprehensive review of the ISMS to evaluate its appropriateness, sufficiency, and efficiency. This was integrated into their regular management meetings. Essential documents, including audit reports, action plans, and review outcomes, were distributed to all members before the meeting. The agenda covered the status of previous review actions, changes affecting the ISMS, feedback, stakeholder inputs, and opportunities for improvement. Decisions and actions targeting ISMS improvements were made, with a significant role played by the ISMS coordinator and the internal audit team in preparing follow up action plans, which were then approved by top management.

In response to the review outcomes, BioVitalis promptly implemented corrective actions, strengthening its Information security measures. Additionally, dashboard tools were introduced to provide a high-level overview of key performance indicators essential for monitoring the organization's information security management. These indicators included metrics on security incidents, their costs, system vulnerability tests, nonconformity detection, and resolution times, facilitating effective recording, reporting, and tracking of monitoring activities.

Furthermore, BioVitalis embarked on a comprehensive measurement process to assess the progress and outcomes of ongoing projects, implementing extensive measures across all processes. The top management determined that the individual responsible for the information, aside from owning the data that contributes to the measures, would also be designated accountable for executing these measurement activities.

BioVitalis is a biopharma company with an ISMS certified under ISO/IEC 27001. For recertification, it reviewed ISMS performance, created dashboards to monitor KPIs such as incident cost, vulnerability tests, and resolution times.

What type of dashboards did BioVitalis utilize?

- A. Operational
- B. Tactical
- C. Strategic

Answer: C

Question: 203

Scenario 8: BioVitalis

BioVitalis is a biopharmaceutical firm headquartered in California, the US. Renowned for its pioneering work in the field of human therapeutics, BioVitalis places a strong emphasis on addressing critical healthcare concerns, particularly in the domains of cardiovascular diseases, oncology, bone health, and inflammation. BioVitalis has demonstrated its commitment to data

security and integrity by maintaining an effective information security management system (ISMS) based on ISO/IEC 27001 for the past two years.

In preparation for the recertification audit, BioVitalis conducted an internal audit. The company's top management appointed Alex, who has actively managed the Compliance Department's day-to-day operations for the last six months, as the internal auditor. With this dual role assignment, Alex is tasked with conducting an audit that ensures compliance and provides valuable recommendations to improve operational efficiency.

During the internal audit, a few nonconformities were identified. To address them comprehensively, the company created action plans for each nonconformity, working closely with the audit team leader

BioVitalis's senior management conducted a comprehensive review of the ISMS to evaluate its appropriateness, sufficiency, and efficiency. This was integrated into their regular management meetings. Essential documents, including audit reports, action plans, and review outcomes, were distributed to all members before the meeting. The agenda covered the status of previous review actions, changes affecting the ISMS, feedback, stakeholder inputs, and opportunities for improvement. Decisions and actions targeting ISMS improvements were made, with a significant role played by the ISMS coordinator and the internal audit team in preparing follow up action plans, which were then approved by top management.

In response to the review outcomes, BioVitalis promptly implemented corrective actions, strengthening its Information security measures. Additionally, dashboard tools were introduced to provide a high-level overview of key performance indicators essential for monitoring the organization's information security management. These indicators included metrics on security incidents, their costs, system vulnerability tests, nonconformity detection, and resolution times, facilitating effective recording, reporting, and tracking of monitoring activities.

Furthermore, BioVitalis embarked on a comprehensive measurement process to assess the progress and outcomes of ongoing projects, implementing extensive measures across all processes. The top management determined that the individual responsible for the information, aside from owning the data that contributes to the measures, would also be designated accountable for executing these measurement activities

Top management decided that the information owner would also be responsible for executing measurement activities across ISMS processes.

Did BioVitalis define the roles for measurement activities correctly?

- A. Yes – the information owner can also be responsible for conducting measurement activities
- B. No – as the information owner cannot perform different measurement-related roles and responsibilities
- C. No – as the responsibility for conducting measurement activities should have been assigned to the information communicator

Answer: A

Question: 204

An organization has compared its actual performance against predetermined performance targets. What is the primary purpose of this action?

- A. To verify that all security incidents are resolved
- B. To assess whether the organization's security objectives are being met
- C. To eliminate the need for manual tracking and reporting

Answer: B

Question: 205

Which statement regarding management reviews is correct?

- A. Management reviews are carried out at various levels in the organization
- B. Management reviews must be carried out monthly
- C. Top management can delegate the ultimate responsibility of the management review process to individuals working for the organization

Answer: A

Question: 206

Scenario 9: CoreBit Systems

CoreBit Systems, with its headquarters in San Francisco, specializes in information and communication technology (ICT) solutions, its clientele primarily includes data communication enterprises and network operators. The company's core objective is to enable its clients a smooth transition into multi-service providers, aligning their operations with the complex demands of the digital landscape.

Recently, John, the internal auditor of CoreBit Systems, conducted an internal audit which uncovered nonconformities related to their monitoring procedures and system vulnerabilities, in response to the identified nonconformities. CoreBit Systems decided to employ a comprehensive problem-solving approach to solve these issues systematically. The method encompasses a team-oriented approach, aiming to identify, correct, and eliminate the root causes of issues. This approach involves several steps. First, establish a group of experts with deep knowledge of processes and controls. Next, break down the nonconformity into measurable components and implement interim containment measures. Then, identify potential root causes and select and verify permanent corrective actions. Finally, put those actions into practice, validate them, take steps to prevent recurrence, and recognize and acknowledge the team's efforts.

Following the analysis of the root cause of the nonconformities, CoreBit Systems's ISMS project manager, Julia, developed a list of potential actions to address the identified nonconformities. Julia carefully evaluated the list to ensure that each action would effectively eliminate the root cause of

the respective nonconformity. While assessing potential corrective action for addressing a nonconformity, Julia identified the issue as significant and assessed a high likelihood of its reoccurrence. Consequently, she chose to implement temporary corrective actions. Afterward, Julia combined all the nonconformities into a single action plan and sought approval from the top management.

The submitted action plan was written as follows:

A new version of the access control policy will be established and new restrictions will be created to ensure that network access is effectively managed and monitored by the Information and Communication Technology (ICT) Department.

However, Julia's submitted action plan was not approved by top management. The reason cited was that a general action plan meant to address all nonconformities was deemed unacceptable.

Consequently, Julia revised the action plan and submitted separate ones for approval. Unfortunately, Julia did not adhere to the organization's specified deadline for submission, resulting in a delay in the corrective action process, and notably, the revised action plans lacked a defined schedule for execution.

Which method did CoreBit Systems use to address and prevent reoccurring problems after identifying the nonconformities?

- A. The Eight Disciplines Problem Solving (8Ds) method
- B. DMAIC (Define, Measure, Analyze, Improve, Control) method
- C. Lean Six Sigma method

Answer: A

Question: 207

Scenario 9: CoreBit Systems

CoreBit Systems, with its headquarters in San Francisco, specializes in information and communication technology (ICT) solutions; its clientele primarily includes data communication enterprises and network operators. The company's core objective is to enable its clients a smooth transition into multi-service providers, aligning their operations with the complex demands of the digital landscape.

Recently, John, the internal auditor of CoreBit Systems, conducted an internal audit which uncovered nonconformities related to their monitoring procedures and system vulnerabilities, in response to the identified nonconformities. CoreBit Systems decided to employ a comprehensive problem-solving approach to solve these issues systematically. The method encompasses a team-oriented approach, aiming to identify, correct, and eliminate the root causes of issues. This approach involves several steps. First, establish a group of experts with deep knowledge of processes and controls. Next, break down the nonconformity into measurable components and implement interim containment measures. Then, identify potential root causes and select and verify permanent corrective actions. Finally, put those actions into practice, validate them, take steps to prevent recurrence, and recognize and acknowledge the team's efforts.

Following the analysis of the root cause of the nonconformities, CoreBit Systems's ISMS project manager, Julia, developed a list of potential actions to address the identified nonconformities. Julia carefully evaluated the list to ensure that each action would effectively eliminate the root cause of

the respective nonconformity. While assessing potential corrective action for addressing a nonconformity, Julia identified the issue as significant and assessed a high likelihood of its reoccurrence. Consequently, she chose to implement temporary corrective actions. Afterward, Julia combined all the nonconformities into a single action plan and sought approval from the top management.

The submitted action plan was written as follows:

A new version of the access control policy will be established and new restrictions will be created to ensure that network access is effectively managed and monitored by the Information and Communication Technology (ICT) Department.

However, Julia's submitted action plan was not approved by top management. The reason cited was that a general action plan meant to address all nonconformities was deemed unacceptable.

Consequently, Julia revised the action plan and submitted separate ones for approval. Unfortunately, Julia did not adhere to the organization's specified deadline for submission, resulting in a delay in the corrective action process, and notably, the revised action plans lacked a defined schedule for execution.

Julia, the ISMS project manager, developed a combined action plan for all nonconformities. However, it was rejected, revised, and resubmitted late—without defined execution schedules.

Did CoreBit Systems have a plan in place to implement permanent corrective action to address the identified nonconformities?

- A. Yes – CoreBit Systems had a comprehensive plan in place to implement permanent corrective actions
- B. No – CoreBit Systems did not have a clear plan to implement a permanent corrective action
- C. No – CoreBit Systems decided not to pursue this course of action

Answer: B

Question: 208

Which audit phase was conducted after the issue with the audit team was resolved?

- A. Stage 1
- B. Stage 2
- C. Audit follow-up

Answer: B

Question: 209

Scenario 10: ProEBank

ProEBank, an Austrian financial institution, implemented an ISMS and prepared for ISO/IEC 27001 certification. During planning, the company identified a conflict of interest with one auditor, who had previously worked with their main competitor. ProEBank refused to undergo the audit until a new audit team was assigned. The certification body acknowledged the issue and replaced the team.

ProEBank is an Austrian financial institution known for its comprehensive range of banking services. Headquartered in Vienna, it leverages the city's advanced technological and financial ecosystem. To enhance its security posture, ProEBank has implemented an information security management system (ISMS) based on the ISO/IEC 27001. After a year of having the ISMS in place, the company decided to apply for a certification audit to obtain certification against ISO/IEC 27001.

To prepare for the audit, the company first informed its employees for the audit and organized training sessions to prepare them. It also prepared documented information in advance, so that the documents would be ready when external auditors asked to review them. Additionally, it determined which of its employees have the knowledge to help the external auditors understand and evaluate the processes.

During the planning phase for the audit, ProEBank reviewed the list of assigned auditors provided by the certification body. Upon reviewing the list, ProEBank identified a potential conflict of interest with one of the auditors, who had previously worked for ProEBank's main competitor in the banking industry. To ensure the integrity of the audit process, ProEBank refused to undergo the audit until a completely new audit team was assigned. In response, the certification body acknowledged the conflict of interest and made the necessary adjustments to ensure the impartiality of the audit team. After the resolution of this issue, the audit team assessed whether the ISMS met both the standard's requirements and the company's objectives. During this process, the audit team focused on reviewing documented information.

Three weeks later, the team conducted an on-site visit to the auditee's location where they aimed to evaluate whether the ISMS conformed to the requirements of ISO/IEC 27001. It was effectively implemented, and enabled the auditee to reach its information security objectives. After the on-site visit, the team prepared the audit conclusions and notified the auditee that some minor nonconformities had been detected. The audit team leader then issued a recommendation for certification.

After receiving the recommendation from the audit team leader, the certification body established a committee to make the decision for certification. The committee included one member from the audit team and two other experts working for the certification body.

Is ProEBank's decision to require a new audit team due to a perceived conflict of interest acceptable?

- A. No – they should have requested only the replacement of the auditor
- B. No – the auditee does not have the right to reject the auditors selected by the certification body
- C. Yes – the auditee is allowed to refuse to undergo the audit until a new audit team is established

Answer: C

Question: 210

Scenario 10: ProEBank

ProEBank is an Austrian financial institution known for its comprehensive range of banking services. Headquartered in Vienna, it leverages the city's advanced technological and financial ecosystem. To enhance its security posture, ProEBank has implemented an information security management system (ISMS) based on the ISO/IEC 27001. After a year of having the ISMS in place, the company decided to apply for a certification audit to obtain certification against ISO/IEC 27001.

To prepare for the audit, the company first informed its employees for the audit and organized training sessions to prepare them. It also prepared documented information in advance, so that the documents would be ready when external auditors asked to review them. Additionally, it determined which of its employees have the knowledge to help the external auditors understand and evaluate the processes.

During the planning phase for the audit, ProEBank reviewed the list of assigned auditors provided by the certification body. Upon reviewing the list, ProEBank identified a potential conflict of interest with one of the auditors, who had previously worked for ProEBank's main competitor in the banking industry. To ensure the integrity of the audit process, ProEBank refused to undergo the audit until a completely new audit team was assigned. In response, the certification body acknowledged the conflict of interest and made the necessary adjustments to ensure the impartiality of the audit team. After the resolution of this issue, the audit team assessed whether the ISMS met both the standard's requirements and the company's objectives. During this process, the audit team focused on reviewing documented information.

Three weeks later, the team conducted an on-site visit to the auditee's location where they aimed to evaluate whether the ISMS conformed to the requirements of ISO/IEC 27001. It was effectively implemented, and enabled the auditee to reach its information security objectives. After the on-site visit, the team prepared the audit conclusions and notified the auditee that some minor nonconformities had been detected. The audit team leader then issued a recommendation for certification.

After receiving the recommendation from the audit team leader, the certification body established a committee to make the decision for certification. The committee included one member from the audit team and two other experts working for the certification body.

After the Stage 2 audit, minor nonconformities were found. Despite this, the audit team leader issued a positive recommendation for certification.

Is this acceptable?

- A. No – the auditor should have issued an unfavorable recommendation for certification because minor nonconformities were identified
- B. Yes – a recommendation for certification should be issued when only minor nonconformities are identified
- C. No – the auditor should have issued a recommendation for certification conditional upon the filing of corrective action plans for the minor nonconformities

Answer: B

Question: 211

Scenario 10: ProEBank

ProEBank is an Austrian financial institution known for its comprehensive range of banking services. Headquartered in Vienna, it leverages the city's advanced technological and financial ecosystem. To enhance its security posture, ProEBank has implemented an information security management system (ISMS) based on the ISO/IEC 27001. After a year of having the ISMS in place, the company decided to apply for a certification audit to obtain certification against ISO/IEC 27001.

To prepare for the audit, the company first informed its employees for the audit and organized training sessions to prepare them. It also prepared documented information in advance, so that the documents would be ready when external auditors asked to review them. Additionally, it determined which of its employees have the knowledge to help the external auditors understand and evaluate the processes.

During the planning phase for the audit, ProEBank reviewed the list of assigned auditors provided by the certification body. Upon reviewing the list, ProEBank identified a potential conflict of interest with one of the auditors, who had previously worked for ProEBank's main competitor in the banking industry. To ensure the integrity of the audit process, ProEBank refused to undergo the audit until a completely new audit team was assigned. In response, the certification body acknowledged the conflict of interest and made the necessary adjustments to ensure the impartiality of the audit team. After the resolution of this issue, the audit team assessed whether the ISMS met both the standard's requirements and the company's objectives. During this process, the audit team focused on reviewing documented information.

Three weeks later, the team conducted an on-site visit to the auditee's location where they aimed to evaluate whether the ISMS conformed to the requirements of ISO/IEC 27001, was effectively implemented, and enabled the auditee to reach its information security objectives. After the on-site visit, the team prepared the audit conclusions and notified the auditee that some minor nonconformities had been detected. The audit team leader then issued a recommendation for certification.

After receiving the recommendation from the audit team leader, the certification body established a committee to make the decision for certification. The committee included one member from the audit team and two other experts working for the certification body.

The certification body's final decision for certification was made by a committee that included one auditor from the audit team and two other experts.

Is this acceptable?

- A. No – the certification body must ensure that persons that make the decision for certification are different from those who carried out the audit
- B. No – the committee should have included only members from the audit team and not other experts that were not part of the audit
- C. Yes – the committee must include one member from the audit team and other individuals working for the certification body

Answer: A

Question: 212

Scenario 10: ProEBank

ProEBank is an Austrian financial institution known for its comprehensive range of banking services. Headquartered in Vienna, it leverages the city's advanced technological and financial ecosystem. To enhance its security posture, ProEBank has implemented an information security management system (ISMS) based on the ISO/IEC 27001. After a year of having the ISMS in place, the company decided to apply for a certification audit to obtain certification against ISO/IEC 27001.

To prepare for the audit, the company first informed its employees for the audit and organized training sessions to prepare them. It also prepared documented information in advance, so that the documents would be ready when external auditors asked to review them. Additionally, it determined which of its employees have the knowledge to help the external auditors understand and evaluate the processes.

During the planning phase for the audit, ProEBank reviewed the list of assigned auditors provided by the certification body. Upon reviewing the list, ProEBank identified a potential conflict of interest with one of the auditors, who had previously worked for ProEBank's main competitor in the banking industry. To ensure the integrity of the audit process, ProEBank refused to undergo the audit until a completely new audit team was assigned. In response, the certification body acknowledged the conflict of interest and made the necessary adjustments to ensure the impartiality of the audit team. After the resolution of this issue, the audit team assessed whether the ISMS met both the standard's requirements and the company's objectives. During this process, the audit team focused on reviewing documented information.

Three weeks later, the team conducted an on-site visit to the auditee's location where they aimed to evaluate whether the ISMS conformed to the requirements of ISO/IEC 27001, was effectively implemented, and enabled the auditee to reach its information security objectives. After the on-site visit, the team prepared the audit conclusions and notified the auditee that some minor nonconformities had been detected. The audit team leader then issued a recommendation for certification.

After receiving the recommendation from the audit team leader, the certification body established a committee to make the decision for certification. The committee included one member from the audit team and two other experts working for the certification body.

To prepare for their ISO/IEC 27001 certification audit, ProEBank trained employees, prepared documentation, and identified key personnel to support the audit. However, they did not conduct a self-assessment before the audit.

Did ProEBank follow all of the best practices while preparing for the certification audit?

- A. Yes – the company followed all of the best practices in preparation for the certification audit
- B. No – the company should have also conducted a self-assessment to prepare for the audit
- C. No – the company should not have informed its employees regarding the upcoming audit

Answer: B

Question: 213

Scenario 1: NobleFind is an online retailer specializing in high-end, custom-design furniture. The company offers a wide range of handcrafted pieces tailored to meet the needs of residential and

commercial clients. NobleFind also provides expert design consultation services. Despite NobleFind's efforts to keep its online shop platform secure, the company faced persistent issues, including a recent data breach. These ongoing challenges disrupted normal operations and underscored the need for enhanced security measures. The designated IT team quickly responded to resolve the problem. To address these issues, NobleFind decided to implement an Information Security Management System (ISMS) based on ISO/IEC 27001 to improve security, protect customer data, and ensure the stability of its services.

In addition to its commitment to information security, NobleFind focuses on maintaining the accuracy and completeness of its product data.

a. This is ensured by carefully managing version control, checking information regularly, enforcing strict access policies, and implementing backup procedures. Moreover, product details and customer designs are accessible only to authorized individuals, with security measures such as multi-factor authentication and data access policies.

NobleFind has implemented an incident investigation process within its ISMS, as part of its comprehensive approach to information security. Additionally, it has established record retention policies to ensure that online information about each product and client information remains readily accessible and usable on demand for authorized entities. NobleFind established an information security policy offering clear guidelines for safeguarding historical data. It also insisted that personnel sign confidentiality agreements and were committed to recruiting only qualified individuals. Additionally, NobleFind implemented measures for monitoring the resources used by its systems, reviewing user access rights, and conducting a thorough analysis of audit logs to swiftly identify and address any security anomalies.

With its ISMS in place, NobleFind maintains and safeguards documented information, encompassing a wide range of data, records, and specifications. This documented information is vital to its operations, ensuring the security and integrity of customer data, historical records, and financial information.

Based on the scenario above, answer the following question.

Which information security principle was impacted during the service interruption that NobleFind experienced?

- A. Confidentiality
- B. Integrity
- C. Availability
- D. Non-repudiation

Answer: C

Question: 214

Scenario 1: NobleFind is an online retailer specializing in high-end, custom-design furniture. The company offers a wide range of handcrafted pieces tailored to meet the needs of residential and commercial clients. NobleFind also provides expert design consultation services. Despite NobleFind's efforts to keep its online shop platform secure, the company faced persistent issues, including a recent data breach. These ongoing challenges disrupted normal operations and underscored the need for enhanced security measures. The designated IT team quickly responded to resolve the problem. To address these issues, NobleFind decided to implement an Information Security Management System (ISMS) based on ISO/IEC 27001 to improve security, protect customer data, and

ensure the stability of its services.

In addition to its commitment to information security, NobleFind focuses on maintaining the accuracy and completeness of its product data

a. This is ensured by carefully managing version control, checking information regularly, enforcing strict access policies, and implementing backup procedures. Product details and customer designs are accessible only to authorized individuals with security measures such as multi-factor authentication and data access policies. NobleFind has implemented an incident investigation process within its ISMS and established record retention policies. NobleFind maintains and safeguards documented information, encompassing a wide range of data, records, and specifications—ensuring the security and integrity of customer data, historical records, and financial information.

As part of its commitment to information security, how does NobleFind ensure the integrity of its information? Refer to Scenario 1.

- A. By implementing backup procedures
- B. By implementing access policies only
- C. By conducting regular checks of the information
- D. By only allowing passionate users to access the information

Answer: C

Question: 215

Scenario 1: NobleFind is an online retailer specializing in high-end, custom-design furniture. The company offers a wide range of handcrafted pieces tailored to meet the needs of residential and commercial clients. NobleFind also provides expert design consultation services. Despite NobleFind's efforts to keep its online shop platform secure, the company faced persistent issues, including a recent data breach. These ongoing challenges disrupted normal operations and underscored the need for enhanced security measures. The designated IT team quickly responded to resolve the problem, demonstrating their agility in handling technical challenges. To address these issues, NobleFind decided to implement an Information Security Management System (ISMS) based on ISO/IEC 27001 to improve security, protect customer data, and ensure the stability of its services.

In addition to its commitment to information security, NobleFind focuses on maintaining the accuracy and completeness of its product data

a. This is ensured by carefully managing version control, checking information regularly, enforcing strict access policies, and implementing backup procedures. Product details and customer designs are accessible only to authorized individuals, with security measures such as multi-factor authentication and data access policies. NobleFind has implemented an incident investigation process within its ISMS and established record retention policies. NobleFind maintains and safeguards documented information, encompassing a wide range of data, records, and specifications—ensuring the security and integrity of customer data, historical records, and financial information.

Has NobleFind implemented any preventive controls? Refer to Scenario 1.

- A. Yes, by establishing an information security policy
- B. Yes, by monitoring the resources used by its systems
- C. No, NobleFind has implemented only corrective and detective controls
- D. Yes, by conducting audit log analysis only

Answer: A

Question: 216

Scenario 1: NobleFind is an online retailer specializing in high-end, custom-design furniture. The company offers a wide range of handcrafted pieces tailored to meet the needs of residential and commercial clients. NobleFind also provides expert design consultation services. Despite NobleFind's efforts to keep its online shop platform secure, the company faced persistent issues, including a recent data breach. These ongoing challenges disrupted normal operations and underscored the need for enhanced security measures. The designated IT team quickly responded to resolve the problem. To address these issues, NobleFind decided to implement an Information Security Management System (ISMS) based on ISO/IEC 27001 to improve security, protect customer data, and ensure the stability of its services.

In addition to its commitment to information security, NobleFind focuses on maintaining the accuracy and completeness of its product data

a. This is ensured by carefully managing version control, checking information regularly, enforcing strict access policies, and implementing backup procedures. Moreover, product details and customer designs are accessible only to authorized individuals, with security measures such as multi-factor authentication and data access policies.

NobleFind has implemented an incident investigation process within its ISMS, as part of its comprehensive approach to information security. Additionally, it has established record retention policies to ensure that online information about each product and client information remains readily accessible and usable on demand for authorized entities. NobleFind established an information security policy offering clear guidelines for safeguarding historical data. It also insisted that personnel sign confidentiality agreements and were committed to recruiting only qualified individuals. Additionally, NobleFind implemented measures for monitoring the resources used by its systems, reviewing user access rights, and conducting a thorough analysis of audit logs to swiftly identify and address any security anomalies.

With its ISMS in place, NobleFind maintains and safeguards documented information, encompassing a wide range of data, records, and specifications. This documented information is vital to its operations, ensuring the security and integrity of customer data, historical records, and financial information.

According to scenario 1, which detective control did NobleFind implement?

- A. Enforcing strict access policies
- B. Conducting a thorough analysis of audit logs
- C. Implementing an incident investigation process
- D. Implementing backup procedures

Answer: B

Question: 217

Scenario 2: NyvMarketing is a marketing firm that provides different services to clients across various industries. With expertise in digital marketing, branding, and market research, NyvMarketing has built a solid

reputation for delivering innovative and impactful marketing campaigns. With the growing Significance Of data Security and information protection within the marketing landscape, the company decided to implement an ISMS based on 27001.

While implementing its ISMS NyvMarketing encountered a significant challenge; the threat of insufficient resources, This challenge posed a risk to effectively executing its ISMS objectives and could potentially

undermine the company's efforts to safeguard Sensitive information. TO address this threat, NyvMarketing adopted a proactive approach by appointing Michael to manage the risks related to resource Constraints.

Michael was pivotal in identifying and addressing resource gaps, strategizing risk mitigation, and allocating resources effectively for ISMS implementation at NyvMarket•ng, strengthening the company's resilience against resource challenges.

Furthermore, NyvMarketing prioritized industry standards and best practices in information security, diligently following ISO/IEC 27002 guidelines. This commitment, driven by excellence and ISO/IEC 27001

requirements, underscored NyvMarketing's dedication to upholding the h•ghest Standards Of information security governance.

While working on the ISMS implementation, NyvMarketing opted to exclude one Of the requirements related to competence (as stipulated in ISO/IEC 27001, Clause 7.2). The company believed that its existing

workforce possessed the necessary competence to fulfill ISMS•related tasks_ However, it did not provide a valid justification for this omission. Moreover, when specific controls from Annex A Of ISO/IEC 27001

were not implemented, NyvMarketing neglected to provide an acceptable justification for these exclusions.

During the ISMS implementation, NFMmarketing thoroughly assessed vulnerabilities that could affect its information Security These vulnerabilities included insufficient maintenance and faulty installation Of

storage media, insufficient periodic replacement schemes for equipment, Inadequate software testing, and unprotected communication lines. Recognizing that these vulnerabilities could pose risks to its data

security, NBMarketing took steps to address these specific weaknesses by implementing the necessary controls and countermeasures-

Based on the scenario above, answer the following question.

In the scenario 2, NyvMarketing faced the threat of insufficient resources during the ISMS implementation. In which of the following categories does this threat fall?

In scenario 2, NyvMarketing faced the threat of insufficient resources during the ISMS

implementation. In which of the following categories does this threat fall?

- A. Organizational threats
- B. Physical threats
- C. Compromise of functions or services
- D. Natural threats

Answer: A

Question: 218

Is NyvMarketing required to follow the guidelines of ISO/IEC 27002 to attain ISO/IEC 27001 certification?

- A. No, adherence to ISO/IEC 27002 guidelines is not mandatory for ISO/IEC 27001 certification
- B. Yes, since it is a requirement according to ISO/IEC 27001
- C. Yes, since the controls provided in Annex A of ISO/IEC 27001 are aligned with ISO/IEC 27002 controls
- D. Yes, since ISO/IEC 27002 is an auditable standard

Answer: A

Question: 219

Scenario 2: NyvMarketing is a marketing firm that provides different services to clients across various industries. With expertise in digital marketing, branding, and market research, NyvMarketing has built a solid reputation for delivering innovative and impactful marketing campaigns. With the growing Significance Of data Security and information protection within the marketing landscape, the company decided to implement an ISMS based on 27001.

While implementing its ISMS NyvMarketing encountered a significant challenge; the threat of insufficient resources, This challenge posed a risk to effectively executing its ISMS objectives and could potentially

undermine the company'S efforts to safeguard Sensitive information. TO address this threat, NyvMarketing adopted a proactive approach by appointing Michael to manage the risks related to resource Constraints.

Michael was pivotal in identifying and addressing resource gaps, strategizing risk mitigation, and allocating resources effectively for ISMS implementation at NyvMarket•ng, strengthening the company's resilience

against resource challenges.

Furthermore, NyvMarketing prioritized industry standards and best practices in information security, diligently following ISO/IEC 27002 guidelines. This commitment, driven by excellence and ISO/IEC 27001

requirements, underscored NyvMarketing's dedication to upholding the highest Standards Of information security governance.

While working on the ISMS implementation, NyvMarketing opted to exclude one Of the requirements related to competence (as stipulated in ISO/IEC 27001, Clause 7.2). The company believed that its existing

workforce possessed the necessary competence to fulfill ISMS-related tasks. However, it did not provide a valid justification for this omission. Moreover, when specific controls from Annex A Of ISO/IEC 27001

were not implemented, NyvMarketing neglected to provide an acceptable justification for these exclusions.

During the ISMS implementation, NyvMarketing thoroughly assessed vulnerabilities that could affect its information Security. These vulnerabilities included insufficient maintenance and faulty installation Of

storage media, insufficient periodic replacement schemes for equipment, Inadequate software testing, and unprotected communication lines. Recognizing that these vulnerabilities could pose risks to its data

security, NyvMarketing took steps to address these specific weaknesses by implementing the necessary controls and countermeasures-

Based on the scenario above, answer the following question.

In the scenario 2, NyvMarketing faced the threat of insufficient resources during the ISMS implementation. In which of the following categories does this threat fall?

According to scenario 2, what is Michael's role at NyvMarketing?

- A. Risk owner
- B. Incident manager
- C. Crisis manager
- D. ISMS auditor

Answer: A

Question: 220

Scenario 2: NyvMarketing is a marketing firm that provides different services to clients across various industries. With expertise in digital marketing, branding, and market research, NyvMarketing has built a solid

reputation for delivering innovative and impactful marketing campaigns. With the growing Significance Of data Security and information protection within the marketing landscape, the company decided to

implement an ISMS based on 27001.

While implementing its ISMS NyvMarketing encountered a significant challenge; the threat of

insufficient resources, This challenge posed a risk to effectively executing its ISMS objectives and could potentially undermine the company's efforts to safeguard Sensitive information. TO address this threat, NyvMarketing adopted a proactive approach by appointing Michael to manage the risks related to resource Constraints.

Michael was pivotal in identifying and addressing resource gaps. strategizing risk mitigation. and allocating resources effectively for ISMS implementation at NyvMarket•ng, strengthening the company's resilience against resource challenges.

Furthermore, NyvMarketing prioritized industry standards and best practices in information security, diligently following ISO/IEC 27002 guidelines. This commitment, driven by excellence and ISO/IEC 27001

requirements, underscored NyvMarketing's dedication to upholding the highest Standards Of information security governance.

While working on the ISMS implementation, NyvMarketing opted to exclude one Of the requirements related to competence (as stipulated in ISO/IEC 27001, Clause 7.2). The company believed that its existing

workforce possessed the necessary competence to fulfill ISMS•related tasks_ However, it did not provide a valid justification for this omission. Moreover. when specific controls from Annex A Of ISO/IEC 27001

were not implemented. NyvMarketing neglected to provide an acceptable justification for these exclusions.

During the ISMS implementation, NFMMarketing thoroughly assessed vulnerabilities that could affect its information Security These vulnerabilities included insufficient maintenance and faulty installation Of

storage media, insufficient periodic replacement schemes for equipment, Inadequate software testing. and unprotected communication lines. Recognizing that these vulnerabilities could pose risks to its data

security. NBMarketing took steps to address these specific weaknesses by implementing the necessary controls and countermeasures-

Based on the scenario above, answer the following question.

In the scenario 2. NyvMarketing faced the threat of insufficient resources during the ISMS implementation. In which of the following categories does this threat fall?

According to scenario 2, did NyvMarketing take actions that comply with ISO/IEC 27001 regarding the implementation of Annex A controls?

- A. Yes, NyvMarketing's actions taken during the implementation of Annex A controls comply with ISO/IEC 27001
- B. No, NyvMarketing's actions did not comply with ISO/IEC 27001 since it excluded one of the Annex A controls without providing justifications
- C. No, NyvMarketing's actions did not comply with ISO/IEC 27001 since it should have included all the Annex A controls
- D. Yes, because ISO/IEC 27002 allows for exclusions

Answer: B

Question: 221

Scenario 2: NyvMarketing is a marketing firm that provides different services to clients across various industries. With expertise in digital marketing, branding, and market research, NyvMarketing has built a solid

reputation for delivering innovative and impactful marketing campaigns. With the growing Significance Of data Security and information protection within the marketing landscape, the company decided to implement an ISMS based on 27001.

While implementing its ISMS NyvMarketing encountered a significant challenge; the threat of insufficient resources, This challenge posed a risk to effectively executing its ISMS objectives and could potentially

undermine the company'S efforts to safeguard Sensitive information. TO address this threat, NyvMarketing adopted a proactive approach by appointing Michael to manage the risks related to resource Constraints.

Michael was pivotal in identifying and addressing resource gaps, strategizing risk mitigation, and allocating resources effectively for ISMS implementation at NyvMarket•ng, strengthening the company's resilience against resource challenges.

Furthermore, NyvMarketing prioritized industry standards and best practices in information security, diligently following ISO/IEC 27002 guidelines. This commitment, driven by excellence and ISO/IEC 27001

requirements, underscored NyvMarketing's dedication to upholding the h•ghest Standards Of information security governance.

While working on the ISMS implementation, NyvMarketing opted to exclude one Of the requirements related to competence (as stipulated in ISO/IEC 27001, Clause 7.2). The company believed that its existing

workforce possessed the necessary competence to fulfill ISMS•telated tasks_ However, it did not provide a valid justification for this omission. Moreover, when specific controls from Annex A Of ISO/IEC 27001

were not implemented, NyvMarketing neglected to provide an acceptable justification for these exclusions.

During the ISMS implementation, NFMmarketing thoroughly assessed vulnerabilities that could affect its information Security These vulnerabilities included insufficient maintenance and faulty installation Of

storage media, insufficient periodic replacement schemes for equipment, Inadequate software testing, and unprotected communication lines. Recognizing that these vulnerabilities could pose risks to its data

security, NBMmarketing took steps to address these specific weaknesses by implementing the necessary controls and countermeasures-

Based on the scenario above, answer the following question.

In the scenario 2, NyvMarketing faced the threat of insufficient resources during the ISMS implementation. In which of the following categories does this threat fall?

Which of the following categories of vulnerabilities did NyvMarketing address during its ISMS implementation? Refer to scenario 2.

- A. Network, personnel, and site vulnerabilities
- B. Organizational and site vulnerabilities
- C. Hardware, software, and network vulnerabilities
- D. Physical and administrative vulnerabilities

Answer: C

Question: 222

A tech company rapidly expanded its operations over the past few years. Its information system, consisting of servers, databases, and communication tools, is a critical part of its daily operations. However, due to rapid growth and increased data flow, the company is now facing a saturation of its information system. This saturation has led to slower response times, increased downtime, and difficulty in managing the overwhelming volume of data.

a. In which category does this threat fall into?

- A. Infrastructure failures
- B. Technical failures
- C. Compromise of functions

Answer: B

Question: 223

What category of decision-making does the implementation of an ISMS belong to within an organization's framework?

- A. Tactical
- B. Operational
- C. Strategic

Answer: C

Question: 224

Which of the following standards provides the requirements and guidelines for establishing a privacy information management system (PIMS)?

- A. ISO/IEC 27701
- B. ISO/IEC 27009
- C. ISO/IEC 27011

Answer: A

Question: 225

An employee at Reyae Ltd. unintentionally sent an email containing critical business strategies to a competitor due to an autofill email suggestion error. The email included proprietary trade secrets and confidential client data

a. Upon receiving the email, the competitor altered the information and attempted to use it to mislead clients into switching services. Which of the following statements correctly describes the security principles affected in this situation?

- A. Reyae Ltd.'s confidentiality was compromised first, while the competitor's actions led to an integrity violation
- B. Reyae Ltd.'s integrity was compromised first, while the competitor's actions led to an availability violation
- C. Reyae Ltd.'s availability was compromised first, while the competitor's actions led to an integrity violation

Answer: A

Question: 226

According to ISO/IEC 27000, which of the following best describes the possible scope of a management system?

- A. It should cover the entire organization without exceptions
- B. It can vary to include the entire organization or specific sections, depending on the needs
- C. It is limited to IT infrastructure and cannot include non-technical departments

Answer: B

Question: 227

Scenario 3: Auto Tsaab, a Swedish Car manufacturer founded in and headquartered in Sweden, is well-known for its innovation in the automotive industry. Despite this strong reputation, the company has faced considerable challenges managing its documented information. Although manual methods of handling this information may have been sufficient in the past, they now pose substantial challenges, particularly in efficiency, accuracy, and scalability. Moreover, entrusting the responsibility of managing documented information to a single individual creates a critical vulnerability, introducing a potential single point of failure within the organization's information management system. To address these challenges and reinforce its commitment to protecting information assets, Auto Tsaab implemented an information security management system ISMS aligned with ISO/IEC 27001. This move was critical in ensuring the security, confidentiality, and integrity of the company's information, particularly as it transitioned from manual to automated information management methods. Initially, Auto Tsaab established automated checking systems that detect and correct corruption. By implementing these automated checks, Auto Tsaab not only improved its ability to maintain data accuracy and consistency but also significantly reduced the risk of undetected errors. Central to Auto ISMS are documented processes. By documenting essential aspects and processes such as the ISMS scope, information security policy, operational planning and control, information security risk assessment, internal audit, and management review, Auto Tsaab ensured that these documents were readily available and adequately protected. Moreover, Auto Tsaab utilizes a comprehensive framework incorporating 36 distinct categories spanning products, services, hardware, and software. This framework, organized in a two-dimensional matrix with six rows and six columns, facilitates the specification of technical details for components and assemblies in its small automobiles, underscoring the company's commitment to innovation and quality. To maintain the industry standards, Auto Tsaab follows rigorous protocols in personnel selection, guaranteeing that every team member is not only eligible but also well-suited for their respective roles within the organization. Additionally, the company established formal procedures for handling policy violations and appointed an internal consultant to continuously enhance its documentation and security practices. After committing to ISO/IEC 27001 adherence, was the documented information in Auto Tsaab's information security management system managed in compliance with the standard?

- A. Yes, the company relied only on manual methods for managing documented information
- B. Yes, the company ensured that documented information was available and protected as needed
- C. Yes, the company delegated the responsibility of managing documented information to a single individual

Answer: B

Question: 228

Scenario 3: Auto Tsaab, a Swedish Car manufacturer founded in and headquartered in Sweden, is well-known for its innovation in the automotive industry. Despite this strong reputation, the company has faced considerable challenges managing its documented information. Although manual methods of handling this information may have been sufficient in the past, they now pose substantial challenges, particularly in efficiency, accuracy, and scalability. Moreover, entrusting the responsibility of managing documented information to a single individual creates a critical vulnerability, introducing a potential single point of failure within the organization's information management system. To address these challenges and reinforce its commitment to protecting information assets, Auto Tsaab implemented an information security management system ISMS aligned with ISO/IEC 27001. This move was critical in ensuring the security, confidentiality, and integrity of the company's information, particularly as it transitioned from manual to automated information management methods. Initially, Auto Tsaab established automated checking systems that detect and correct corruption. By implementing these automated checks, Auto Tsaab not only improved its ability to maintain data accuracy and consistency but also significantly reduced the risk of undetected errors. Central to Auto ISMS are documented processes. By documenting essential aspects and processes such as the ISMS scope, information security policy, operational planning and control, information security risk assessment, internal audit, and management review, Auto Tsaab ensured that these documents were readily available and adequately protected. Moreover, Auto Tsaab utilizes a comprehensive framework incorporating 36 distinct categories spanning products, services, hardware, and software. This framework, organized in a two-dimensional matrix with six rows and six columns, facilitates the specification of technical details for components and assemblies in its small automobiles, underscoring the company's commitment to innovation and quality. To maintain the industry standards, Auto Tsaab follows rigorous protocols in personnel selection, guaranteeing that every team member is not only eligible but also well-suited for their respective roles within the organization. Additionally, the company established formal procedures for handling policy violations and appointed an internal consultant to continuously enhance its documentation and security practices. According to scenario 3, which security architecture framework does Auto Tsaab utilize?

- A. The Open Group Architecture
- B. Open Security
- C. Zachman

Answer: C

Question: 229

Scenario 3: Auto Tsaab, a Swedish Car manufacturer founded in and headquartered in Sweden, is well-known for its innovation in the automotive industry. Despite this strong reputation, the

company has faced considerable challenges managing its documented information. Although manual methods of handling this information may have been sufficient in the past, they now pose substantial challenges, particularly in efficiency, accuracy, and scalability. Moreover, entrusting the responsibility of managing documented information to a single individual creates a critical vulnerability, introducing a potential single point of failure within the organization's information management system. To address these challenges and reinforce its commitment to protecting information assets, Auto Tsaab implemented an information security management system ISMS aligned with ISO/IEC 27001. This move was critical in ensuring the security, confidentiality, and integrity of the company's information, particularly as it transitioned from manual to automated information management methods. Initially, Auto Tsaab established automated checking systems that detect and correct corruption. By implementing these automated checks, Auto Tsaab not only improved its ability to maintain data accuracy and consistency but also significantly reduced the risk of undetected errors. Central to Auto ISMS are documented processes. By documenting essential aspects and processes such as the ISMS scope, information security policy, operational planning and control, information security risk assessment, internal audit, and management review, Auto Tsaab ensured that these documents were readily available and adequately protected. Moreover, Auto Tsaab utilizes a comprehensive framework incorporating 36 distinct categories spanning products, services, hardware, and software. This framework, organized in a two-dimensional matrix with six rows and six columns, facilitates the specification of technical details for components and assemblies in its small automobiles, underscoring the company's commitment to innovation and quality. To maintain the industry standards, Auto Tsaab follows rigorous protocols in personnel selection, guaranteeing that every team member is not only eligible but also well-suited for their respective roles within the organization. Additionally, the company established formal procedures for handling policy violations and appointed an internal consultant to continuously enhance its documentation and security practices. Based on scenario 3, which control of Annex A does Auto Tsaab apply in the personnel selection process?

- A. Annex A 6.4 Disciplinary process
- B. Annex A 6.1 Screening
- C. Annex A 6.3 Information Security awareness, education, and training

Answer: B

Question: 230

Scenario 3: Auto Tsaab, a Swedish Car manufacturer founded in and headquartered in Sweden, is well-known for its innovation in the automotive industry. Despite this strong reputation, the

company has faced considerable challenges managing its documented information. Although manual methods of handling this information may have been sufficient in the past, they now pose substantial challenges, particularly in efficiency, accuracy, and scalability. Moreover, entrusting the responsibility of managing documented information to a single individual creates a critical vulnerability, introducing a potential single point of failure within the organization's information management system. To address these challenges and reinforce its commitment to protecting information assets, Auto Tsaab implemented an information security management system ISMS aligned with ISO/IEC 27001. This move was critical in ensuring the security, confidentiality, and integrity of the company's information, particularly as it transitioned from manual to automated information management methods. Initially, Auto Tsaab established automated checking systems that detect and correct corruption. By implementing these automated checks, Auto Tsaab not only improved its ability to maintain data accuracy and consistency but also significantly reduced the risk of undetected errors. Central to Auto ISMS are documented processes. By documenting essential aspects and processes such as the ISMS scope, information security policy, operational planning and control, information security risk assessment, internal audit, and management review, Auto Tsaab ensured that these documents were readily available and adequately protected. Moreover, Auto Tsaab utilizes a comprehensive framework incorporating 36 distinct categories spanning products, services, hardware, and software. This framework, organized in a two-dimensional matrix with six rows and six columns, facilitates the specification of technical details for components and assemblies in its small automobiles, underscoring the company's commitment to innovation and quality. To maintain the industry standards, Auto Tsaab follows rigorous protocols in personnel selection, guaranteeing that every team member is not only eligible but also well-suited for their respective roles within the organization. Additionally, the company established formal procedures for handling policy violations and appointed an internal consultant to continuously enhance its documentation and security practices.

Is Auto Tsaab's approach for addressing policy violations and enforcing disciplinary procedures compliant with ISO/IEC 27001? Refer to scenario 3.

- A. Yes, the control is defined according to ISO/IEC 27001
- B. No, the control should be implemented only to define responsibilities for remote working arrangements within the company
- C. No, the control should be implemented to establish communication protocols

Answer: A

Question: 231

What service did Auto Tsaab implement to manage and protect information effectively?

- A. Cryptographic services
- B. Access control services
- C. Integrity services
- D. Backup services

Answer: C

Question: 232

Which control in Annex A of ISO/IEC 27001 requires that the information security requirements shall be identified, specified, and approved when developing or acquiring applications?

- A. A.8.25 Secure development life cycle
- B. A.8.26 Application security requirements
- C. A.8.27 Secure system architecture and engineering principles

Answer: B

Question: 233

Why is an in-depth review crucial for organizations to evaluate their security architecture?

- A. To conduct background checks on potential employees to ensure security compliance
- B. To determine the organization's compliance with financial regulations
- C. To assess whether security requirements based on industry best practices can be met
- D. To meet shareholder expectations

Answer: C

Question: 234

A tech company has implemented a security measure to confirm the secure removal or overwriting of sensitive data and licensed software on equipment before disposal or reuse. What type of security control was implemented?

- A. Physical control
- B. Technological control
- C. Organizational control

Answer: B

Question: 235

Which of the following steps is necessary to effectively implement information security controls?

- A. Implement security controls before conducting a risk assessment
- B. Establish a schedule for the implementation of each control
- C. Hire an external contractor with cybersecurity expertise

Answer: B

Question: 236

According to ISO/IEC 27001 controls, why should the use of privileged utility programs be restricted and tightly controlled?

- A. To ensure that utility programs are compatible with existing system software
- B. To prevent misuse of utility programs that could override system and application controls
- C. To enable the correlation and analysis of security-related events

Answer: B

Question: 237

Which of the following is categorized under the organizational controls of ISO/IEC 27001?

- A. Annex 5.3 Segregation of duties
- B. Annex 7.6 Working in secure areas
- C. Annex 8.8 Management of technical vulnerabilities

Answer: A

Question: 238

Scenario 4: UX Software, a company specializing in L.JXfUI design. QA and software testing. and mobile application development. recognized the need to improve its information security measures, As such. the

company implemented an ISMS based on ISO/IEC 27001- This strategic move aimed to enhance the confidentiality. availability, and integrity Of information shared internally and externally, aligning with industry standards and best practices.

The integration of ISMS into UX Software's existing processes and ensuring that these processes are adjusted in accordance with the framework of ISMS signified an important milestone. underscoring the

organization'S commitment to information security. UX Software meticulously tailored these procedures to align with the ISMS framework, ensuring they ate contextually and culturally appropriate while avoiding

mismatches. This proactive stance reassured their employees and instilled confidence in their clients, ensuring the protection of sensitive data throughout their operations.

UX Software'S top management took action to define the Scope Of their ISMS to adhere to ISO/IEC 27003 to drive this initiative forward. Sven, a key member Of the top management team at UX Software. assumed

the role of project sponsor. a critical position responsible for ensuring the execution of ISMS implementation with adequate resources. Sven's leadership was pivotal in steering the project towards compliance with

27001, thus elevating the organization's information security posture to the highest level-

In parallel with their dedication to information security. UX Software incorporated the technical specifications Of security controls within the justification section Of their Statement Of Applicability This approach

demonstrated their Commitment to meeting ISO/IEC 27001 requirements and ensured thorough documentation and justification Of Security controls, thereby Strengthening the overall Security framework Of the

organization. Additionally. UX Software established a committee responsible for ensuring the effectiveness of correctrve actions, managing the ISMS documented information, and continually improving the ISMS

while addressing nonconformities.

By implementing an ISMS based on ISO/IEC 27001, UX Software improved its information security and reinforced its position as a reliable partner. This dedication to information security serves as a testament to

UX Software's commitment to delivering high-quality software solutions while safeguarding the interests of its internal stakeholders and valued clients.

When UX Software integrated ISMS into their existing processes, did they adapt those processes to align with the ISMS framework?

A. No, they should have placed all existing processes on hold until the ISMS framework is fully implemented

- B. No, they should have revised all existing processes to match the ISMS framework
- C. Yes, they adjusted their existing processes to fit with the ISMS framework

Answer: C

Question: 239

Scenario 4: UX Software, a company specializing in L.JXfUI design. QA and software testing. and mobile application development. recognized the need to improve its information security measures, As such. the

company implemented an ISMS based on ISO/IEC 27001- This strategic move aimed to enhance the confidentiality. availability, and integrity Of information shared internally and externally, aligning with industry

standards and best practices.

The integration of ISMS into UX Software's existing processes and ensuring that these processes are adjusted in accordance with the framework of ISMS signified an important milestone. underscoring the

organization'S commitment to information security. UX Software meticulously tailored these procedures to align with the ISMS framework, ensuring they ate contextually and culturally appropriate while avoiding

mismatches. This proactive stance reassured their employees and instilled confidence in their clients, ensuring the protection of sensitive data throughout their operations.

UX Software'S top management took action to define the Scope Of their ISMS to adhere to ISO/IEC 27003 to drive this initiative forward. Sven, a key member Of the top management team at UX Software. assumed

the role of project sponsor. a critical position responsible for ensuring the execution of ISMS implementation with adequate resources. Sven's leadership was pivotal in steering the project towards compliance with

27001, thus elevating the organization's information security posture to the highest level-

In parallel with their dedication to information security. UX Software incorporated the technical specifications Of security controls within the justification section Of their Statement Of Applicability This approach

demonstrated their Commitment to meeting ISO/IEC 27001 requirements and ensured thorough documentation and justification Of Security controls, thereby Strengthening the overall Security framework Of the

organization. Additionally. UX Software established a committee responsible for ensuring the effectiveness of correctrve actions, managing the ISMS documented information, and continually improving the ISMS

while addressing nonconformities.

By implementing an ISMS based on ISO/IEC 27001, UX Software improved its information security and reinforced its position as a reliable partner. This dedication to information security serves as a testament to

UX Software's commitment to delivering high-quality software solutions while safeguarding the interests of its internal stakeholders and valued clients.

According to Scenario 4, UX Software decided to use the guidelines of ISO/IEC 27003 to define the

scope of the ISMS. Is the scope defined in accordance with these guidelines?

- A. Yes, they defined the scope according to ISO/IEC 27003
- B. No, they should have followed a multi-step approach involving management representatives and refinement
- C. No, they should have determined the final scope first

Answer: A

Question: 240

Scenario 4: UX Software, a company specializing in L.JXfUI design. QA and software testing. and mobile application development. recognized the need to improve its information security measures, As such. the

company implemented an ISMS based on ISO/IEC 27001- This strategic move aimed to enhance the confidentiality. availability, and integrity Of information shared internally and externally, aligning with industry

standards and best practices.

The integration of ISMS into UX Software's existing processes and ensuring that these processes are adjusted in accordance with the framework of ISMS signified an important milestone. underscoring the

organization'S commitment to information security. UX Software meticulously tailored these procedures to align with the ISMS framework, ensuring they ate contextually and culturally appropriate while avoiding

mismatches. This proactive stance reassured their employees and instilled confidence in their clients, ensuring the protection of sensitive data throughout their operations.

UX Software'S top management took action to define the Scope Of their ISMS to adhere to ISOIEC 27003 to drive this initiative forward. Sven, a key member Of the top management team at UX Software. assumed

the role of project sponsor. a critical position responsible for ensuring the execution of ISMS implementation with adequate resources. Sven's leadership was pivotal in steering the project towards compliance with

27001, thus elevating the organization's information security posture to the highest level-

In parallel with their dedication to information security. UX Software incorporated the technical specifications Of security controls within the justification section Of their Statement Of Applicability This approach

demonstrated their Commitment to meeting ISO/IEC 27001 requirements and ensured thorough documentation and justification Of Security controls, thereby Strengthening the overall Security framework Of the

organization. Additionally. UX Software established a committee responsible for ensuring the effectiveness of correctrve actions, managing the ISMS documented information, and continually improving the ISMS

while addressing nonconformities.

By implementing an ISMS based on ISO/IEC 27001, UX Software improved its information security

and reinforced its position as a reliable partner. This dedication to information security serves as a testament to

UX Software's commitment to delivering high-quality software solutions while safeguarding the interests of its internal stakeholders and valued clients.

Based on scenario 4, the developers of UX Software incorporated the technical specifications of security controls within the justification section of their Statement of Applicability. Is this recommended?

- A. Yes, the technical specifications of security controls must be included within the justification section
- B. No, the justification section should encompass the rationale for the inclusion and exclusion of each security control
- C. No, the justification section should concisely overview previous software projects

Answer: B

Question: 241

Scenario 4: UX Software, a company specializing in L.JXfUI design. QA and software testing. and mobile application development. recognized the need to improve its information security measures, As such. the

company implemented an ISMS based on ISO/IEC 27001- This strategic move aimed to enhance the confidentiality. availability, and integrity Of information shared internally and externally, aligning with industry

standards and best practices.

The integration of ISMS into UX Software's existing processes and ensuring that these processes are adjusted in accordance with the framework of ISMS signified an important milestone. underscoring the

organization'S commitment to information security. UX Software meticulously tailored these procedures to align with the ISMS framework, ensuring they ate contextually and culturally appropriate while avoiding

mismatches. This proactive stance reassured their employees and instilled confidence in their clients, ensuring the protection of sensitive data throughout their operations.

UX Software'S top management took action to define the Scope Of their ISMS to adhere to ISO/IEC 27003 to drive this initiative forward. Sven, a key member Of the top management team at UX Software. assumed

the role of project sponsor. a critical position responsible for ensuring the execution of ISMS implementation with adequate resources. Sven's leadership was pivotal in steering the project towards compliance with

27001, thus elevating the organization's information security posture to the highest level-

In parallel with their dedication to information security. UX Software incorporated the technical specifications Of security controls within the justification section Of their Statement Of Applicability

This approach

demonstrated their Commitment to meeting ISO/IEC 27001 requirements and ensured thorough

documentation and justification Of Security controls, thereby Strengthening the overall Security framework Of the organization. Additionally. UX Software established a committee responsible for ensuring the effectiveness of correctrve actions, managing the ISMS documented information, and continually improving the ISMS while addressing nonconformities.

By implementing an ISMS based on ISO/IEC 27001, UX Software improved its information security and reinforced its position as a reliable partner. This dedication to information security serves as a testament to

UX Software's commitment to delivering high-quality software solutions while safeguarding the interests of its internal stakeholders and valued clients.

According to scenario 4, what is the role of Sven in the UX Software?

- A. ISMS project manager
- B. ISMS project champion
- C. Member of the project team

Answer: B

Question: 242

Scenario 4: UX Software, a company specializing in L.JXfUI design. QA and software testing. and mobile application development. recognized the need to improve its information security measures, As such. the

company implemented an ISMS based on ISO/IEC 27001- This strategic move aimed to enhance the confidentiality. availability, and integrity Of information shared internally and externally, aligning with industry standards and best practices.

The integration of ISMS into UX Software's existing processes and ensuring that these processes are adjusted in accordance with the framework of ISMS signified an important milestone. underscoring the

organization'S commitment to information security. UX Software meticulously tailored these procedures to align with the ISMS framework, ensuring they ate contextually and culturally appropriate while avoiding

mismatches. This proactive stance reassured their employees and instilled confidence in their clients, ensuring the protection of sensitive data throughout their operations.

UX Software'S top management took action to define the Scope Of their ISMS to adhere to ISOfIEC 27003 to drive this initiative forward. Sven, a key member Of the top management team at UX Software. assumed

the role of project sponsor. a critical position responsible for ensuring the execution of ISMS implementation with adequate resources. Sven's leadership was pivotal in steering the project towards compliance with

27001, thus elevating the organization's information security posture to the highest level-

In parallel with their dedication to information security. UX Software incorporated the technical

specifications Of security controls within the justification section Of their Statement Of Applicability
This approach

demonstrated their Commitment to meeting ISO/IEC 27001 requirements and ensured thorough documentation and justification Of Security controls, thereby Strengthening the overall Security framework Of the

organization. Additionally. UX Software established a committee responsible for ensuring the effectiveness of correctrve actions, managing the ISMS documented information, and continually improving the ISMS

while addressing nonconformities.

By implementing an ISMS based on ISO/IEC 27001, UX Software improved its information security and reinforced its position as a reliable partner. This dedication to information security serves as a testament to

UX Software's commitment to delivering high-quality software solutions while safeguarding the interests of its internal stakeholders and valued clients.

Based on scenario 4, which of the following committees did UX Software establish?

- A. Information security committee
- B. Steering committee
- C. Operational committee

Answer: B

Question: 243

Has Bytes determined all the relevant factors that impact its ability to achieve the intended outcomes of its ISMS, in accordance with clause 4.1 "Understanding the organization and its context" of ISO/IEC 27001?

- A. No, the company did not determine which requirements of interested parties will be addressed through the ISMS
- B. Yes, the company determined all the relevant issues to its purpose that affect its ability to achieve the intended outcomes
- C. No, the company did not determine whether climate change is a relevant issue

Answer: B

Question: 244

Scenario 5: Bytes iS a dynamic and innovative Company specializing in the design, manufacturing. and distribution Of hardware and software, with a focus On providing comprehensive network and supporting

services. It is headquartered in the vibrant tech hub of Lagos, Nigeri

a. It has a diverse and dedicated team, boasting a workforce of over 800 employees who are passionate about delivering cutting-edge solutions

to their Clients. Given the nature Of its business. Bytes frequently handles sensitive data both internally and When collaborating With Clients and partners.

Recognizing the Challenges inherent in securely sharing data with clients. partners, and within its own internal operations. Bytes has implemented robust information security measures, They utilize a defined risk

assessment process, which enables them to assess and address potential threats and information security risks. This process ensures compliance with ISO/IEC 27001 requirements, a critical aspect of Bytes'

operations.

Initially. Bytes identified both external and internal issues that are relevant to its purpose and that impact its ability to achieve the intended information security management System Outcomes, External issues

beyond the company's control include factors Such as social and Cultural dynamics, political. legal. normative, and regulatory environments, financial and macroeconomic conditions. technological developments,

natural factors, and competitive pressures. Internal issues, which are within the organization's control, encompass aspects like the company's culture. its policies, objectives, and strategies; governance structures.

roles, and responsibilities: adopted standards and guidelines; contractual relationships that influence processes within the ISMS scope: processes and procedures resources and knowledge capabilities; physical

infrastructure information systems. information flows. and decision-making processes; as well as the results of previous audits and risk assessments. Bytes also focused on identifying the interested parties

relevant to the ISMS understanding their requirements, and determining which Of those requirements will be addressed by the ISMS

In pursuing a secure digital environment, Bytes leverages the latest technology, utilizing automated vulnerability scanning tools to identify known vulnerable services in their ICT systems. This proactive approach

ensures that potential weaknesses are swiftly addressed. bolstering their overall information security posture. In their comprehensive approach to information security, Bytes has identified and assessed various

risks. During this process, despite implementing the security controls, Bytes' expert team identified unacceptable residual risks, and the team Currently faces uncertainty regarding which specific options to for

addressing these identified and unacceptable residual risks.

According to Scenario 5, which type of policy did Bytes formulate?

A. High-level specific policies

B. High-level general policies

C. Topic-specific policies

Answer: B

Question: 245

Based on scenario 5, did Bytes meet the criteria when selecting the risk assessment methodology?
 Scenario 5: Bytes is a dynamic and innovative Company specializing in the design, manufacturing, and distribution Of hardware and software, with a focus On providing comprehensive network and supporting

services. It is headquartered in the vibrant tech hub of Lagos, Nigeri

a. It has a diverse and dedicated team, boasting a workforce of over 800 employees who are passionate about delivering cutting-edge solutions

to their Clients. Given the nati-jte Of its business. Bytes frequently handles sensitive data both internally and When collaborating With Clients and partners.

Recognizing the Challenges inherent in securely sharing data with clients. partners, and within its own internal operations. Bytes has implemented robust information security measures, They utilize a defined risk

assessment process, which enables them to assess and address potential threats and information security risks. This process ensures compliance with ISO/IEC 27001 requirements, a critical aspect of Bytes'

operations.

Initially. Bytes identified both external and internal issues that are relevant to its purpose and that impact its ability to achieve the intended information security management System Outcomes,

External issues

beyond the company'S control include factors Such as social and Cultural dynamics, political. legal. normative, and regulatory environments, financial and macroeconomic conditions. technological developments,

natural factors, and competitive pressures. Internal issues, which are within the organization's control, encompass aspects like the company's culture. its policies, objectives, and strategies; govetnance structures.

roles, and responsibilities: adopted standards and guidelines; contractual relationships that influence processes within the ISMS scope: processes and procedures resources and knowledge capabilities; physical

infrastructure information systems. information flows. and decisiornaking processes; as well as the results of previous audits and risk assessments. Bytes also focused on identifying the interested parties

relevant to the ISMS understanding their requirements, and determining which Of those requirements will be addressed by the ISMS

In pursuing a secure digital environment, Bytes leverages the latest technology, utilizing automated vulnerability scanning tools to identify known vulnerable services in their ICT systems. This proactive approach

ensures that potential weaknesses are swiftly addressed. bolstering their overall information security posture. In their comprehensive approach to information security, Bytes has identified and assessed various

risks. During this process, despite implementing the security controls, Bytes' expert team identified unacceptable residual risks, and the team Currently faces uncertainty regarding which specific options to for

addressing these identified and unacceptable residual risks.

A. No, because Bytes selected a method developed in-house

B. Yes, since the risk assessment methodology complied with the ISO/IEC 27001 requirements

C. No, Bytes did not consult with external stakeholders or subject matter experts when selecting the risk assessment methodology

Answer: B

Question: 246

Scenario 5: Bytes is a dynamic and innovative Company specializing in the design, manufacturing, and distribution Of hardware and software, with a focus On providing comprehensive network and supporting

services. It is headquartered in the vibrant tech hub of Lagos, Nigeri

a. It has a diverse and dedicated team, boasting a workforce of over 800 employees who are passionate about delivering cutting-edge solutions

to their Clients. Given the nature Of its business. Bytes frequently handles sensitive data both internally and When collaborating With Clients and partners.

Recognizing the Challenges inherent in securely sharing data with clients. partners, and within its own internal operations. Bytes has implemented robust information security measures, They utilize a defined risk

assessment process, which enables them to assess and address potential threats and information security risks. This process ensures compliance with ISO/IEC 27001 requirements, a critical aspect of Bytes' operations.

Initially. Bytes identified both external and internal issues that are relevant to its purpose and that impact its ability to achieve the intended information security management System Outcomes, External issues

beyond the company's control include factors Such as social and Cultural dynamics, political. legal. normative, and regulatory environments, financial and macroeconomic conditions. technological developments,

natural factors, and competitive pressures. Internal issues, which are within the organization's control, encompass aspects like the company's culture. its policies, objectives, and strategies; governance structures.

roles, and responsibilities: adopted standards and guidelines; contractual relationships that influence processes within the ISMS scope: processes and procedures resources and knowledge capabilities; physical

infrastructure information systems. information flows. and decision-making processes; as well as the results of previous audits and risk assessments. Bytes also focused on identifying the interested parties

relevant to the ISMS understanding their requirements, and determining which Of those requirements will be addressed by the ISMS

In pursuing a secure digital environment, Bytes leverages the latest technology, utilizing automated vulnerability scanning tools to identify known vulnerable services in their ICT systems. This proactive approach

ensures that potential weaknesses are swiftly addressed. bolstering their overall information security posture. In their comprehensive approach to information security, Bytes has identified and assessed various

risks. During this process, despite implementing the security controls, Bytes' expert team identified unacceptable residual risks, and the team Currently faces uncertainty regarding which specific options to for

addressing these identified and unacceptable residual risks.

According to scenario 5, what should Bytes consider when assessing the security of its ICT systems?

- A. The skills and expertise of the IT team responsible for assessing the ICT systems
- B. The cost of the tools they used when assessing the security of their ICT systems
- C. The tools they used may produce false positives due to a lack of environmental context

Answer: C

Question: 247

Scenario 5: Bytes is a dynamic and innovative Company specializing in the design, manufacturing, and distribution Of hardware and software, with a focus On providing comprehensive network and supporting

services. It is headquartered in the vibrant tech hub of Lagos, Nigeri

a. It has a diverse and dedicated team, boasting a workforce of over 800 employees who are passionate about delivering cutting-edge solutions

to their Clients. Given the nati-jte Of its business. Bytes frequently handles sensitive data both internally and When collaborating With Clients and partners.

Recognizing the Challenges inherent in securely sharing data with clients. partners, and within its own internal operations. Bytes has implemented robust information security measures, They utilize a defined risk

assessment process, which enables them to assess and address potential threats and information security risks. This process ensures compliance with ISO/IEC 27001 requirements, a critical aspect of Bytes' operations.

Initially. Bytes identified both external and internal issues that are relevant to its purpose and that impact its ability to achieve the intended information security management System Outcomes, External issues

beyond the company'S control include factors Such as social and Cultural dynamics, political. legal. normative, and regulatory environments, financial and macroeconomic conditions. technological developments,

natural factors, and competitive pressures. Internal issues, which are within the organization's control, encompass aspects like the company's culture. its policies, objectives, and strategies; govtenance structures.

roles, and responsibilities: adopted standards and guidelines; contractual relationships that influence processes within the ISMS scope: processes and procedures resources and knowledge capabilities; physical

infrastructure information systems. information flows. and decisiornaking processes; as well as the results of previous audits and risk assessments. Bytes also focused on identifying the interested parties

relevant to the ISMS understanding their requirements, and determining which Of those

requirements will be addressed by the ISMS

In pursuing a secure digital environment, Bytes leverages the latest technology, utilizing automated vulnerability scanning tools to identify known vulnerable services in their ICT systems. This proactive approach

ensures that potential weaknesses are swiftly addressed, bolstering their overall information security posture. In their comprehensive approach to information security, Bytes has identified and assessed various

risks. During this process, despite implementing the security controls, Bytes' expert team identified unacceptable residual risks, and the team Currently faces uncertainty regarding which specific options to for

addressing these identified and unacceptable residual risks.

Based on scenario 5, certain residual risks were defined as unacceptable. Which risk treatment options should Bytes consider?

- A. Bytes should terminate the affected projects immediately
- B. Bytes should identify alternative risk treatment options
- C. Bytes should suspend all operations until risks are fully eliminated

Answer: B

Question: 248

Which statement regarding organizational roles, responsibilities, and authorities is NOT correct?

- A. Top management is responsible for reporting on the performance of the ISMS and cannot assign this responsibility to someone else
- B. A project manager can have information security responsibilities as well
- C. Top management must assign the responsibility for ensuring that the ISMS conforms to ISO/IEC 27001

Answer: A

Question: 249

What is the first phase in the information security policy development life cycle?

- A. Policy construction
- B. Policy implementation
- C. Risk assessment
- D. Policy planning / Needs assessment

Answer: D

Question: 250

Which of the following would be an acceptable justification for excluding the Annex A 6.1 Screening control?

- A. The organization considers background verification checks unnecessary for its operations
- B. A collective agreement with employees prohibits security checks
- C. The organization voluntarily performs comprehensive criminal background checks on all employees

Answer: B

Question: 251

What is the primary purpose of risk analysis?

- A. To comprehend the nature of risk and determine its level
- B. To implement risk treatment measures
- C. To assess vulnerabilities and determine their source

Answer: A

Question: 252

Which of the following statements is correct regarding the methodology for managing the implementation of an ISMS?

- A. Organizations must strictly follow a specific methodology to meet the minimum requirements
- B. The sequence of steps must remain fixed throughout the ISMS implementation
- C. Organizations can adapt the methodology to their specific context, and steps can be modified as needed

Answer: C

Question: 253

How does the Statement of Applicability (SoA) contribute to the certification audit process?

- A. It provides a comprehensive overview of security incidents for external auditors
- B. It provides a reference for external auditors, listing pertinent controls relevant to the ISMS
- C. It provides a checklist for top management to ensure the implementation of relevant controls to the ISMS

Answer: B

Question: 254

A manufacturing company faced a risk of production delays due to potential supply chain disruptions. After assessing the potential impact of the risk, the company decided to accept the risk, considering the disruption unlikely to significantly affect its operations. Which risk treatment option did the company select in this case?

- A. Risk avoidance
- B. Risk retention
- C. Risk deflection

Answer: B

Question: 255

Which factor should be considered when estimating the consequences of a security event?

- A. Probability of
- B. Severity of the consequence
- C. Length of the event

Answer: B

Question: 256

Scenario 6: CB Consulting is a reputable firm based in Dublin, Ireland, providing Strategic business Solutions to diverse clients. With a dedicated team Of professionals, CB Consulting prides itself on its commitment to excellence, integrity, and client satisfaction. CB Consulting started implementing an ISMS aligned with ISO/IEC 27001 as part of its ongoing commitment to enhancing its information security

practices. Throughout this process, ensuring effective communication and adherence to established security protocols is essential.

Sarah, an employee at CB has been appointed as the head Of a new project focused on managing sensitive client data. Additionally, she is responsible for Overseeing activities during the response phase of incident management, including regular reporting to the incident manager of the incident management team and keeping key stakeholders informed. Meanwhile, CB Consulting has reassigned Tom to serve as the company's legal consultant.

CB Consulting has also reassigned Clare, formerly an IT security analyst, as their information security officer to oversee the implementation Of the ISMS and ensure compliance with ISO/IEC 27001.

Clare's primary

responsibility is to conduct regular risk assessments, identify potential vulnerabilities, and implement appropriate Security measures to mitigate risks effectively. Clare has established a procedure Stating that

information security risk assessments are conducted only when significant changes occur, playing a crucial role in strengthening the company's security posture and safeguarding against potential threats.

To ensure it has a Competent workforce to meet information security Objectives, CB Consulting has implemented a process to and verify that all employees, including Sarah, Tom, and Clare, possess the necessary competence based on their education, training, or experience. Where gaps were identified, the company has taken specific actions such as providing additional training and mentoring. Additionally, CB

Consulting retains documented information as evidence of the competencies required and acquired.

CB Consulting has established a robust communication strategy aligned with industry standards to ensure secure and effective information exchange. It identified the requirements for communication on relevant

issues. First, the company designated specific roles. Such as a public relations officer for external communication and a Security officer for internal matters, to manage sensitive issues like data breaches. Then,

communication triggers, content, and recipients were carefully defined, with messages pre-approved by management where necessary. Lastly, dedicated channels were implemented to ensure the confidentiality

and integrity of transmitted information.

Based on the scenario above, answer the following question.

CB Consulting prioritizes transparent and Substantive communication practices to foster trust, enhance Stakeholder engagement, and reinforce its commitment to information security excellence.

Which principle

of effective communication is emphasized by this approach?

Transparency

CB Consulting prioritizes transparent and substantive communication practices to foster trust, enhance stakeholder engagement, and reinforce its commitment to information security excellence.

Which principle of effective communication is emphasized by this approach?

- A. Transparency
- B. Clarity
- C. Timeliness

Answer: A

Question: 257

Scenario 6: CB Consulting is a reputable firm based in Dublin, Ireland. providing Strategic business Solutions to diverse clients, With a dedicated team Of professionals, CB Consulting prides itself on its commitment to excellence, integrity, and client satisfaction. CB Consulting started implementing an ISMS aligned with ISO/IEC 27001 as part of its ongoing commitment to enhancing its information security

practices. Throughout this process, ensuring effective communication and adherence to established security protocols is essential.

Sarah, an employee at CB has been appointed as the head Of a new project focused on managing sensitive client data, Additionally, she is responsible for Overseeing activities during the response phase of incident management, including regular reporting to the incident manager of the incident management team and keeping key stakeholders informed. Meanwhile, CB Consulting has reassigned Tom to

serve as the company's legal consultant.

CB Consulting has also reassigned Clare. formerly an IT security analyst, as their information security officer to oversee the implementation Of the ISMS and ensure compliance with ISO/IEC 27001.

Clare's primary

responsibility is to conduct regular risk assessments. identify potential vulnerabilities, and implement appropriate Security measures to mitigate risks effectively. Clare has established a procedure Stating that

information security risk assessments are conducted only when significant changes occur. playing a crucial role in strengthening the company's security posture and safeguarding against potential threats.

To ensure it has a Competent workforce to meet information security Objectives, CB Consulting has implemented a process to and verify that all employees, including Sarah, Tom, and Clare, possess the necessary competence based on their education. training, or experience. Where gaps were identified, the company has taken specific actions such as providing additional training and mentoring. Additionally, CB

Consulting retains documented information as evidence of the competencies required and acquired.

CB Consulting has established a robust communication strategy aligned with industry standards to ensure secure and effective information exchange. It identified the requirements for communication on relevant

issues. First, the company designated specific roles. Such as a public relations officer for external communication and a Security officer for internal matters, to manage sensitive issues like data breaches. Then.

communication triggers, content. and recipients were carefully defined. with messages pre-approved by management where necessary. Lastly, dedicated channels were implemented to ensure the confidentiality

and integrity of transmitted information.

Based on the scenario above, answer the following question.

CB Consulting prioritizes transparent and Substantive communication practices to foster trust, enhance Stakeholder engagement, and reinforce its commitment to information security excellence.

Which principle

of effective communication is emphasized by this approach?

Transparency

Has CB Consulting taken appropriate measures to ensure compliance with ISO/IEC 27001 requirements regarding acquiring necessary competence? Refer to scenario 6.

A. Yes. CB Consulting has taken compliant actions regarding acquiring the necessary competence

B. No, reassigning current employees for tasks directly related to ISMS implementation management is not permissible

C. No, reassigning current employees for tasks related to legal consulting is not permissible

Answer: A

Question: 258

In addition to leading the new project involving sensitive client data, what is Sarah's role within the company? Refer to scenario 6.

Scenario 6: CB Consulting is a reputable firm based in Dublin, Ireland. providing Strategic business Solutions to diverse clients, With a dedicated team Of professionals, CB Consulting prides itself on its commitment to excellence, integrity, and client satisfaction. CB Consulting started implementing an ISMS aligned with ISO/IEC 27001 as part of its ongoing commitment to enhancing its information security

practices. Throughout this process, ensuring effective communication and adherence to established security protocols is essential.

Sarah, an employee at CB has been appointed as the head Of a new project focused on managing sensitive client data, Additionally, she is responsible for Overseeing activities during the response phase of incident management, including regular reporting to the incident manager of the incident management team and keeping key stakeholders informed. Meanwhile, CB Consulting has reassigned Tom to

serve as the company's legal consultant.

CB Consulting has also reassigned Clare. formerly an IT security analyst, as their information security officer to oversee the implementation Of the ISMS and ensure compliance with ISO/IEC 27001.

Clare's primary

responsibility is to conduct regular risk assessments. identify potential vulnerabilities, and implement appropriate Security measures to mitigate risks effectively. Clare has established a procedure Stating that

information security risk assessments are conducted only when significant changes occur. playing a crucial role in strengthening the company's security posture and safeguarding against potential threats.

TO ensure it has a Competent workforce to meet information security Objectives, CB Consulting has implemented a process to and verify that all employees, including Sarah, Tom, and Clare, possess the

necessary competence based on their education, training, or experience. Where gaps were identified, the company has taken specific actions such as providing additional training and mentoring. Additionally, CB

Consulting retains documented information as evidence of the competencies required and acquired. CB Consulting has established a robust communication strategy aligned with industry standards to ensure secure and effective information exchange. It identified the requirements for communication on relevant

issues. First, the company designated specific roles. Such as a public relations officer for external communication and a Security officer for internal matters, to manage sensitive issues like data breaches. Then,

communication triggers, content, and recipients were carefully defined, with messages pre-approved by management where necessary. Lastly, dedicated channels were implemented to ensure the confidentiality

and integrity of transmitted information.

Based on the scenario above, answer the following question.

CB Consulting prioritizes transparent and Substantive communication practices to foster trust, enhance Stakeholder engagement, and reinforce its commitment to information security excellence.

Which principle

of effective communication is emphasized by this approach?

Transparency

A. CSIRT

B. Incident coordinator

C. Incident manager

Answer: B

Question: 259

Scenario 6: CB Consulting is a reputable firm based in Dublin, Ireland, providing Strategic business Solutions to diverse clients. With a dedicated team Of professionals, CB Consulting prides itself on its commitment to excellence, integrity, and client satisfaction. CB Consulting started implementing an ISMS aligned with ISO/IEC 27001 as part of its ongoing commitment to enhancing its information security

practices. Throughout this process, ensuring effective communication and adherence to established security protocols is essential.

Sarah, an employee at CB has been appointed as the head Of a new project focused on managing sensitive client data. Additionally, she is responsible for Overseeing activities during the response phase of incident management, including regular reporting to the incident manager of the incident management team and keeping key stakeholders informed. Meanwhile, CB Consulting has reassigned Tom to

serve as the company's legal consultant.

CB Consulting has also reassigned Clare, formerly an IT security analyst, as their information security officer to oversee the implementation Of the ISMS and ensure compliance with ISO/IEC 27001.

Clare's primary

responsibility is to conduct regular risk assessments. identify potential vulnerabilities, and implement appropriate Security measures to mitigate risks effectively. Clare has established a procedure Stating that information security risk assessments are conducted only when significant changes occur. playing a crucial role in strengthening the companys security posture and safeguarding against potential threats.

TO ensure it has a Competent workforce to meet information security Objectives, CB Consulting has implemented a process to and verify that all employees, including Sarah, Tom, and Clare, possess the necessary competence based on their education. training, or experience. Where gaps were identified, the company has taken specific actions such as providing additional training and mentoring. Additionally, CB

Consulting retains documented information as evidence of the competencies requ. red and acquired.

CB Consulting has established a robust communication strategy aligned with industry standards to ensure secure and effective information exchange. It identified the requirements for communication on relevant

issues. First, the company designated specific toles. Such as a public relations officer for external communication and a Security officer for internal matters, to manage sensitive issues like data breaches. Then.

communication triggers, content. and recipients were carefully defined. with messages pre-approved by management where necessary. Lastly, dedicated channels were implemented to ensure the confidentiality

and integrity of transmitted information.

Based on the scenario above, answer the following question.

CB Consulting prioritizes transparent and Substantive communication practices to foster trust, enhance Stakeholder engagement, and reinforce its commitment to information security excellence.

Which principle

of effective communication is emphasized by this approach?

Transparency

Based on scenario 6, Clare has established a procedure stating that information security risk assessments are conducted only when significant changes occur. Is the frequency of risk assessments determined correctly?

- A. No, she should perform risk assessments quarterly per ISO/IEC 27001 requirements
- B. No, she should perform risk assessments annually, as mandated by regulatory authorities
- C. No, the company must conduct risk assessments at planned intervals

Answer: C

Question: 260

Scenario 6: CB Consulting is a reputable firm based in Dublin, Ireland. providing Strategic business Solutions to diverse clients, With a dedicated team Of professionals, CB Consulting prides itself on its commitment to excellence, integrity, and client satisfaction. CB Consulting started implementing an ISMS aligned with ISO/IEC 27001 as part of its ongoing commitment to enhancing its information

security

practices. Throughout this process, ensuring effective communication and adherence to established security protocols is essential.

Sarah, an employee at CB has been appointed as the head of a new project focused on managing sensitive client data. Additionally, she is responsible for overseeing activities during the response phase of incident management, including regular reporting to the incident manager of the incident management team and keeping key stakeholders informed. Meanwhile, CB Consulting has reassigned Tom to

serve as the company's legal consultant.

CB Consulting has also reassigned Clare, formerly an IT security analyst, as their information security officer to oversee the implementation of the ISMS and ensure compliance with ISO/IEC 27001.

Clare's primary

responsibility is to conduct regular risk assessments, identify potential vulnerabilities, and implement appropriate security measures to mitigate risks effectively. Clare has established a procedure stating that

information security risk assessments are conducted only when significant changes occur, playing a crucial role in strengthening the company's security posture and safeguarding against potential threats.

To ensure it has a competent workforce to meet information security objectives, CB Consulting has implemented a process to assess and verify that all employees, including Sarah, Tom, and Clare, possess the necessary competence based on their education, training, or experience. Where gaps were identified, the company has taken specific actions such as providing additional training and mentoring. Additionally, CB

Consulting retains documented information as evidence of the competencies required and acquired. CB Consulting has established a robust communication strategy aligned with industry standards to ensure secure and effective information exchange. It identified the requirements for communication on relevant

issues. First, the company designated specific roles. Such as a public relations officer for external communication and a security officer for internal matters, to manage sensitive issues like data breaches. Then,

communication triggers, content, and recipients were carefully defined, with messages pre-approved by management where necessary. Lastly, dedicated channels were implemented to ensure the confidentiality

and integrity of transmitted information.

Based on the scenario above, answer the following question.

CB Consulting prioritizes transparent and substantive communication practices to foster trust, enhance stakeholder engagement, and reinforce its commitment to information security excellence. Which principle

of effective communication is emphasized by this approach?

Transparency

To what extent did CB Consulting identify the communication requirements for relevant issues according to best practices? Refer to the last paragraph of scenario 6.

- A. The company fully identified all communication requirements in line with best practices
- B. The company missed identifying the intended parties of the communication
- C. The company did not establish a process to ensure messages are sent and properly received

Answer: A

Question: 261

Is Yefund's development of communication protocols acceptable?

- A. Yes, because internal communications are the primary factor influencing information security
- B. Yes, because external communications are not relevant to the ISMS
- C. No, Yefund should have determined internal and external communications

Answer: C

Question: 262

Scenario 7: Yefund, an insurance Company headquartered in Monaco, is a reliable name in Commerce, industry, and Corporate services. With a rich history spanning decades, Yefund has consistently delivered tailored insurance solutions to businesses of all sizes. safeguarding their assets and mitigating risks. As a forward-thinking company, Yetund recognizes the importance of information security in protecting sensitive data and maintaining the trust Of Its clients. Thus, has embarked on a transformative journey towards implemenung an ISMS based on ISO/IEC 27001- iS implementing cutting-edge AI technologies within its ISMS to improve the identification and management Of information assets, Through AI. is automating the identification Of assets. tracking changes over time. and strategically selecting controls based on asset sensitivity and exposure. This proactive approach ensures that Yefund remains agile and adaptive in safeguarding critical information assets against emerging threats. Although Yetund recognized the urgent need to enhance its security posture, the implementation team took a gradual approach to integrate each ISMS element- Rather than waiting for an official launch, they carefully tested and validated security controls, gradually putting each element into operational mode as it was completed and approved. This methodical process ensured that critical security measures, such as encryption protocols. access controls. and monitoring systems. were fully operational and effective in safeguarding customer information, including personal. policy, and financial details. Recently. Kian. a member of Vefund's information security team. identified two security events. Upon evaluation. one reported incident did not meet the criteria to be classified as such- However, the second incident. involving critical network components experiencing downtime. raised concerns about potential risks to sensitive data security and was therefore categorized as an incident. The first event

was recorded

as a report without further action, whereas the second incident prompted a series of actions, including investigation, containment, eradication, recovery, resolution, closure, incident reporting, and post-incident

activities. Additionally, IRTS were established to address the events according to their Categorization. After the incident, Yefund recognized the development of internal communication protocols as the single need to improve their ISMS framework. It determined the relevance of communication aspects such as

what, when, with whom, and how to communicate effectively. Yefund decided to focus on developing internal communication protocols, reasoning that internal coordination was their most immediate priority. This

decision was made despite having external stakeholders, such as clients and regulatory bodies, who also required secure and timely communication.

Additionally, Yefund has prioritized the professional development of its employees through comprehensive training programs. Yefund assessed the effectiveness and impact of its training initiatives through

Kirkpatrick's four-level training evaluation model. From measuring trainees' involvement and impressions of the training (Level 1) to evaluating learning outcomes (Level 2), post-training behavior (Level 3), and

tangible results (Level 4), Yefund ensures that its training programs are holistic, impactful, and aligned with organizational objectives.

Yefund's journey toward implementing an ISMS reflects a commitment to security, innovation, and continuous improvement. By leveraging technology, fostering a culture of proactive vigilance, enhancing

communication protocols, and investing in employee development, Yefund seeks to fortify its position as a trusted partner in safeguarding the interests of its clients and stakeholders.

According to Scenario 7, is Yefund using AI accordingly to plan the ISMS?

- A. No, AI is not involved in identifying information assets or recognizing potential threats
- B. No, AI assists in ISMS planning by providing sample policies and training materials through virtual assistants
- C. Yes, AI automates the identification of information assets, tracks the changes over time, and selects controls based on asset sensitivity and exposure

Answer: C

Question: 263

Scenario 7: Yefund, an insurance company headquartered in Monaco, is a reliable name in Commerce, industry, and Corporate services. With a rich history spanning decades, Yefund has consistently delivered tailored insurance solutions to businesses of all sizes, safeguarding their assets and mitigating risks. As a forward-thinking company, Yefund recognizes the importance of information security in

protecting

sensitive data and maintaining the trust Of Its clients. Thus, has embarked on a transformative journey towards implemenung an ISMS based on ISO/IEC 27001-

iS implementing cutting-edge AI technologies within its ISMS to improve the identification and management Of information assets, Through AI. is automating the identification Of assets. tracking changes over time. and strategically selecting controls based on asset sensitivity and exposure. This proactive approach ensures that Yefund remains agile and adaptive in safeguarding critical information assets

against emerging threats. Although Yetund recognized the urgent need to enhance its security posture, the implementation team took a gradual approach to integrate each ISMS element- Rather than waiting for

an official launch, they carefully tested and validated security controls, gradually putting each element into operational mode as it was completed and approved. This methodical process ensured that critical

security measures, such as encryption protocols. access controls. and monitoring systems. were fully operational and effective in safeguarding customer information, including personal. policy, and financial details.

Recently. Kian. a member of Vefund's information security team. identified two security events.

Upon evaluation. one reported incident did not meet the criteria to be classified as such- However, the second

incident. involving critical network components experiencing downtime. raised concerns about potential risks to sensitive data security and was therefore categorized as an incident. The first event was recorded

as a report without further action, whereas the second incident prompted a series Of actions, including investigation. containment, eradication, recovery. resolution, closure, incident reporting, and post-incident

activities. Additionally. IRTS were established to address the events according to their Categorization. After the incident. Yetund recognized the development of internal communication protocols as the single need to improve their ISMS framework It determined the relevance of communication aspects such as

what, when, with whom. and how to Communicate effectively Yefund decided to focus On developing internal communication protocols, reasoning that internal coordination their most immediate priority. This

decision was made despite having external stakeholders. such as clients and regulatory bodies. who also required secure and timely communication.

Additionally, Yefund has prioritized the professional development Of its employees through comprehensive training programs, Yefund assessed the effectiveness and impact Of its training initiatives through

Kirkpatrick's four-level training evaluation model. From measuring trainees' involvement and impressions of the training (Level 1) to evaluating learning outcomes (Level 2), post-training behavior (Level 3), and

tangible results (Level 4), Yefund ensures that Its training programs ate holistic. impactful. and aligned With organizational objectives.

Yefund•s journey toward implementing an ISMS reflects a commitment to security, innovation, and continuous improvement, By leveraging technology, fostering a culture Of proactive vigilance, enhancing

communication ptotOCOIS, and investing in employee development. Yefund seeks to fortify its

position as a trusted partner in safeguarding the interests Of its Clients and stakeholders.

Based on scenario 7, is Yefund's integration of ISMS elements acceptable?

- A. No, it is advisable to temporarily delay operational mode until all elements are completed
- B. Yes, ISMS elements can be completed, approved, and put into operational mode gradually
- C. No, it should have activated the ISMS elements to judge their effectiveness and then completed and approved them based on their performance in operational mode

Answer: B

Question: 264

Scenario 7: Yefund, an insurance Company headquartered in Monaco, is a reliable name in Commerce, industry, and Corporate services. With a rich history spanning decades, Yefund has consistently delivered tailored insurance solutions to businesses of all sizes. safeguarding their assets and mitigating risks. As a forward-thinking company, Yetund recognizes the importance of information security in protecting sensitive data and maintaining the trust Of Its clients. Thus, has embarked on a transformative journey towards implemenung an ISMS based on ISO/IEC 27001- iS implementing cutting-edge AI technologies within its ISMS to improve the identification and management Of information assets, Through AI. is automating the identification Of assets. tracking changes over time. and strategically selecting controls based on asset sensitivity and exposure. This proactive approach ensures that Yefund remains agile and adaptive in safeguarding critical information assets against emerging threats. Although Yetund recognized the urgent need to enhance its security posture, the implementation team took a gradual approach to integrate each ISMS element- Rather than waiting for an official launch, they carefully tested and validated security controls, gradually putting each element into operational mode as it was completed and approved. This methodical process ensured that critical security measures, such as encryption protocols. access controls. and monitoring systems. were fully operational and effective in safeguarding customer information, including personal. policy, and financial details. Recently. Kian. a member of Vefund's information security team. identified two security events. Upon evaluation. one reported incident did not meet the criteria to be classified as such- However, the second incident. involving critical network components experiencing downtime. raised concerns about potential risks to sensitive data security and was therefore categorized as an incident. The first event was recorded as a report without further action, whereas the second incident prompted a series Of actions, including investigation. containment, eradication, recovery. resolution, closure, incident reporting,

and post-incident activities. Additionally, IRTS were established to address the events according to their Categorization. After the incident, Yefund recognized the development of internal communication protocols as the single need to improve their ISMS framework. It determined the relevance of communication aspects such as what, when, with whom, and how to Communicate effectively. Yefund decided to focus On developing internal communication protocols, reasoning that internal coordination their most immediate priority. This decision was made despite having external stakeholders, such as clients and regulatory bodies, who also required secure and timely communication. Additionally, Yefund has prioritized the professional development Of its employees through comprehensive training programs, Yefund assessed the effectiveness and impact Of its training initiatives through Kirkpatrick's four-level training evaluation model. From measuring trainees' involvement and impressions of the training (Level 1) to evaluating learning outcomes (Level 2), post-training behavior (Level 3), and tangible results (Level 4), Yefund ensures that Its training programs ate holistic, impactful, and aligned With organizational objectives. Yefund's journey toward implementing an ISMS reflects a commitment to security, innovation, and continuous improvement, By leveraging technology, fostering a culture Of proactive vigilance, enhancing communication ptotOCOIS, and investing in employee development. Yefund seeks to fortify its position as a trusted partner in safeguarding the interests Of its Clients and stakeholders.

Did Yefund handle the identified information security events appropriately? Refer to scenario 7.

- A. Yes, both information security events were effectively addressed
- B. No, because information security events should not be categorized merely as event reports under any circumstances
- C. No, monitoring teams must be established to address the events according to their categorization

Answer: A

Question: 265

Scenario 7: Yefund, an insurance Company headquartered in Monaco, is a reliable name in Commerce, industry, and Corporate services. With a rich history spanning decades, Yefund has consistently delivered tailored insurance solutions to businesses of all sizes, safeguarding their assets and mitigating risks. As a forward-thinking company, Yetund recognizes the importance of information security in protecting sensitive data and maintaining the trust Of Its clients. Thus, has embarked on a transformative journey towards implemenung an ISMS based on ISO/IEC 27001- is implementing cutting-edge AI technologies within its ISMS to improve the identification and

management Of information assets, Through AI. is automating the identification Of assets. tracking changes over time. and strategically selecting controls based on asset sensitivity and exposure. This proactive approach ensures that Yefund remains agile and adaptive in safeguarding critical information assets against emerging threats. Although Yetund recognized the urgent need to enhance its security posture, the implementation team took a gradual approach to integrate each ISMS element- Rather than waiting for an official launch, they carefully tested and validated security controls, gradually putting each element into operational mode as it was completed and approved. This methodical process ensured that critical security measures, such as encryption protocols. access controls. and monitoring systems. were fully operational and effective in safeguarding customer information, including personal. policy, and financial details.

Recently. Kian. a member of Vefund's information security team. identified two security events. Upon evaluation. one reported incident did not meet the criteria to be classified as such- However, the second incident. involving critical network components experiencing downtime. raised concerns about potential risks to sensitive data security and was therefore categorized as an incident. The first event was recorded as a report without further action, whereas the second incident prompted a series Of actions, including investigation. containment, eradication, recovery. resolution, closure, incident reporting, and post-incident activities. Additionally. IRTS were established to address the events according to their Categorization. After the incident. Yetund recognized the development of internal communication protocols as the single need to improve their ISMS framework It determined the relevance of communication aspects such as what, when, with whom. and how to Communicate effectively Yefund decided to focus On developing internal communication protocols, reasoning that internal coordination their most immediate priority. This decision was made despite having external stakeholders. such as clients and regulatory bodies. who also required secure and timely communication.

Additionally, Yefund has prioritized the professional development Of its employees through comprehensive training programs, Yefund assessed the effectiveness and impact Of its training initiatives through Kirkpatrick's four-level training evaluation model. From measuring trainees' involvement and impressions of the training (Level 1) to evaluating learning outcomes (Level 2), post-training behavior (Level 3), and tangible results (Level 4), Yefund ensures that Its training programs ate holistic. impactful. and aligned With organizational objectives.

Yefund•s journey toward implementing an ISMS reflects a commitment to security, innovation, and continuous improvement, By leveraging technology, fostering a culture Of proactive vigilance, enhancing communication ptotOCOIS, and investing in employee development. Yefund seeks to fortify its position as a trusted partner in safeguarding the interests Of its Clients and stakeholders.

According to scenario 7, did Yefund correctly define Level 2 of Kirkpatrick's four-level training evaluation model?

- A. Yes, at this level, Yefund should evaluate the training's learning outcomes by determining what the trainees learned from it
- B. No, at this level, Yefund should measure the trainees' involvement in the training and determine their general impressions of the training
- C. No, at this level, Yefund should evaluate the behavior of trainees after the training

Answer: A

Question: 266

During a security audit, security analysts discover that an attacker has been repeatedly querying a black-box machine learning model to infer whether certain sensitive data points were part of the training dataset. By doing so, the attacker was able to determine if a specific individual's data was used in training. What threat does this attack represent?

- A. Backdoor in the training set
- B. Data poisoning
- C. Membership inference attack

Answer: C

Question: 267

What potential vulnerability in AI systems could be exploited for malicious purposes?

- A. High computational power
- B. Lack of real-time processing capabilities
- C. Adversarial manipulation of data inputs

Answer: C

Question: 268

The IRT has been notified of a potential compromise in the organization's network. Which type of services would be most appropriate for the IRT to provide in this situation?

- A. Proactive services
- B. Reactive services
- C. Security quality management services

Answer: B

Question: 269

Jane is a developer looking to deploy an application she created using a programming language supported by her cloud service provider. She does not need to manage the underlying infrastructure like servers or storage, but needs control over the application and its environment. Which cloud service model does Jane need?

- A. Infrastructure as a Service
- B. Platform as a Service
- C. Software as a Service

Answer: B

Question: 270

Which dashboard did SecureLynx use to report the results of implemented processes and controls?

- A. Operational dashboards
- B. Tactical dashboards
- C. Strategic dashboard

Answer: A

Question: 271

Scenario 8: SecureLynx is one Of the largest cybersecurity advisory and consulting companies that helps private sector organizations prevent security threats. improve security systems. and achieve business

SecureLynr is committed to complying with national and international standards to enhance the company'S resilience and credibility_ SecureLynx has Started implementing an ISMS based on ISO/IEC 27001

as part of its relentless pursuit of security.

As part of the internal audit activities, the top management reviewed and approved the audit objectives to assess the effectiveness of SecureLynx's ISMS. During the audit, the internal auditor evaluated whether

top management supports activities associated with the ISMS and if the roles and responsibilities of relevant parties are clearly defined. This rigorous examination is a testament to SecureLynx's commitment to continuous improvement and alignment of security measures with organizational goals.

SecureLynx employs an innovative dashboard that visually represents implemented processes and controls to ensure transparency and accountability within the organization. This tool offers stakeholders a real-

time overview of security measures, empowering them to make informed decisions and swiftly respond to emerging threats. As part of this initiative, Paula was appointed to a new position entrusted with the

responsibility of collecting, recording, and storing data to measure the effectiveness of the ISMS.

Furthermore, SecureLynx conducts management reviews every six months to ensure its systems are robust and continually improving. These reviews serve as a crucial mechanism for assessing the efficacy of

security measures and identifying areas for enhancement. SecureLynx's dedication to implementing and maintaining a robust ISMS exemplifies its commitment to innovation and client satisfaction.

Based on the scenario above, answer the following question.

According to Scenario 8, did SecureLynx follow the recommended steps when reviewing and approving the internal audit objectives?

- A. No, the internal auditor should review and approve internal audit objectives
- B. No, the information security manager should review and approve internal audit objectives
- C. Yes, the top management should review and approve the internal audit objectives

Answer: C

Question: 272

Scenario 8: SecureLynx is one of the largest cybersecurity advisory and consulting companies that helps private sector organizations prevent security threats, improve security systems, and achieve business

SecureLynx is committed to complying with national and international standards to enhance the company's resilience and credibility. SecureLynx has started implementing an ISMS based on ISO/IEC 27001

as part of its relentless pursuit of security.

As part of the internal audit activities, the top management reviewed and approved the audit objectives to assess the effectiveness of SecureLynx's ISMS. During the audit, the internal auditor evaluated whether

top management supports activities associated with the ISMS and if the roles and responsibilities of relevant parties are clearly defined. This rigorous examination is a testament to SecureLynx's

commitment to continuous improvement and alignment of security measures with organizational goals.

SecureLynx employs an innovative dashboard that visually represents implemented processes and controls to ensure transparency and accountability within the Organization. This tool Offers stakeholders a real-

time overview of security measures. empowering them to make informed decisions and swiftly respond to emerging threats. As part of this initiative, Paula was appointed to a new position entrusted with the

responsibility Of collecting, recording, and Stoting data to measure the effectiveness Of the ISMS-

Furthermore, SecureLynx conducts management reviews every six months to ensure its Systems are robust and continually improving. These reviews serve as a crucial mechanism for assessing the efficacy Of

security measures and identifying areas for enhancement. SecureLynx's dedication to implementing and maintaining a robust ISMS exemplifies its commitment to innovation and Client satisfaction.

Based on the scenario above, answer the following question.

Based on scenario 8, has SecureLynx appropriately conducted management reviews?

A. No, management reviews should only occur when there are significant changes to the company's ISMS

B. No, ISO/IEC 27001 requires management reviews to be conducted annually

C. Yes, management reviews are intended to be conducted periodically

Answer: C

Question: 273

Scenario 8: SecureLynx is one Of the largest cybersecurity advisory and consulting companies that helps private sector organizations prevent security threats. improve security systems. and achieve business

SecureLynr is committed to complying with national and international standards to enhance the company'S resilience and credibility_ SecureLynx has Started implementing an ISMS based on ISO/IEC 27001

as part of its relentless pursuit of security.

As part of the internal audit activities. the top management reviewed and approved the audit objectives to assess the effectiveness of SecureLynx's ISMS During the audit, the internal auditor evaluated whether

top management Supports activities associated with the ISMS and if the toles and responsibilities Of relevant parties are Clearly defined. This rigorous examination is a testament to SecureLynx'S commitment to continuous improvement and alignment of security measures with organizational goals.

SecureLynx employs an innovative dashboard that visually represents implemented processes and controls to ensure transparency and accountability within the Organization. This tool Offers stakeholders a real-

time overview of security measures. empowering them to make informed decisions and swiftly

respond to emerging threats. As part of this initiative, Paula was appointed to a new position entrusted with the responsibility Of collecting, recording, and Stoting data to measure the effectiveness Of the ISMS- Furthermore, SecureLynx conducts management reviews every six months to ensure its Systems are robust and continually improving. These reviews serve as a crucial mechanism for assessing the efficacy Of security measures and identifying areas for enhancement. SecureLynx's dedication to implementing and maintaining a robust ISMS exemplifies its commitment to innovation and Client satisfaction. Based on the scenario above, answer the following question. Based on the description of Paula's responsibilities at SecureLynx, her role is known as:

- A. Information collector
- B. Information analyst
- C. Information communicator

Answer: B

Question: 274

Scenario 8: SecureLynx is one Of the largest cybersecurity advisory and consulting companies that helps private sector organizations prevent security threats. improve security systems. and achieve business

SecureLynr is committed to complying with national and international standards to enhance the company'S resilience and credibility_ SecureLynx has Started implementing an ISMS based on ISO/IEC 27001

as part of its relentless pursuit of security.

As part of the internal audit activities. the top management reviewed and approved the audit objectives to assess the effectiveness of SecureLynx's ISMS During the audit, the internal auditor evaluated whether

top management Supports activities associated with the ISMS and if the toles and responsibilities Of relevant parties are Clearly defined. This rigorous examination is a testament to SecureLynx'S commitment to continuous improverment and alignment of security measures with organizational goals.

SecureLynx employs an innovative dashboard that visually represents implemented processes and controls to ensure transparency and accountability within the Organization. This tool Offers stakeholders a real-

time overview of security measures. empowering them to make informed decisions and swiftly respond to emerging threats. As part of this initiative, Paula was appointed to a new position entrusted with the

responsibility Of collecting, recording, and Stoting data to measure the effectiveness Of the ISMS- Furthermore, SecureLynx conducts management reviews every six months to ensure its Systems are robust and continually improving. These reviews serve as a crucial mechanism for assessing the efficacy Of security measures and identifying areas for enhancement. SecureLynx's dedication to implementing

and maintaining a robust ISMS exemplifies its commitment to innovation and Client satisfaction.

Based on the scenario above, answer the following question.

Based on scenario 8, which internal audit activity is the internal auditor at SecureLynx performing?

- A. Evaluation of the ISMS governance
- B. Evaluation of the information security objectives
- C. Evaluation of the risk management process

Answer: A

Question: 275

According to ISO/IEC 27001, what shall the organization determine regarding monitoring and measurement?

Scenario 8: SecureLynx is one Of the largest cybersecurity advisory and consulting companies that helps private sector organizations prevent security threats. improve security systems. and achieve business

SecureLynx is committed to complying with national and international standards to enhance the company'S resilience and credibility_ SecureLynx has Started implementing an ISMS based on ISO/IEC 27001

as part of its relentless pursuit of security.

As part of the internal audit activities. the top management reviewed and approved the audit objectives to assess the effectiveness of SecureLynx's ISMS During the audit, the internal auditor evaluated whether

top management Supports activities associated with the ISMS and if the toles and responsibilities Of relevant parties are Clearly defined. This rigorous examination is a testament to SecureLynx'S commitment to continuous improverment and alignment of security measures with organizational goals.

SecureLynx employs an innovative dashboard that visually represents implemented processes and controls to ensure transparency and accountability within the Organization. This tool Offers stakeholders a real-

time overview of security measures. empowering them to make informed decisions and swiftly respond to emerging threats. As part of this initiative, Paula was appointed to a new position entrusted with the

responsibility Of collecting, recording, and Stoting data to measure the effectiveness Of the ISMS-

Furthermore, SecureLynx conducts management reviews every six months to ensure its Systems are robust and continually improving. These reviews serve as a crucial mechanism for assessing the efficacy Of

security measures and identifying areas for enhancement. SecureLynx's dedication to implementing and maintaining a robust ISMS exemplifies its commitment to innovation and Client satisfaction.

Based on the scenario above, answer the following question.

- A. The number of attributes to be measured
- B. The methods for monitoring, measurement, analysis, and evaluation
- C. The frequency of analysis and evaluation

Answer: B

Question: 276

What is the main difference between an audit program and an audit plan?

- A. An audit program outlines the activities and arrangements for a particular audit, while an audit plan provides an overarching framework for a series of audits with specific timelines and purposes
- B. An audit program outlines the overarching framework for a series of audits with specific timelines and purposes, while an audit plan outlines the activities and arrangements for a particular audit
- C. An audit program outlines policies, procedures, or requirements for reference in audit evidence comparison, while an audit plan provides an overarching framework for a series of audits with specific timelines and purposes

Answer: B

Question: 277

Which feedback relates specifically to information security performance during management review?

- A. Opportunities for continual improvement
- B. Risk assessment results
- C. Nonconformities and corrective actions

Answer: B

Question: 278

An organization has compared its actual performance against predetermined performance targets. What is the primary purpose of this action?

- A. To verify that all security incidents are resolved
- B. To assess whether the organization's security objectives are being met
- C. To eliminate the need for manual tracking and reporting

Answer: B

Question: 279

What is the purpose of an internal audit charter?

- A. To outline how the organization benefits from internal audits, especially in achieving its objectives
- B. To outline the assessment of collected audit evidence against predefined audit criteria
- C. To outline the audit results, considering the audit objectives and all findings

Answer: A

Question: 280

SkyFleet did not submit action plans within the specified deadline and was not recommended for certification. Is this acceptable?

- A. No, SkyFleet should receive an extension
- B. No, SkyFleet should be recommended for certification
- C. Yes, SkyFleet should not be recommended for certification

Answer: C

Question: 281

How can SkyFleet demonstrate its ongoing commitment to continual improvement in information security?

- A. By letting employees take independent action ensures swift problem resolution
- B. By outsourcing its information security responsibilities to a third-party vendor
- C. By publishing an annual report on information security performance

Answer: C

Question: 282

Scenario 9: SkyFleet specializes in air freight services, providing fast and reliable transportation solutions for businesses that need quick delivery of goods across long distances. Given the confidential nature of the information it handles, SkyFleet is committed to maintaining the highest information security standards. To achieve this, the company has had an information security management system (ISMS) based on ISO/IEC 27001 in operation for a year. To enhance its reputation, SkyFleet is pursuing certification against ISO/IEC 27001.

SkyFleet strongly emphasizes the ongoing maintenance of information security. In pursuit of this goal, it has established a rigorous review process, conducting in-depth assessments of the ISMS strategy every two years to ensure security measures remain robust and up to date. In addition, the company takes a balanced approach to nonconformities. For example, when employees fail to follow proper data encryption protocols for internal communications, SkyFleet assesses the nature and scale of this nonconformity. If this deviation is deemed minor and limited in scope, the company does not prioritize immediate resolution. However, a significant action plan was developed to address a major nonconformity involving the revamp of the company's entire data management system to ensure the protection of client data.

a. SkyFleet entrusted the approval of this action plan to the employees directly responsible for implementing the changes. This streamlined approach ensures that those closest to the issues actively engage in the resolution process. SkyFleet's blend of innovation, dedication to information security, and adaptability has built its reputation as a key player in the IT and communications services sector.

Despite initially not being recommended for certification due to missed deadlines for submitting required action plans, SkyFleet undertook corrective measures to address these deficiencies in preparation for the next certification process. These measures involved analyzing the root causes of the delay, developing a corrective action plan, reassessing ISMS implementation to ensure compliance with ISO/IEC 27001 requirements, intensifying internal audit activities, and engaging with a certification body for a follow-up audit.

According to Scenario 9, has SkyFleet accurately established the appropriate frequency for reviewing its ISMS Strategy?

- A. Yes. SkyFleet should review its ISMS every two years
- B. No. Reviews are only necessary when significant changes in business operations occur
- C. No. SkyFleet should conduct at least an annual review of the ISMS

Answer: C

Question: 283

Scenario 9: SkyFleet specializes in air freight services, providing fast and reliable transportation solutions for businesses that need quick delivery of goods across long distances. Given the confidential nature of the information it handles, SkyFleet is committed to maintaining the highest

information security standards. To achieve this, the company has had an information security management system (ISMS) based on ISO/IEC 27001 in operation for a year. To enhance its reputation, SkyFleet is pursuing certification against ISO/IEC 27001.

SkyFleet strongly emphasizes the ongoing maintenance of information security. In pursuit of this goal, it has established a rigorous review process, conducting in-depth assessments of the ISMS strategy every two years to ensure security measures remain robust and up to date. In addition, the company takes a balanced approach to nonconformities. For example, when employees fail to follow proper data encryption protocols for internal communications, SkyFleet assesses the nature and scale of this nonconformity. If this deviation is deemed minor and limited in scope, the company does not prioritize immediate resolution. However, a significant action plan was developed to address a major nonconformity involving the revamp of the company's entire data management system to ensure the protection of client data.

a. SkyFleet entrusted the approval of this action plan to the employees directly responsible for implementing the changes. This streamlined approach ensures that those closest to the issues actively engage in the resolution process. SkyFleet's blend of innovation, dedication to information security, and adaptability has built its reputation as a key player in the IT and communications services sector.

Despite initially not being recommended for certification due to missed deadlines for submitting required action plans, SkyFleet undertook corrective measures to address these deficiencies in preparation for the next certification process. These measures involved analyzing the root causes of the delay, developing a corrective action plan, reassessing ISMS implementation to ensure compliance with ISO/IEC 27001 requirements, intensifying internal audit activities, and engaging with a certification body for a follow-up audit.

Based on Scenario 9, SkyFleet did not take any measures in certain situations when the employees do not behave as expected by procedures and policies. Is this acceptable?

- A. Yes, as it pertains to a limited number of employees and is not deemed a significant concern
- B. Yes, it is acceptable when the issues are limited in scope
- C. No, they should have taken action to control and correct it
- D. Yes, if the ISMS review is pending

Answer: C

Question: 284

Scenario 9: SkyFleet specializes in air freight services, providing fast and reliable transportation solutions for businesses that need quick delivery of goods across long distances. Given the confidential nature of the information it handles, SkyFleet is committed to maintaining the highest information security standards. To achieve this, the company has had an information security management system (ISMS) based on ISO/IEC 27001 in operation for a year. To enhance its reputation, SkyFleet is pursuing certification against ISO/IEC 27001.

SkyFleet strongly emphasizes the ongoing maintenance of information security. In pursuit of this goal, it has established a rigorous review process, conducting in-depth assessments of the ISMS strategy every two years to ensure security measures remain robust and up to date. In addition, the company takes a balanced approach to nonconformities. For example, when employees fail to follow proper data encryption protocols for internal communications, SkyFleet assesses the nature and scale of this nonconformity. If this deviation is deemed minor and limited in scope, the company does not prioritize immediate resolution. However, a significant action plan was developed to address a major nonconformity involving the revamp of the company's entire data management system to ensure the protection of client data.

a. SkyFleet entrusted the approval of this action plan to the employees directly responsible for implementing the changes. This streamlined approach ensures that those closest to the issues actively engage in the resolution process. SkyFleet's blend of innovation, dedication to information security, and adaptability has built its reputation as a key player in the IT and communications services sector.

Despite initially not being recommended for certification due to missed deadlines for submitting required action plans, SkyFleet undertook corrective measures to address these deficiencies in preparation for the next certification process. These measures involved analyzing the root causes of the delay, developing a corrective action plan, reassessing ISMS implementation to ensure compliance with ISO/IEC 27001 requirements, intensifying internal audit activities, and engaging with a certification body for a follow-up audit.

According to scenario 9, has SkyFleet accurately outlined the responsible party for approving its action plan for the revamp of the company's entire data management system?

- A. Yes, the employees directly involved in implementing the actions should approve the action plans
- B. No, the responsibility for approving action plans lies on top management
- C. No, an independent third party should be responsible for approving action plans
- D. Yes, any employee can approve as long as they are part of the team

Answer: B

Question: 285

What is the primary requirement for the documented information of an ISMS?

- A. It must exist solely in a digital format to ensure modern compatibility
- B. It must be sufficiently flexible to adapt to any identified change triggers
- C. It must be accessible to the public at all times to maintain transparency
- D. It must be controlled, maintained, and available as necessary to support the operation of the ISMS

Answer: D

Question: 286

Scenario 10: CircuitLinking is a company specializing in water purification solutions, designing and manufacturing efficient filtration and treatment systems for both residential and commercial applications. Over the past two years, the company has actively implemented an integrated management system (IMS) that aligns with both ISO/IEC 27001 for information security and ISO 9001 for quality management. Recently, the company has applied for a combined audit to achieve certification against both ISO/IEC 27001 and ISO 9001.

In preparation, CircuitLinking ensured a clear understanding of ISO/IEC 27001, identified subject-matter experts, allocated resources, and gathered documentation to provide evidence of effective procedures. After passing Stage 1 (focused on verifying the design), Stage 2 was conducted to examine implementation and effectiveness. An auditor with a potential conflict of interest was replaced at the company's request. The audit process continued, and the company was awarded certification.

During a later recertification audit, significant changes to the management system triggered a Stage 1 assessment to evaluate the impact.

Based on the scenario above, answer the following question:

During the Stage 1 audit, the auditor assessed the design of CircuitLinking's management system. Is this approach recommended?

- A. Yes, during the Stage 1 audit, the auditor should assess the design of the management system
- B. No, during the Stage 1 audit, the auditor should assess the auditee's physical infrastructure
- C. No, during the Stage 1 audit, the auditor should assess the effectiveness of the management system

Answer: A

Question: 287

Scenario 10: CircuitLinking is a company specializing in water purification solutions, designing and manufacturing efficient filtration and treatment systems for both residential and commercial applications. Over the past two years, the company has actively implemented an integrated management system (IMS) that aligns with both ISO/IEC 27001 for information security and ISO 9001 for quality management. Recently, the company has taken a significant step forward by applying for a combined audit, aiming to achieve certification against both ISO/IEC 27001 and ISO 9001.

In preparation for the certification audit, CircuitLinking ensured a clear understanding of ISO/IEC 27001 within the company, identified key subject-matter experts to assist the auditors, allocated sufficient resources, performed a self-assessment, and gathered all necessary documentation in advance. Following the successful completion of the Stage 1 audit (which focused on verifying the design of the management system), the Stage 2 audit was conducted to examine the implementation and effectiveness of the information security and quality management systems.

One of the auditors, Megan, was a previous employee of the company. To uphold the integrity of the certification process, the company notified the certification body about the potential conflict of interest and requested an auditor change. Subsequently, the certification body selected a replacement, ensuring impartiality. Additionally, the company requested a background check of the audit team members; however, the certification body denied this request. The necessary adjustments to the audit plan were made, and transparent communication with stakeholders was maintained.

The audit process continued seamlessly under the new auditor's guidance. Upon audit completion, the certification body evaluated the results and conclusions of the audit and CircuitLinking's public information, and awarded CircuitLinking the combined certification.

A recertification audit for CircuitLinking was conducted to verify that the company's management system continued to meet the required standards and remained effective within the defined scope of certification. CircuitLinking had implemented significant changes, including a major overhaul of its information security processes, new technology platforms, and adjustments to comply with recent legislative changes. Due to these updates, the recertification audit required a Stage 1 assessment to evaluate the impact.

Which of the following does NOT follow auditing best practices? Refer to Scenario 10.

- A. CircuitLinking's request for background information on audit team members being denied
- B. CircuitLinking applying for a combined audit
- C. The certification body evaluating the audit findings
- D. The company notifying the certification body about a conflict of interest

Answer: A

Question: 288

Scenario 10: CircuitLinking is a company specializing in water purification solutions, designing and manufacturing efficient filtration and treatment systems for both residential and commercial applications. Over the past two years, the company has actively implemented an integrated management system (IMS) that aligns with both ISO/IEC 27001 for information security and ISO 9001 for quality management. Recently, the company has taken a significant step forward by applying for a combined audit, aiming to achieve certification against both ISO/IEC 27001 and ISO 9001.

In preparation for the certification audit, CircuitLinking ensured a clear understanding of ISO/IEC 27001 within the company and identified key subject-matter experts to assist the auditors. It also allocated sufficient resources and performed a self-assessment to verify that processes were clearly defined, roles and responsibilities were segregated, and documented information was maintained. To avoid delays, the company gathered all necessary documentation in advance to provide evidence that procedures were in place and effective.

Following the successful completion of the Stage 1 audit, which focused on verifying the design of the management system, the Stage 2 audit was conducted to examine the implementation and effectiveness of the information security and quality management systems.

One of the auditors, Megan, was a previous employee of the company. To uphold the integrity of the certification process, the company notified the certification body about the potential conflict of interest and requested an auditor change. Subsequently, the certification body selected a replacement, ensuring impartiality. Additionally, the company requested a background check of the audit team members; however, the certification body denied this request. The necessary adjustments to the audit plan were made, and transparent communication with stakeholders was maintained.

The audit process continued seamlessly under the new auditor's guidance. Upon audit completion, the certification body evaluated the results and conclusions of the audit and CircuitLinking's public information and awarded CircuitLinking the combined certification.

A recertification audit for CircuitLinking was conducted to verify that the company's management system continued to meet the required standards and remained effective within the defined scope of certification. CircuitLinking had implemented significant changes to its management system, including a major overhaul of its information security processes, the adoption of new technology platforms, and adjustments to comply with recent changes in industry legislation. Due to these substantial updates, the recertification audit required a Stage 1 assessment to evaluate the impact of these changes.

According to Scenario 10, the certification body evaluated the results and conclusions of the audit and CircuitLinking's public information when making the certification decision. Is this acceptable?

- A. No, the certification body should also consider the auditor's opinions when making the certification decision
- B. No, the certification decision must be based solely on the audit findings, and no external information can be considered
- C. Yes, the certification body must make the certification decision based on other relevant information, such as public information
- D. No, only top management's input should be considered

Answer: C

Question: 289

Scenario 10: CircuitLinking is a company specializing in water purification solutions, designing and manufacturing efficient filtration and treatment systems for both residential and commercial applications. Over the past two years, the company has actively implemented an integrated management system (IMS) that aligns with both ISO/IEC 27001 for information security and ISO 9001 for quality management. Recently, the company has taken a significant step forward by applying for a combined audit, aiming to achieve certification against both ISO/IEC 27001 and ISO 9001.

In preparation for the certification audit, CircuitLinking ensured a clear understanding of ISO/IEC 27001 within the company and identified key subject-matter experts to assist the auditors. It also allocated sufficient resources and performed a self-assessment to verify that processes were clearly defined, roles and responsibilities were segregated, and documented information was maintained. To avoid delays, the company gathered all necessary documentation in advance to provide evidence that procedures were in place and effective.

Following the successful completion of the Stage 1 audit, which focused on verifying the design of the management system, the Stage 2 audit was conducted to examine the implementation and effectiveness of the information security and quality management systems.

One of the auditors, Megan, was a previous employee of the company. To uphold the integrity of the certification process, the company notified the certification body about the potential conflict of interest and requested an auditor change. Subsequently, the certification body selected a replacement, ensuring impartiality. Additionally, the company requested a background check of the audit team members; however, the certification body denied this request. The necessary adjustments to the audit plan were made, and transparent communication with stakeholders was maintained.

The audit process continued seamlessly under the new auditor's guidance. Upon audit completion, the certification body evaluated the results and conclusions of the audit and CircuitLinking's public information and awarded CircuitLinking the combined certification.

A recertification audit for CircuitLinking was conducted to verify that the company's management system continued to meet the required standards and remained effective within the defined scope of certification. CircuitLinking had implemented significant changes to its management system, including a major overhaul of its information security processes, the adoption of new technology platforms, and adjustments to comply with recent changes in industry legislation. Due to these substantial updates, the recertification audit required a Stage 1 assessment to evaluate the impact of these changes.

According to Scenario 10, the recertification audit activities at CircuitLinking included a Stage 1 audit. Is this acceptable?

- A. No, the stage 1 audit is only required for initial certification
- B. Yes, when there are significant changes to the management system, recertification audit activities may need to have a stage 1 audit
- C. No, the stage 1 audit is only required when unresolved nonconformities from the previous audit

cycle remain and have not been adequately addressed
D. No, stage 1 audits are only for new sites, not recertification

Answer: B

Question: 290

Scenario 10: CircuitLinking is a company specializing in water purification solutions, designing and manufacturing efficient filtration and treatment systems for both residential and commercial applications. Over the past two years, the company has actively implemented an integrated management system (IMS) that aligns with both ISO/IEC 27001 for information security and ISO 9001 for quality management. Recently, the company has taken a significant step forward by applying for a combined audit, aiming to achieve certification against both ISO/IEC 27001 and ISO 9001.

In preparation for the certification audit, CircuitLinking ensured a clear understanding of ISO/IEC 27001 within the company and identified key subject-matter experts to assist the auditors. It also allocated sufficient resources and performed a self-assessment to verify that processes were clearly defined, roles and responsibilities were segregated, and documented information was maintained. To avoid delays, the company gathered all necessary documentation in advance to provide evidence that procedures were in place and effective.

Following the successful completion of the Stage 1 audit, which focused on verifying the design of the management system, the Stage 2 audit was conducted to examine the implementation and effectiveness of the information security and quality management systems.

One of the auditors, Megan, was a previous employee of the company. To uphold the integrity of the certification process, the company notified the certification body about the potential conflict of interest and requested an auditor change. Subsequently, the certification body selected a replacement, ensuring impartiality. Additionally, the company requested a background check of the audit team members; however, the certification body denied this request. The necessary adjustments to the audit plan were made, and transparent communication with stakeholders was maintained.

The audit process continued seamlessly under the new auditor's guidance. Upon audit completion, the certification body evaluated the results and conclusions of the audit and CircuitLinking's public information and awarded CircuitLinking the combined certification.

A recertification audit for CircuitLinking was conducted to verify that the company's management system continued to meet the required standards and remained effective within the defined scope of certification. CircuitLinking had implemented significant changes to its management system, including a major overhaul of its information security processes, the adoption of new technology platforms, and adjustments to comply with recent changes in industry legislation. Due to these substantial updates, the recertification audit required a Stage 1 assessment to evaluate the impact of these changes.

According to Scenario 10, is the request made by CircuitLinking to replace Megan acceptable?

- A. Yes, but no other auditor should have been assigned in her place
- B. No, as long as she remains impartial, she can audit CircuitLinking
- C. Yes, considering her past as an employee for CircuitLinking
- D. No, only the same auditor can complete the full audit cycle

Answer: C

**Thank You for Purchasing ISO-IEC-27001-LEAD-
IMPLEMENTER PDF**

Test Your Preparation with Practice Exam Software

Use Coupon “**20OFF**” for extra 20% discount on purchase of Practice Test Software. Practice Exam Software helps you validate your preparation in simulated exam environment.

Download Free Practice Test Demo from Here:

[https://www.study4exam.com/ISO-IEC-27001-LEAD-
IMPLEMENTER.html](https://www.study4exam.com/ISO-IEC-27001-LEAD-IMPLEMENTER.html)

<https://www.study4exam.com>